

Contenido

1	Introducción al tema de investigación	1
2	Antecedentes	4
3	Análisis del objeto de estudio	6
4	Identificación y formulación del problema de investigación	6
4.1	Planteamiento del problema	6
4.2	Formulación de la pregunta de investigación.....	7
5	Objetivos	7
5.1	Objetivo general.....	7
5.2	Objetivos específicos	7
6	Límites y alcances	7
6.1	Límites.....	7
6.2	Alcances.....	8
7	Justificación	8
7.1	Justificación Teórica.....	8
7.2	Justificación Metodológica	9
8	Marco teórico	9
8.1	Conceptos básicos	9
8.1.1	Seguridad informática	9
8.1.2	IDS	21
8.1.3	CRISP - DM.....	27
8.1.4	Minería de datos	29
9	Análisis del Proyecto	39
10	Diseño del Proyecto.....	39
10.1	Análisis de los datos (Estadístico y Gráfico)	46
10.2	Selección de Variables	57
10.2.1	Chi Cuadrado	58
10.2.2	Ganancia de Información	59
10.2.3	Correlación	61
10.2.4	Promedio análisis de pesos	62
10.3	Correlación de Variables	65
10.4	Primer Estudio Experimental a nivel ataque o normal.....	66
10.4.1	Preparación de datos.....	66

10.4.2	Árbol de decisión	68
10.4.3	Naive Bayes	72
10.4.4	Random Forest	74
10.4.5	Red Neuronal	78
10.5	Segundo Estudio Experimental a nivel de 5 categorías.....	80
10.5.1	Preparación de datos.....	80
10.5.2	Árbol de decisión	81
10.5.3	Naive Bayes	86
10.5.4	Random Forest	89
10.6	Tercer Estudio Experimental a nivel de ataque	94
10.6.1	Preparación de datos.....	94
10.6.2	Árbol de decisión	96
10.6.3	Naive Bayes	99
10.6.4	Random Forest	102
11	Conclusiones y Recomendaciones.....	106
11.1	Conclusiones.....	106
11.2	Recomendaciones.....	106
	Bibliografía	107

Ilustración

Ilustración 1: Gráfica que muestra nº incidentes reportados al CERT	16
Ilustración 2: Sofisticación de los ataques vs. Conocimiento técnico del intruso.....	17
Ilustración 3: Clasificación de los IDS	23
Ilustración 4: Esquema general de un Sistema de Detección de Intrusiones.....	24
Ilustración 5: IDS basado en anomalías	26
Ilustración 6: Metodología CRISP-DM	27
Ilustración 7: Tabla de Resultados Análisis RapidMiner (Elaboración Propia).....	51
Ilustración 8: Gráfico Distribución Tiempo de Conexión - Clase (Elaboración Propia)	52
Ilustración 9: Gráfico Distribución (Tipo de Protocolo - Clase) Elaboración Propia.....	52
Ilustración 10: Gráfico Distribución (Servicio - Clase) Elaboración Propia.....	53
Ilustración 11: Gráfico Distribución (Flag - Clase) Elaboración Propia	53
Ilustración 12: Gráfico Distribución (Bytes transmitidos Fuente - Clase) Elaboración Propia	54
Ilustración 13: Gráfico Distribución (Bytes transmitidos Destino - Clase) Elaboración Propia	54
Ilustración 14: Gráfico Distribución (Land - Clase) Elaboración Propia.....	55
Ilustración 15: Gráfico Distribución (Fragmentos Errados - Clase) Elaboración Propia	55
Ilustración 16: Frecuencia Tipo de Protocolo (Elaboración Propia)	56
Ilustración 17: Frecuencia por tipo de servicio (Elaboración Propia)	56
Ilustración 18: Frecuencia por tipo de flag (Elaboración Propia)	57
Ilustración 19: Gráfico de la distribución de registros de la muestra.....	67
Ilustración 20: Proceso Estudio I (Ataque - Normal).....	68
Ilustración 21: Proceso de entrenamiento y prueba Estudio I (Ataque - Normal).....	68
Ilustración 22: Árbol de decisión Estudio I.....	69
Ilustración 23: Proceso Estudio I (Ataque - Normal).....	72
Ilustración 24: Proceso de entrenamiento y prueba Estudio I (Ataque - Normal).....	72
Ilustración 25: Distribución Simple Estudio I.....	73
Ilustración 26: Proceso Estudio I (Ataque - Normal).....	74
Ilustración 27: Proceso de entrenamiento y prueba Estudio I (Ataque - Normal)	74
Ilustración 28: Random Forest (Modelo I) Estudio I.....	75
Ilustración 29: Proceso Estudio I (Ataque - Normal).....	78
Ilustración 30: Proceso de entrenamiento y prueba Estudio I (Ataque - Normal)	78
Ilustración 31: Red Neuronal (Modelo I) Estudio I.....	79
Ilustración 32: Gráfico de la distribución de registros de la muestra.....	80
Ilustración 33: Proceso Estudio II	81
Ilustración 34: Proceso de entrenamiento y prueba Estudio II	81
Ilustración 35: Árbol de decisión Estudio II.....	82
Ilustración 36: Proceso Estudio II (Cinco categorías).....	86
Ilustración 37: Proceso de entrenamiento y prueba Estudio II (Cinco categorías)	87
Ilustración 38: Distribución Simple Estudio II.....	88
Ilustración 39: Proceso Estudio II (Cinco Categorías).....	89
Ilustración 40: Proceso de entrenamiento y prueba Estudio II (Cinco Categorías)	89
Ilustración 41: Random Forest (Modelo II) Estudio II	90

Ilustración 42: Gráfico de la distribución de registros de la muestra.....	95
Ilustración 43: Proceso Estudio III (Ataques).....	96
Ilustración 44: Proceso de entrenamiento y prueba Estudio III (Ataques)	96
Ilustración 45: Árbol de decisión Estudio III	97
Ilustración 46: Proceso Estudio I (Ataque - Normal).....	99
Ilustración 47: Proceso de entrenamiento y prueba Estudio III (Ataques)	100
Ilustración 48: Distribución Simple Estudio III.....	101
Ilustración 49: Proceso Estudio III (Ataques).....	102
Ilustración 50: Proceso de entrenamiento y prueba Estudio III (Ataques)	103
Ilustración 51: Random Forest (Modelo III) Estudio III	104

Tablas

Tabla 1: Cuadro de peso obtenido con Chi Cuadrado	59
Tabla 2: Cuadro de peso obtenido con Information Gain	61
Tabla 3: Cuadro de peso obtenido con Correlación	62
Tabla 4: Cuadro de peso promedio	64
Tabla 5: Cuadro de las variables seleccionadas	65
Tabla 6: Correlación de variables seleccionadas para investigación.....	65
Tabla 7: Precisión con Árbol de decisión.....	69
Tabla 8: Precisión con Naive Bayes.....	73
Tabla 9: Precisión con Random Forest.....	75
Tabla 10: Precisión con Red Neuronal	79
Tabla 11: Precisión con Árbol de decisión	82
Tabla 12: Precisión con Naive Bayes.....	87
Tabla 13: Precisión con Random Forest	90
Tabla 14: Precisión con Árbol de decisión	97
Tabla 15: Precisión con Naive Bayes.....	100
Tabla 16: Precisión con Random Forest	103

1 Introducción al tema de investigación

“Detección de Intrusiones mediante Técnicas de minería de datos”

A partir de la invención de los ordenadores hasta nuestros días, su cantidad e importancia en las actividades cotidianas ha ido en aumento dentro de nuestra sociedad. Al experimentar este crecimiento también la posibilidad de interconectarlos mediante la creación de redes, surgieron nuevos retos y aplicaciones.

Durante estos años hemos podido comprobar que las redes de ordenadores facilitan el trabajo, la comunicación y la coordinación de los diferentes departamentos de una empresa, sea cual sea su situación geográfica. Esto, unido a la expansión de Internet y al número de clientes potenciales que ofrece Internet, hace que lo que era una red de ordenadores corta y de fácil administración pase a ser una extensa y compleja red donde recae la responsabilidad de comunicación y la necesidad de darse a conocer ofreciendo sus productos u ofertas.

Por este motivo y debido a la importancia que han adquirido las redes de ordenadores para el desarrollo empresarial actual, se hace necesario desarrollar una política de seguridad de las redes de ordenadores a toda la estructura empresarial. Todos los días aparecen noticias de empresas atacadas por hackers en las cuales toda la información de sus clientes ha sido sustraída o cuyos servidores que proporcionan conexión con Internet, ha dejado de funcionar.

Es en este contexto donde surgen nuevos conceptos referentes a la seguridad de las redes de ordenadores, como la vulnerabilidad y los ataques, tanto internos como externos. La diferencia entre los dos términos, es que la vulnerabilidad es referente a errores software o de configuración que pueden permitir a un intruso acceder a un sistema mientras que un ataque es un intento de explotar una vulnerabilidad en ese sistema. Las vulnerabilidades son los caminos para realizar los ataques. Por lo tanto

debemos estar atentos a las vulnerabilidades y a las actualizaciones que evitan estas vulnerabilidades y por lo tanto, los posibles ataques.

(Borghello, 2014) “Un sistema de detección de intrusos es un componente más dentro del modelo de seguridad de una organización. Consiste en detectar actividades inapropiadas, incorrectas o anómalas desde el exterior-interior de un sistema informático.” ¹

La seguridad informática en las organizaciones se ha convertido en un elemento crítico para el resguardo de la información, en la cual la detección de intrusos busca evitar ataques que puedan afectar de diferentes maneras a estas.

La tendencia que se vive en la actualidad, en la cual el conocimiento se ha convertido en la materia prima por así decirlo para lograr crecimiento en base a la toma de decisiones correctas basadas en la información proporcionada por diferentes fuentes.

Una manera de afrontar eficazmente estos retos es mediante la minería de grandes almacenes de datos presentes en las redes de datos. La minería de datos permite a las organizaciones descubrir y conocer los patrones ocultos en grandes volúmenes de datos. A continuación, estos patrones se incorporan en modelos de minería de datos y se utilizan para pronosticar las conductas individuales con gran precisión.

La investigación que se realiza ayudará a poder generar conocimiento acerca de los ataques de intrusión y cuáles son las técnicas de minería de datos que más se adecuan a cada uno de estos ataques, para poder mejorar la detección de intrusiones en los IDS.

¹ Borghello, Cristian (20 de Abril de 2014). Seguridad de la Información. Obtenido de <http://www.seguinfo.com.ar/proteccion/deteccion.htm>

Esta tesis se organiza con de la siguiente manera:

1. Introducción al tema de investigación: Este apartado da a conocer de una manera genérica sin mucho detalle el tema de la investigación y el aporte de este estudio.
2. Antecedentes: Se explica los estudios anteriores que se han realizado sobre el tema para poder sustentar la aplicabilidad de la tesis, no repitiendo un estudio que ya se hubiera realizado.
3. Análisis del objeto de estudio: Se explica que vamos a estudiar y de qué manera pensamos abordar el tema.
4. Identificación y formulación del problema: Se trata de explicar cuál es el problema que se ha identificado, para formular la pregunta de la investigación, que se convierte en el eje sobre el cual esta investigación se moverá.
5. Objetivos: En este punto se explica los objetivos que persigue la investigación los cuales deben ser verificados al final.
6. Límites y alcances: Se explica hasta donde llegará la investigación y cuáles son los puntos que no se abordarán en este trabajo.
7. Justificación: Se aborda las perspectivas las cuales dan sustento al trabajo.
8. Marco teórico: Se explican las bases teóricas en las cuales se fundamenta la investigación.
9. Análisis preliminar del proyecto: Se realiza una evaluación preliminar del estado del arte en el cual se encuentra hoy en día el tema de investigación, su aplicabilidad en el mundo real.
10. Propuesta de Solución: Se propone una solución para el problema planteado en el punto 4, podríamos decir que se realiza una descripción de todos los pasos a seguir para la obtención de los objetivos.

2 Antecedentes

(Britos, 2010) “En el presente trabajo se proponen modelos estadísticos y clasificadores multivariantes para detectar perfiles de tráfico anómalos, como así también el uso de clasificadores basados en redes neuronales o en agentes cooperantes.”²

En el análisis propuesto y realizado en esta investigación se utilizaron redes neuronales y colonia de hormigas para poder realizar la detección de intrusos, en la cual se pudo evidenciar que de una manera muy sencilla se podía entrenar a la red neuronal para poder distinguir entre condiciones normales y condiciones de ataque.

La ACCM de aprendizaje supervisado ha logrado mejorar el agrupamiento logrado utilizando la colonia de hormigas y se vuelve insensible ante los valores extremos.

(Campoy, 2011) “Las aplicaciones técnicas basadas en Lógica Borrosa para la detección de intrusos (IDS), están demostrando ser un enfoque adecuado para solucionar muchos de los problemas de seguridad. Esta investigación propone el modelo teórico necesario para el desarrollo de un método de detección de intrusos web basados en lógica difusa, diseñado para identificar el ataque mediante reglas y ofrecer el grado del ataque mediante lógica difusa.”³

Este proyecto realizó una propuesta teórica para la detección de intrusos mediante lógica borrosa, utilizando los weblogs donde se pueden establecer las reglas por medio de la experiencia humana.

(Pinzón Trejos, 2010) “Finalmente, la nueva estrategia de detección diseñada en la arquitectura AIDeMaS incorpora técnicas y algoritmos de aprendizaje automático.

² Britos, J. D. (1 de Septiembre de 2010). Detección de Instrucciones en redes de datos con captura distribuida y procesamiento estadístico. La Plata, Argentina: Universidad Nacional de La Plata.

³ Campoy, D. (2011). Propuesta teórica de Webmining para detección de Intrusos mediante lógica borrosa.

La identificación de intrusiones representa una de las tareas más complicadas en la detección de intrusiones.”⁴

Algunos aspectos de AIDeMaS, tales como el tiempo de respuesta o la curva de aprendizaje inicial puede ser una desventaja con respecto a las soluciones existentes. Sin embargo, AIDeMaS proporciona una manera más eficiente de clasificación una vez que el sistema ha adquirido experiencia, además de mejorar el tiempo de respuesta. A través de los resultados obtenidos en los experimentos y de las comparaciones realizadas, podemos concluir que la arquitectura AIDeMaS presenta características novedosas que no han sido consideradas en los enfoques previos y que aportan características importantes para resolver diferentes tipos de ataques XDoS y ataques de inyección SQL.

(González Márquez, 2009) “Los sistemas de detección nos permiten detectar la presencia de personas ajenas a un sistema (red, aplicaciones, ordenadores, información) estos buscan prevenir o reconocer un patrón mediante la aplicación de metodologías basadas en perfiles, las cuales emplean diversas técnicas para lograr su objetivo.”⁵

Este proyecto se basa en el uso de reglas para poder reconocer los patrones que se utilizan para diferentes tipos de ataques que logren pasar sin ser detectados hasta los hosts.

(Vallejo & Germán, 2012) “Con base a los fundamentos y técnicas de la minería de datos se pueden diseñar y elaborar modelos que permiten encontrar comportamientos clandestinos de fácil detección a simple vista como lo es la

⁴ Pinzón Trejos, C. I. (2010). Arquitectura multi-agente adaptativa para la detección de ataques en entornos dinámicos y distribuidos. Salamanca, España: Universidad de Salamanca.

⁵ González Márquez, V. (2009). Sistema de detección de intrusos basado en sistemas expertos. Distrito Federal, Mexico: Instituto Politécnico Nacional.

información no evidente desconocida a priori y potencialmente útil en referencia a hechos determinados.”⁶

Se ha utilizado la metodología CRISP-DM para generar un modelo que utilice diferentes algoritmos de minería de datos para poder generar datos estadísticos de los ataques de intrusión, y poder determinar las mejores prácticas para poder neutralizar dichos ataques.

3 Análisis del objeto de estudio

El objeto de estudio es la detección de intrusiones en redes de datos, divididas por el tipo de ataque o intrusión que realiza el atacante.

Se va a utilizar la inteligencia de Negocio como medio estratégico para poder generar el conocimiento necesario a través del análisis de datos por medio de sus herramientas lo cual nos permitirá lograr el objetivo trazado para el presente proyecto.

4 Identificación y formulación del problema de investigación

4.1 Planteamiento del problema

Los ordenadores se han convertido en un elemento imprescindible para nuestras vidas. Hoy en día empresas, instituciones, universidades y particulares están presentes en Internet de forma que cualquier usuario del planeta puede acceder a información, compra-venta, transacción o entretenimiento a través de la red.

Algunos datos que se manejan deben mantenerse a salvo de cualquier intrusión de modo que la seguridad en este tipo de actividades tiene una importancia crítica.

La minería de datos es el proceso de ahondar en los datos para detectar patrones y relaciones ocultos; emplea una orientación empresarial clara y potentes

⁶ Vallejo, D., & Germán, T. (2012). Minería de datos aplicada en la detección de intrusos. Medellin, Colombia: usbmed.

tecnologías analíticas para explorar rápida y concienzudamente montañas de datos y extraer de ellas la información útil y aplicable que se necesita.

4.2 Formulación de la pregunta de investigación

¿Cuáles son los algoritmos más apropiados para los diferentes tipos de ataques en la detección de intrusos en la red de datos?

5 Objetivos

5.1 Objetivo general

Aplicar las técnicas de minería de datos más apropiados para cada tipo de ataque en la detección de intrusos en la red de datos.

5.2 Objetivos específicos

- Hacer un estudio, de tal manera seleccionar los atributos.
- Detectar los elementos que se consideran ruido
- Realizar la eliminación del ruido.
- Discretizar las variables de acuerdo a la utilización de las técnicas de minería de datos.
- Analizar el comportamiento del modelo desde dos perspectivas:
 - a. Clasificación en categorías.
 - b. Clasificación a nivel de ataque.
- Evaluar la capacidad de cada algoritmo en el modelo.

6 Límites y alcances

6.1 Límites

- No se va a realizar la implementación de los diferentes algoritmos y la forma que se usan en un Intrusion Detection System.
- Se va a utilizar solamente los datos de la simulación realizada por una universidad norteamericana.
- Se va a utilizar características de conexiones TCP, conexiones de dominio y de tráfico computadas en ventanas de 2 segundos.

6.2 Alcances

- Realizar la exploración de los datos.
- Realizar la reducción de datos.
- Evaluar cada una de las variables.
- Identificar las variables más representativas.
- Generar una vista minable.
- Aplicar técnicas de minería de datos de acuerdo a las características de los tipos de ataques.
- Valorar técnicas de minería de datos con cada uno de los ataques para definir el más apropiado para cada uno.

7 Justificación

7.1 Justificación Teórica

Esta tendencia que busca aprovechar los recursos que existen sobre aplicaciones y prácticas enfocadas a la toma de decisiones ha venido teniendo demasiado auge en las directivas de todo tipo de empresas. Incluso los desarrolladores de software que implementan motores de base de datos ya incluyen módulos para realizar análisis sobre la información que está contenida para generar nuevo conocimiento. Esta fuerte tendencia no es ajena a este proyecto, y poder mostrar como un análisis con herramientas computacionales afecta una empresa (y así otras que puedan verse beneficiadas con los resultados) es un objetivo intrínseco del proyecto.

Todas las empresas que manejan información tienen un conocimiento en bruto, no explotado. Este es uno de los principios claves de la metodología CRISP – DM, la cual busca lograr extraer, con fines de aprovechamiento, conocimiento nuevo. Se debe aclarar que el objetivo de la metodología en ningún momento es el de informar la situación de la base en un momento dado, para eso están otros sistemas de informes como OLAP, en el caso de la minería de datos el objetivo es analizar tendencias sobre una cantidad de información que la mayoría de empresas no saben (o simplemente no quieren) aprovechar.

El proyecto busca descubrir patrones para poder identificar los ataques que se realizan a una red de datos, estos patrones pueden variar de acuerdo a la técnica y al tipo de ataque, lo que se busca con el proyecto es poder dar el conocimiento de cuál es la mejor técnica de minería de datos en cada tipo de ataque que ayude a reducir los falsos positivos dando un porcentaje de fiabilidad para su detección.

El proyecto propuesto busca, mediante la aplicación de técnicas de minería de datos como redes neuronales, Naive Bayes, Random Forest, árboles de decisión y red neuronal para lograr predecir bajo ciertos comportamientos si una red está siendo objeto de un ataque.

7.2 Justificación Metodológica

La metodología de CRISP-DM está descrita en términos de un modelo de proceso jerárquico, consistente en un conjunto de tareas descritas en cuatro niveles de abstracción (de lo general a lo específico): fase, tarea genérica, tarea especializada, e instancia de procesos.

La investigación será explicativa puesto que se quiere encontrar las mejores técnicas para utilizarlas en un IDS en la evaluación de patrones que indiquen que se trata de un ataque o no y además predictiva puesto que se pueda predecir el comportamiento en cuanto al comportamiento de los ataques en una red de datos.

8 Marco teórico

8.1 Conceptos básicos

8.1.1 Seguridad informática

La seguridad informática consiste en asegurar que los recursos del sistema de información (material informático o programas) de una organización, sean utilizados de la manera que se decidió y que el acceso a la información allí contenida, así como su modificación, sólo sea posible a las personas que se encuentren acreditadas y dentro de los límites de su autorización.

Podemos definir la Seguridad Informática como el cumplimiento de confidencialidad, integridad y disponibilidad en un sistema informático [Rus91]. La confidencialidad requiere que la información sea accesible únicamente por aquellos que estén autorizados, la integridad que la información se mantenga inalterada ante accidentes o intentos maliciosos, es decir la información sólo puede ser modificada por quien está autorizado y de manera controlada y la disponibilidad significa que el sistema informático se mantenga trabajando sin sufrir ninguna degradación en cuanto a accesos y provea los recursos que requieran los usuarios autorizados cuando éstos los necesiten.

8.1.1.1 Elementos de la Seguridad Informática

Políticas de Seguridad: En cualquier entorno en el que tengamos datos o información que hay que proteger no sólo son importantes las herramientas de las que disponemos para proteger dicha información sino también el disponer de una buena política de Seguridad.

Las políticas de seguridad informática surgen como una herramienta organizacional para concienciar a los colaboradores de la organización sobre la importancia y sensibilidad de la información y servicios críticos que permiten a la empresa crecer y mantenerse competitiva. No se puede considerar que una política de seguridad informática es una descripción técnica de mecanismos, ni una expresión legal que involucre sanciones a conductas de los empleados, es más bien una descripción de lo que deseamos proteger y el por qué de ello y cómo lograrlo, pues cada política de seguridad es una invitación a cada uno de sus miembros a reconocer la información como uno de sus principales activos así como, un motor de intercambio y desarrollo en el ámbito de sus negocios.

Las Políticas de Seguridad Informática deben considerar principalmente los siguientes elementos:

- Alcance de las políticas, incluyendo facilidades, sistemas y personal sobre la cual aplica.
- Objetivos de la política y descripción clara de los elementos involucrados en su definición.
- Responsabilidades por cada uno de los servicios y recursos informáticos aplicado a todos los niveles de la organización.
- Requerimientos mínimos para configuración de la seguridad de los sistemas que abarca el alcance de la política.
- Definición de violaciones y sanciones por no cumplir con las políticas.
- Responsabilidades de los usuarios con respecto a la información a la que tiene acceso.
- Las políticas de seguridad informática, también deben ofrecer explicaciones comprensibles sobre por qué deben tomarse ciertas decisiones y explicar la importancia de los recursos. Igualmente, deberán establecer las expectativas de la organización en relación con la seguridad y especificar la autoridad responsable de aplicar los correctivos o sanciones.
- Otro punto importante, es que las políticas de seguridad deben redactarse en un lenguaje sencillo y entendible, libre de tecnicismos y términos ambiguos que impidan una comprensión clara de las mismas, claro está sin sacrificar su precisión.
- Por último, y no menos importante, el que las políticas de seguridad, deben seguir un proceso de actualización periódica.

(Shannon, 1949) El cifrado es el más antiguo de entre los mecanismos de protección. Un sistema secreto se define como un conjunto de transformaciones de un espacio a otro espacio, donde cada transformación en particular corresponde a un cifrado con una llave particular.⁷ (Hellman, 1976) La criptografía es el estudio de

⁷ Shannon, C. E. (1949). Communication Theory of Secrecy Systems. Bell System Technical Journal, vol.28-4.

sistemas matemáticos que involucra a dos problemas de seguridad: privacidad y autenticación. La Criptografía es una rama de las matemáticas que, al orientarse al mundo de los mensajes digitales, proporciona las herramientas idóneas para solucionar los problemas relacionados con la autenticidad y la confiabilidad. El problema de la confidencialidad se vincula comúnmente con técnicas denominadas de "encriptación" y la autenticidad con técnicas denominadas "firma digital", aunque la solución de ambos, en realidad, se reduce a la aplicación de procedimientos criptográficos de encriptación y desencriptación.

Por otro lado, la mayoría de los sistemas de ordenadores proveen mecanismos de control de accesos en su primera línea de defensa. Este mecanismo únicamente limita el acceso a un objeto en el sistema, pero no modela ni restringe qué es lo que un sujeto puede hacer con el objeto en el caso de que tenga acceso a su manipulación.

El flujo de información se puede controlar para incrementar la seguridad mediante la aplicación de modelos como el de Bell y LaPadula para proveer confidencialidad, o el modelo Biba para proveer integridad. Ambos modelos son conservadores y restringen operaciones de lectura y escritura para asegurar que no se pueda comprometer la integridad y la confidencialidad de los datos de un sistema.

Por ello, un sistema completamente seguro no sería de gran utilidad ya que sería demasiado restrictivo.

Los controles de acceso y modelos de protección no son útiles ante amenazas internas. Si una contraseña es débil y se compromete, las medidas de control de acceso no pueden prevenir la pérdida o corrupción de la información a la que el usuario estaba autorizado a acceder. En general, los métodos estáticos de aseguramiento de propiedades de seguridad en un sistema o son insuficientes, o pueden resultar demasiado restrictivos para los propios usuarios.

Por otro lado también podemos encontrar mecanismos de identificación y autenticación (I&A). Estos mecanismos posibilitan la identificación adecuada de los sujetos y objetos del sistema. La identificación es la declaración de quién es el usuario (conocido a nivel global), mientras que autenticación es la prueba o confirmación de esa identificación. Existen tres tipos de identificación: la declaración de identidad, identidad colectiva y habilidad. Asimismo, esas identidades de los usuarios se verifican mediante tres métodos genéricos: Lo que saben (contraseñas, PIN,...), lo que tienen (tarjetas magnéticas, claves electrónicas,...) y finalmente lo que son (autenticación biométrica como iris, huellas dactilares,...).

Por último, hay otra serie de mecanismos con el objetivo de velar por la disponibilidad de un sistema. Algunos de ellos actúan a modo de filtros, dejando pasar aquella información que esté autorizada, en el caso de routers (con listas de acceso o ACL) y cortafuegos. Y por último los que de alguna manera detectan amenazas, como antivirus y sistemas de detección de intrusos. Éstos últimos forman la última línea de defensa en el esquema general de protección de un sistema informático, y no sólo son útiles para detectar incidentes de seguridad, sino también intentos de romper la seguridad.

8.1.1.2 Amenazas

El uso creciente de los sistemas de ordenadores ha exacerbado el problema de accesos no autorizados y la manipulación de datos. El alto nivel de conectividad en el que nos encontramos no sólo proporciona acceso a gran cantidad y variedad de fuentes de datos más rápido que nunca antes, sino que lo provee desde cualquier lugar en la red. Desde el ataque del gusano Internet de 1988, ha habido una innumerable cantidad de intrusiones de red que se han saltado los mecanismos establecidos para la protección de los sistemas. Hay muchas amenazas que ya existían y las nuevas tecnologías han provocado que aparezcan nuevas, por ejemplo los móviles o los ataques a la web. Las nuevas tecnologías y plataformas ayudan a que salgan nuevos ataques. Las amenazas han existido siempre pero tal

vez ahora la gente las comunica más. Los delitos en la red en estos momentos están ingresando más dinero que delitos de tráfico de drogas o de armas.

Los ataques informáticos online se han convertido en una constante. La evolución de la tecnología y la organización de grupos de 'hackers' han hecho que las amenazas de seguridad aumenten y que las autoridades tengan que actualizarse constantemente para poder hacer frente a la múltiple variedad de ataques, por ejemplo para intentar facilitar herramientas de colaboración entre cuerpos de policía de todo el mundo, Symantec ha fundado el Instituto de seguridad Norton.

Páginas web gubernamentales, financieras y empresariales de todo el mundo conocen al movimiento 'Anonymous' ya que son el blanco de sus objetivos, este grupo de hackers llevan a cabo un ataque de denegación de servicio colapsando las webs.

Grandes empresas son el objetivo de los delincuentes, ejemplo de ello en 2011 Google Inc. sufrió un importante ataque a Gmail, los atacantes intentaban hacerse con las cuentas de correos de usuarios de entre ellos estarías gente del gobierno, periodistas etc. Facebook es una de las mayores redes sociales que existen en la actualidad superando los 100 millones de usuarios registrados en 2008 y posteriormente en 2010 fue víctima de un ataque informático por el método conocido como phishing, en el que los delincuentes imitan la apariencia de esta página web para robar los datos de registro de los usuarios. En 2011 grandes compañías como son Sony reveló el coste asociado con la reparación de la brecha masiva de seguridad que expuso la información personal de más de 100 millones de usuarios de los servicios PlayStation Network y Qriocity: que le costó mínimo 171 millones de dólares. La compañía japonesa SEGA, ha reconocido haber sufrido un ataque informático a su base de datos. Se produjo el acceso no autorizado a los datos de 1,3 millones de clientes de su canal de juegos Sega Play. El episodio fue un recordatorio de los retos de cuán importante es la seguridad de los datos y un indicador de que muchas organizaciones no se están protegiendo lo

suficientemente bien. Cuando se trata de todos estos problemas de seguridad, las empresas no están invirtiendo por avanzado, pero después tienen que gastar mucho dinero para arreglar las cosas.

El Instituto Nacional de Tecnologías de la Comunicación (Inteco), centro especializado en seguridad en la Red y ubicado en León, a través de su Centro de Respuesta a Incidentes de Seguridad de la Información, Inteco-CERT, ha superado la cifra de 10.000 virus analizados y catalogados en su base de datos. Esta información es importante para que usuarios particulares y empresas conozcan a qué amenazas se enfrentan en internet. Cada semana, el Inteco-CERT localiza y clasifica una media de 12 códigos maliciosos, con la finalidad de conseguir una mayor seguridad en internet y de asesorar a los usuarios sobre el modo de protegerse de las diferentes amenazas que van surgiendo en la Red. El estudio de los virus identificados por el instituto refleja la evolución de la tecnología y el hecho de que los virus permanecen en el tiempo y evolucionan, adaptándose a los nuevos sistemas operativos y ampliando su campo de acción a nuevas plataformas. Así, los técnicos del Inteco han observado que cada vez hay más virus documentados que afectan a dispositivos móviles como iPad, iPhone, Android o Symbian, entre otros, que se unen a los que atacan a sistemas operativos distintos de Windows, como Mac OS o Linux.

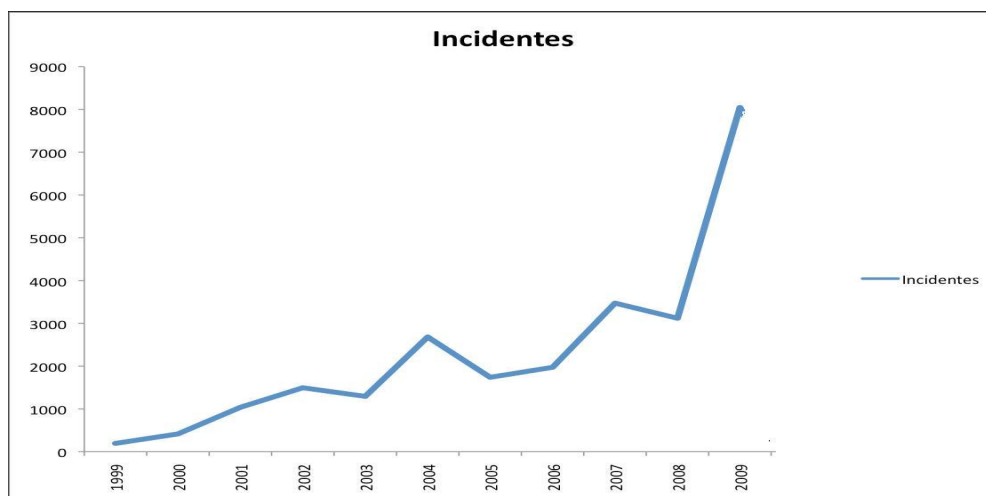


Ilustración 1: Gráfica que muestra nº incidentes reportados al CERT⁸

Otro aspecto a tener en cuenta es la dificultad que conlleva la realización de software, ya que éste es cada vez más complejo y el ciclo de vida del software se está reduciendo significativamente debido al aumento de la competitividad del mercado.

Este hecho acarrea la consecuencia de realizar diseños pobres, testeo inadecuado, y por lo tanto errores en el software que se manifiestan como vulnerabilidades de seguridad.

Antes, los intrusos necesitaban de un conocimiento más profundo de las redes y las computadoras para poder lanzar sus ataques. Desgraciadamente, gracias al incremento del conocimiento sobre el funcionamiento de los sistemas, los intrusos están cada vez más preparados y lo que antes estaba accesible para sólo unos pocos (expertos), hoy en día cualquiera tiene herramientas accesibles con las que poder determinar las debilidades de los sistemas y explotarlas con el fin de obtener

⁸ computer emergency response team for Internet security incidents. (20 de Mayo de 2014). CERT. Obtenido de <http://cert.inteco.es/cert/INTECOCERT/?jsessionid=1F07AA82BDE8C7A747C7504C3620A33D?postAction=getCertHome>

los privilegios necesarios para realizar cualquier acción dañina. Esto puede observarse en la siguiente gráfica:

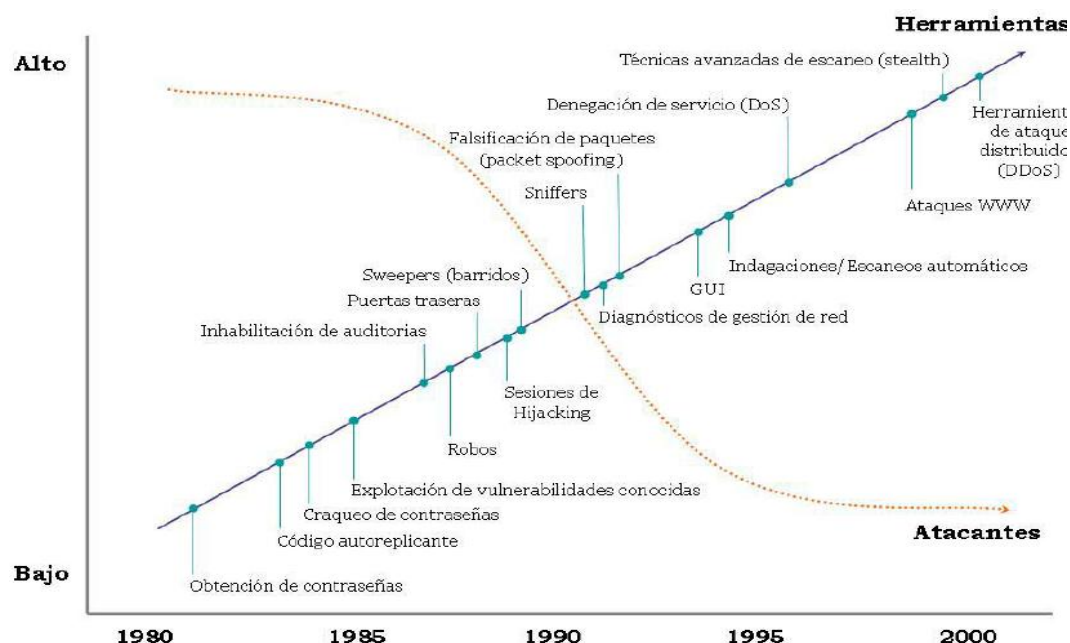


Ilustración 2: Sofisticación de los ataques vs. Conocimiento técnico del intruso

8.1.1.3 Clasificación de los Ataques Informáticos

El propósito de una clasificación o taxonomía es proporcionar un medio útil y coherente de clasificar los ataques. Actualmente, los ataques a menudo se describen de forma diferente por diferentes organizaciones, dando lugar a confusión a los que en realidad es un ataque en particular. Por ejemplo, una organización puede clasificar como un ataque a un virus mientras que otra lo clasifica como un gusano. Una taxonomía permite tener un conocimiento previo que se aplicará a nuevos ataques así como proporciona una forma estructurada para el estudio de estos ataques. Se pueden encontrar multitud de trabajos referentes a la categorización y clasificación de ataques informáticos e intrusiones.

Uno de los primeros trabajos dedicados a categorizar diferentes aspectos de la seguridad informática, se centraba en la debilidad de los sistemas informáticos y defectos de diseño en sistemas operativos, así como en vulnerabilidades

funcionales y métodos de abusos informáticos. Varias de las taxonomías desarrolladas más tarde se enfocaban principalmente en dos aspectos: categorización de uso indebido de computadoras, y categorización de la gente que intentaba obtener acceso no autorizado a ordenadores.

En un intento anterior de describir tipos de ataques informáticos, Neumann y Parker desarrollaron el SRI Computer Abuse Methods Model, el cual describe aproximadamente 3000 ataques y usos indebidos recogidos durante unos veinte años, y los clasifica en un árbol de nueve categorías de ataques. Lindqvist y Jonson extendieron este modelo expandiendo las categorías 5, 6 y 7 del árbol original. Jayaram y Morse también desarrollaron una clasificación de amenazas de seguridad en redes, en la que proveen cinco clases de amenazas de seguridad y dos clases de mecanismos de seguridad. Otro trabajo significativo en taxonomías de ataques fue realizado por el grupo CERIAS de Purdue University. Inicialmente, Sandeep Kumar realizó una clasificación de intrusiones en sistemas de ordenadores UNIX basado en logs del sistema y redes de Petri coloreadas. Aslam extendió dicho estudio añadiendo una taxonomía de fallos de seguridad en sistemas UNIX. Finalmente, Iván Krsul reorganizó las dos taxonomías anteriores y proporcionó una taxonomía más compleja de ataques informáticos organizados en cuatro grupos (diseño, supuestos ambientales, fallos de codificación y errores de configuración). Richardson extendió estas clasificaciones desarrollando una base de datos de vulnerabilidades para ayudar en el estudio del problema de ataques de denegación de servicio (DoS). La base de datos se pobló con 630 ataques de sitios populares donde se reportaban incidentes informáticos. Estos ataques se clasificaron dentro de las categorías correspondientes a las extensiones de la taxonomía de fallas de seguridad de Aslam y de la taxonomía de Krsul. Dentro del proyecto de evaluación de detección de intrusos DARPA intrusion detection evaluation data sets), Kendall desarrolló una base de datos de ataques similar, que se puede encontrar en los conjuntos de datos de evaluación de detección de intrusos DARPA. En esta base de datos, utilizada actualmente como elemento evaluador y comparativo de los

sistemas de detección desarrollados por los investigadores, los ataques se clasifican en cuatro grupos principales, utilizando como criterio el tipo de ataque:

Denegación de Servicio (DoS): Estos ataques tratan de detener el funcionamiento de una red, máquina o proceso; o si no denegar el uso de los recursos o servicios a usuarios autorizados. Hay dos tipos de ataques DoS; por un lado ataques de sistema operativo, los cuales tratan de explotar los fallos en determinados sistemas operativos y pueden evitarse aplicando los respectivos parches; y ataques de red, que explotan limitaciones inherentes de los protocolos e infraestructuras de red. Hay varios tipos de denegación de servicio (DOS), algunos ataques como "mailbomb", "Neptune" o "smurf" abusan de los dispositivos legítimos. Otros como "teardrop", crean paquetes malformados que confunden a los protocolos TCP / IP en la máquina objetivo, y ésta última intentará la reconstrucción de los paquetes. Y otros "apache2" ó back" sacan provecho de los errores en la red.

Indagación o exploración (probing): Este tipo de ataques escanean las redes tratando de identificar direcciones IP válidas y recoger información acerca de ellas (servicios que ofrecen, sistemas operativos que usan). A menudo, esta información provee al atacante una lista de vulnerabilidades potenciales que podrían ser utilizadas para llevar a cabo ataques a los servicios y a las máquinas escogidas.

Estos ataques son los más frecuentes, y a menudo son precursores de otros ataques. Un atacante con un mapa de las máquinas y servicios disponibles en una red puede utilizar esta información para encontrar todos los puntos débiles de esta última. Algunas de estas herramientas de análisis "satan, saint, mscan" permiten que incluso un hacker principiante, pueda revisar rápidamente cientos o miles de máquinas en una red.

R2L (Remote to Local): cuando un atacante que no dispone de cuenta alguna en una máquina, logra acceder (tanto como usuario o como root) a dicha máquina. En

la mayoría de los ataques R2L, el atacante entra en el sistema informático a través de Internet. Hay varias maneras en que un atacante puede lograr su objetivo.

Algunos ataques explotan el desbordamiento de búfer causado por el software de servidor de red "imap, named, sendmail". Los ataques de "ftp_write, xsnoop y guest" tratan de explotar la debilidad o la mala configuración de las políticas de seguridad del sistema. El ataque "xlock" utiliza ingeniería social para tener éxito, el atacante debe suplantar a los operadores humanos que proporcionan sus contraseñas de los protectores de pantalla que en realidad son caballos de Troya.

U2R (User to Root): Este tipo de ataque se da cuando un atacante que dispone de una cuenta en un sistema informático es capaz de elevar sus privilegios explotando vulnerabilidades en los mismos, un agujero en el sistema operativo o en un programa instalado en el sistema. Hay varios tipos de ataques U2R la más común es el ataque "buffer_overflow" que se produce cuando un programa copia una gran cantidad de datos en un búfer de memoria estática sin comprobar si el tamaño de esta última es suficiente, lo que provocará un desbordamiento. Los datos desbordados se almacenan en la pila de sobrecarga del sistema, cubriendo así las siguientes instrucciones para ser ejecutadas. Mediante la manipulación cuidadosa de los datos almacenados en la pila, un atacante puede provocar la ejecución de código en el sistema operativo que le ayudará a conseguir lo que quiere. Otra clase de ataques U2R explotan los programas que proporcionan información sobre el medio en el que se ejecutan, un buen ejemplo de este tipo de ataque es el ataque "l0d0module". Otra clase de ataques U2R explotan los programas que tienen una mala gestión de los archivos temporales. Algunos ataques U2R explotan la vulnerabilidad debido a las condiciones competitivas explotables durante la ejecución de un solo programa, dos o más programas se ejecutan simultáneamente.

A pesar de que una programación controlada podría eliminar todas estas vulnerabilidades, tales errores están presentes en todas las versiones de UNIX y Windows de Microsoft disponibles hoy en día.

8.1.2 IDS

Las primeras investigaciones sobre detección de intrusos comienzan en 1980 en un trabajo de consultoría realizado para el gobierno norteamericano por James P. Anderson, quien trató de mejorar la complejidad de la auditoría y la habilidad para la vigilancia de sistemas informáticos. Anderson presentó la idea de que el comportamiento normal de un usuario podría caracterizarse mediante el análisis de su actividad en los registros de auditoría. De ese modo, los intentos de abusos podrían descubrirse detectando actividades anómalas que se desviaran significativamente de ese comportamiento normal.

Se puede definir intrusión como la violación de la política de seguridad de un sistema, o como la materialización de una amenaza. Heady et al. [Hea90] definen intrusión como cualquier conjunto de acciones que tratan de comprometer la integridad, confidencialidad o disponibilidad de un recurso. Una de las definiciones más populares de intrusión es: fallo operacional maligno, inducido externamente [Powe01], aunque es bien sabido que muchas de las intrusiones proceden del interior del sistema de información. Finalmente, el NIST (National Institute of Standards and Technology) define detección de intrusos como el proceso de monitorización de eventos que suceden en un sistema informático o red y análisis de dichos eventos en busca de signos de intrusiones.

El primer modelo de detección de anomalías fue el propuesto por Dorothy Denning, con la idea básica de monitorizar las operaciones estándares de un sistema objetivo, observando desviaciones en su uso. Su artículo provee un marco metodológico que más tarde inspiraría a muchos investigadores.

Entre 1988 y 1990 el Instituto de Investigación SRI International desarrolla la propuesta de Denning. De ese modo surge IDES (Intrusion Detection Expert System), un sistema experto que detecta las desviaciones a partir del

comportamiento de diferentes sujetos. IDES fue el primer sistema de detección de anomalías en host.

En 1988, simultáneamente, en los laboratorios Lawrence Livermore de University of California en Davis, se realiza el proyecto Haystack para las fuerzas aéreas de EE.UU. Haystack era el primer IDS que analizaba los datos de auditoría y los comparaba con patrones de ataque predefinidos. De este modo nacía el primer sistema de detección de usos indebidos basado en firmas, el tipo de IDS más extendido en el mercado actual.

En 1990, surgen los primeros proyectos de IDS basados en red. Todd Heberlein introduce tal idea y desarrolla NSM (Network Security Monitor) en University of California at Davis. En esa misma fecha, en Los Alamos National Laboratory de EEUU realizan un prototipo de un sistema experto que monitoriza la actividad de red. Su nombre es NADIR (Network Anomaly Detector and Intrusion Reporter).

A partir de este momento, comienzan una gran variedad de proyectos de investigación que hacen uso de diferentes técnicas y algoritmos para el análisis del comportamiento de un sistema informático.

8.1.2.1 Clasificación de los IDS

La clasificación o taxonomía de los sistemas de detección de intrusos ha sido tratada en numerosos trabajos, de los que destacan los de Hervé Debar y Stefan Axelsson de Chalmers University of Technology en Suecia. La clasificación más común se realiza en base a tres características funcionales de los IDS:

Fuentes de información. Se refiere al origen de los datos que se usan para determinar si una intrusión se ha llevado a cabo. Básicamente existen 2 tipos aquellos que obtienen sus datos de una máquina o host, y aquellos que los obtienen a partir de la monitorización de una red.

Análisis. Se trata del método de detección utilizado. La información recogida en el paso anterior puede ser analizada mediante dos estrategias diferentes, una basada en uso indebido y la otra basada en anomalías.

Respuestas. Una vez que se ha determinado si ha sucedido alguna intrusión, los IDS pueden o bien responder de forma activa ante la misma, o bien registrar la detección y no realizar acción alguna.

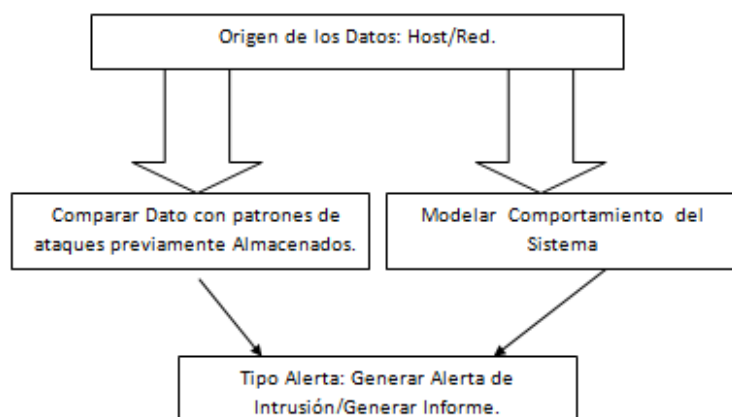


Ilustración 3: Clasificación de los IDS

8.1.2.2 Estrategia de Análisis de los IDS

Después del proceso de recopilación de información, se lleva a cabo el proceso de análisis. Los dos tipos principales de análisis son:

- Detección de usos indebidos ("misuse detection"): Para encontrar usos indebidos se comparan firmas (patrones de ataques conocidos) con la información recogida en busca de coincidencias.
- Detección de anomalías: Para la detección de anomalías se manejan técnicas estadísticas que definen de forma aproximada lo que es el comportamiento usual o normal.
- La siguiente figura muestra un esquema general de detector de intrusiones de usos indebidos (mediante comparación de patrones) y de anomalías.

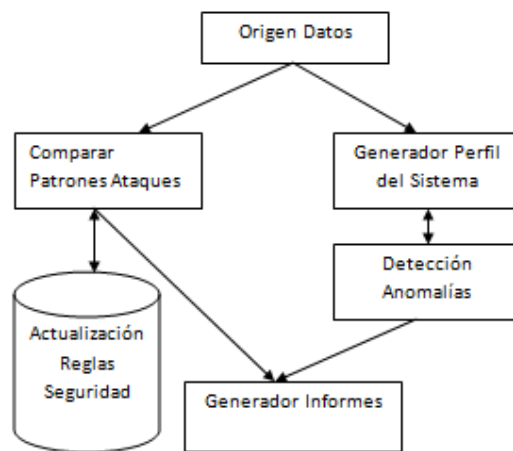


Ilustración 4: Esquema general de un Sistema de Detección de Intrusiones.

Nos vamos a centrar en la estrategia de análisis de los IDS, pasaremos a describir las dos estrategias básicas en las que un IDS se basa para detectar si se está llevando a cabo o no un ataque.

8.1.2.3 Estrategia de Análisis: Uso Indebido

Un IDS basado en detección de uso indebido monitoriza las actividades que ocurren en un sistema y las compara con firmas de ataques, las cuales se encuentran almacenadas en una base de datos. Cuando las actividades monitorizadas coinciden con las firmas, genera una alarma. La detección de intrusos basada en uso indebido se atiene al conocimiento a priori de las secuencias y actividades que forman un ataque. Con este método se detectan las tentativas de explotación de vulnerabilidades conocidas o patrones de ataque típicos. Esta estrategia es la más utilizada en los IDS comerciales y por la que apuestan los fabricantes.

Típicamente, un sistema de detección de uso indebido contiene dos componentes principales:

- Un lenguaje o modelo para describir o representar las técnicas utilizadas por los atacantes.

- Programas de monitorización para detectar la presencia de un ataque basado en las representaciones o descripciones dadas.

La ventaja de los IDS basados en uso indebido es la fidedigna detección de patrones de ataques conocidos. Al igual que un software antivirus, el comportamiento malévolo puede identificarse con una precisión aceptable. Como desventaja, cabe mencionar el hecho de que el patrón del ataque ha de ser conocido con anterioridad, lo que hace que nuevas intrusiones pasen desapercibidas ante el detector, o que el sistema pueda ser fácilmente engañado con pequeñas variantes de los patrones de ataques conocidos. Otra desventaja es que hay que adaptar manualmente el IDS al sistema en el que se implanta si no queremos que se dispare el número de falsos positivos -una intrusión anómala, la actividad es no intrusiva, pero como es anómala el sistema decide que es intrusiva. Se denominan falsos positivos, porque el sistema erróneamente indica la existencia de intrusión.

8.1.2.4 Anomalía

Consiste en la elaboración de perfiles estadísticos de comportamiento a lo largo del tiempo. Estos perfiles se construyen mediante determinadas técnicas, capaces de detectar cambios graduales en los patrones de conducta de los usuarios o anomalías.

Una anomalía se puede definir como la discrepancia de una regla o de un uso. De ese modo, el primer paso de un sistema de detección de anomalías comienza por establecer lo que se considera comportamiento normal de un sistema (usuarios, redes, registros de auditoría, llamadas del sistema de los procesos, etc.).

Una vez definido esto, clasificará como sospechosas o intrusivas aquellas desviaciones que pueda detectar sobre el comportamiento normal. La detección de anomalías depende mucho de la suposición de que los usuarios y las redes se comportan de un modo suficientemente regular, de forma que cualquier desviación significativa pueda ser considerada como evidencia de una intrusión.

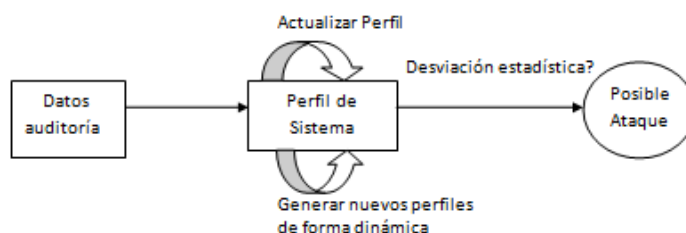


Ilustración 5: IDS basado en anomalías

La gran ventaja de la detección de anomalías es que el sistema es capaz de aprender el comportamiento normal del objeto de estudio, y a partir de ahí detectar desviaciones del mismo, clasificándolas como intrusiones. De este modo, se demuestra que es capaz de detectar tipos de ataques hasta el momento desconocidos.

Como desventaja, por definición únicamente señala comportamientos inusuales, pero éstos no tienen necesariamente por qué ser ilícitos. Por ello, destaca el problema de su alta tasa de falsos positivos. Otra desventaja de este proceso es la falta de claridad.

Un intruso podría actuar lentamente y realizar sus acciones cuidadosamente para modificar el perfil de los usuarios de modo que sus actividades serían aceptadas como legales cuando en realidad deberían lanzar una alarma (falsos negativos).

Otras veces, no es o debería ser suficiente el hecho de simplemente avisar de un comportamiento anómalo sin explicar los posibles orígenes. Se hacen uso de mecanismos heurísticos y estadísticos para adaptarse a los cambios en el comportamiento del objeto a estudio así como para detectar cambios imprevistos. Básicamente los sistemas basados en detección de anomalías se clasifican en, sistemas basados en conocimiento por ejemplo sistemas expertos, sistemas basados en métodos estadísticos y sistemas basados en aprendizaje automático.

3. Exploración de los datos.
4. Verificación de calidad de datos.

8.1.3.3 Preparación de los datos

Se realiza la preparación de datos cubre todas las actividades necesarias para construir el conjunto de datos final (los datos que alimentarán a las herramientas de modelado) de los datos iniciales. Las tareas incluyen la selección de tablas, registros, y atributos, así como la transformación y la limpieza de datos para las herramientas.

1. Selección de los datos.
2. Limpieza de datos.
3. Construcción de datos.
4. Integración de datos.

8.1.3.4 Modelado

Típicamente hay varias técnicas para el mismo tipo de problema de minería de datos. Algunas técnicas tienen requerimientos específicos sobre la forma de datos. Por lo tanto, el volver a la fase de preparación de los datos es un paso, el cual no se puede omitir.

1. Selección de la técnica de modelado.
2. Diseño de la evaluación.
3. Construcción del modelo.
4. Evaluación del modelo.

8.1.3.5 Evaluación

Cuando llegamos a esta etapa, se tiene un modelo que nos ayude a tener un análisis de los datos de manera correcta.

Antes del proceder al despliegue final del modelo, es importante evaluarlo a fondo y la revisión de los pasos ejecutados para crearlo, para comparar el modelo correctamente obtenido con los objetivos de negocio. Un objetivo clave es determinar si hay alguna cuestión importante de negocio que no ha sido considerada. En el final de esta fase, una decisión en el uso de los resultados de minería de datos debería ser obtenida.

1. Evaluación de resultados
2. Revisar el proceso
3. Validación de resultados obtenidos

8.1.3.6 Despliegue

La creación del modelo no es generalmente el final del proyecto. Incluso si el objetivo del modelo es de aumentar el conocimiento de los datos, el conocimiento ganado tendrá que ser organizado y presentado en el modo en el que el cliente pueda usarlo. Ello a menudo implica la aplicación de modelos "vivos" dentro de un proceso de toma de decisiones de una organización, por ejemplo, en tiempo real la personalización de página Web o la repetida obtención de bases de datos de mercadeo. Dependiendo de los requerimientos, la fase de desarrollo puede ser tan simple como la generación de un informe o tan compleja como la realización repetida de un proceso cruzado de minería de datos a través de la empresa. En muchos casos, es el cliente, no el analista de datos, quien lleva el paso de desarrollo. Sin embargo, incluso si el analista realizara el esfuerzo de despliegue, esto es importante para el cliente para entender de frente que acciones necesita para ser ejecutadas en orden para hacer uso de los modelos creados actualmente.

8.1.4 Minería de datos

De un tiempo a esta parte, muchas de las técnicas desarrolladas en la Estadística Clásica, así como en la Inteligencia Artificial han sido puestas en práctica en un intento de construir modelos de predicción de comportamientos de forma automática y bajo una base estadística bien fundamentada.

La búsqueda de patrones útiles en datos se conoce con diferentes términos (incluyendo data mining) en diferentes comunidades (extracción de conocimiento, descubrimiento de información, procesamiento de patrones de datos,...). El término que más fuerza ha tomado es el llamado KDD (Knowledge Discovery in Databases) que se refiere al proceso no trivial de identificar patrones válidos, nuevos, potencialmente útiles, y comprensibles a partir de datos.

En las últimas décadas, ambas comunidades científicas, la Estadística Clásica con el reconocimiento de patrones y la Inteligencia Artificial con el Aprendizaje automático han extendido sus áreas de aplicación de forma notoria, aumentando la capacidad de extraer de las grandes bases de datos, información de distintos tipos desarrollando multitud de modelos predictivos/explicativos. Alrededor del año 1990, ambas disciplinas aunaron esfuerzos y crearon un nuevo campo interdisciplinario que es conocido en la comunidad internacional como Data Mining (Minería de Datos). Data mining es la aplicación de algoritmos específicos para la extracción de patrones (modelos) de los datos. El data mining es un paso particular del proceso de KDD.

La mayoría de los algoritmos de data mining se pueden ver como una combinación de unas pocas técnicas y principios. En particular, los algoritmos de data mining consisten mayormente en una mezcla específica de tres componentes:

- El modelo. El componente principal. Tiene dos factores relevantes: su función (como la de clasificar, agrupar, resumir,...), y el modo de representar el conocimiento (como una función lineal de múltiples variables, en modo de árbol, de reglas, una red,...). Un modelo contiene ciertos parámetros que deben determinarse a partir de los datos.
- El criterio de preferencia. Es la base para escoger un modelo o un conjunto de parámetros sobre otros. El criterio suele ser la función que hace que el modelo se ajuste más apropiadamente a los datos que se disponen.

- El algoritmo de búsqueda. La especificación de un algoritmo para obtener modelos particulares y parámetros, los datos, el modelo (o familia de modelos), y un criterio de preferencia.

8.1.4.1 Discretización

El proceso de discretización entra en la parte de pre procesamiento de los datos en el proceso de KDD. Antes de tratar el concepto de discretización vamos a exponer los tipos de datos que existen. Generalmente se hace la distinción en:

Cuantitativas: Se distinguen a su vez en:

- Discretas Un atributo discreto tiene un número finito o contable de valores. En general se representa como números enteros. Atributos binarios son un caso especial de ellos.
- Continuas Un atributo continuo tiene un número infinito de valores posibles. Es representado por números reales o de punto flotante. Se pueden obtener tan precisos como sea el instrumento de medición.

Cualitativas o Categóricas: Se pueden distinguir:

- Nominales. No tienen orden significativo, nombran el objeto al que se refieren
- Ordinales. Tienen orden definido se puede establecer un orden en sus valores

La discretización, es de especial importancia en Inteligencia Artificial, pues permite que muchos algoritmos de aprendizaje ideados para funcionar con atributos nominales o categóricos puedan también utilizarse con conjuntos de datos que incluyen valores numéricos, algo esencial en la resolución de problemas reales. Un gran número de algoritmos de aprendizaje operan exclusivamente con espacios discretos, sin embargo, muchas bases de datos contienen atributos de dominio continuo, lo que hace imprescindible la aplicación previa de algún método que reduzca la cardinalidad del conjunto de valores que estas características pueden

tomar, dividiendo su rango en un conjunto finito de intervalos. Esta transformación de atributos continuos en discretos se denomina discretización.

La discretización de los valores no sólo permite construir modelos de clasificación más compactos y sencillos, que resultan más fáciles de comprender, comparar, utilizar y explicar, sino que permite mejorar la precisión del clasificador y hace más rápido el aprendizaje.

8.1.4.1.1 Aprendizaje Automático: Aprendizaje Supervisado

Una característica principal dentro del data mining es el paradigma de aprendizaje de los sistemas. Existen diversas definiciones de aprendizaje automático entre ellas: "Aprendizaje denota cambios en el sistema que son adaptativos en el sentido de que permiten al sistema realizar la misma tarea, o una tomada de la misma población, la próxima vez de una forma más eficiente y efectiva."

Según Carbonnell "Se puede definir operacionalmente como la habilidad para realizar nuevas tareas que no podrá realizar anteriormente o realizar anteriores tareas mejor más rápidas, más exactas, etc. Como resultado de los cambios producidos por el proceso de aprendizaje". Especificó "El aprendizaje es un fenómeno que se muestra cuando un sistema mejora su rendimiento en una determinada tarea sin necesidad de ser reprogramado." En 1991 Weiss y Kulikowski lo explicaron como "Un sistema que aprende es un programa de computador que toma decisiones en base a la experiencia acumulada contenida en casos resueltos satisfactoriamente. A diferencia de los sistemas expertos, que resuelven los problemas utilizando un modelo por computador del razonamiento del experto humano, un sistema de aprendizaje puro puede utilizar muchas técnicas diferentes para explotar el potencial computacional del computador, sin importar su relación con el proceso cognitivo humano." Según Anzai, [Anz92]: "Cuando un sistema genera automáticamente una nueva estructura de datos o programa a partir de una existente y de esta forma irreversible cambia con algún propósito por un determinado tiempo, es lo que llamamos aprendizaje automático" Langley, 1996:

“Aprendizaje es la mejora en el rendimiento en ciertos entornos por medio de la adquisición de conocimiento como resultado de la experiencia en dicho entorno”.

Por último Mitchell como “Un programa de ordenador se dice que aprende de la experiencia E con respecto a una clase de tareas T y a la medida de rendimiento P, si su rendimiento en las tareas que pertenecen a T medido según P, se incrementa con la experiencia E”

Aunque el despegue del Aprendizaje Automático se produce en los años ochenta, de ahí que las primeras definiciones mostradas anteriormente daten de esos años, la búsqueda de sistemas con capacidad de aprender se remonta a los primeros días de los computadores.

La adquisición del conocimiento por parte de los sistemas de Aprendizaje Automático se puede realizar de diferentes formas, igual que ocurre en los humanos que no tienen una única forma de aprender, aunque todos los paradigmas de aprendizaje se pueden encuadrar en las definiciones antes enunciadas, ya que todos tienen como objetivo común el incremento del rendimiento del sistema que adquiere el conocimiento.

Dentro del paradigma automático, nos encontramos con el aprendizaje supervisado, el cual genera hipótesis utilizando ejemplos con etiqueta (clase) conocida; a su vez dichas hipótesis servirán para hacer predicciones ante nuevos ejemplos con etiqueta desconocida [Bou04]. Dentro de un marco más operativo, el objetivo del aprendizaje supervisado (tanto binario como multiclase) es dividir el espacio de instancias (ejemplos) en regiones en donde la mayoría de los casos estén etiquetados con la misma clase; dicha partición es la que servirá para predecir la clase de nuevos ejemplos. Al sistema se le proporciona un conjunto de hechos etiquetados y el sistema debe obtener el conjunto de reglas que expliquen estos hechos.

8.1.4.2 Funciones de los Modelos

Las funciones de los modelos más comunes en data mining incluyen:

Clasificación: Un clasificador es una función que asigna a una muestra no etiquetada una etiqueta o clase. Todos los clasificadores poseen una estructura de datos interna para realizar la asignación de una etiqueta a un ejemplo. Se clasifica un caso entre varias clases o categorías predefinidas. Los modelos de clasificación se pueden construir utilizando una gran variedad de algoritmos. Henery [Hen94] cataloga los algoritmos de clasificación en tres tipos:

- Extensiones de discriminación lineal (como perceptrón multicapa, discriminación lógica)
- Árboles de decisión y métodos basados en reglas (como C4.5, AQ, CART)
- Estimadores de densidad (Naïve Bayes, k-nearest neighbor, LVQ).

Regresión: clasifica un caso a una variable de predicción de valor-real. En la regresión se persigue la obtención de un modelo que permita predecir el valor numérico de alguna variable.

Clustering (agrupamiento): clasifica un caso en una de las clases o agrupaciones en las que las clases se deben determinar a partir de los propios datos. Los clusters se definen buscando agrupaciones naturales de los datos basado en modelos de medidas de similaridad, densidad de probabilidad o distancia.

Summarization (resumen): provee una descripción compacta de un subconjunto de datos de entrada (media y desviación estándar para todos los campos, o reglas de resumen, técnicas de visualización multivariadas, relaciones funcionales entre variables).

Modelado de dependencias: describe las dependencias significantes entre variables. Existen modelos de dependencias a dos niveles: el estructurado y el cuantitativo. El modelo estructurado de dependencias especifica (a menudo en

modo gráfico) qué variables son localmente dependientes; el modelo cuantitativo especifica la fortaleza de las dependencias usando una escala numérica. El análisis de relaciones (como reglas de asociación), que determina relaciones existentes entre elementos de una base de datos, podría considerarse un caso particular de modelado de dependencias.

Link analysis (análisis de conexiones): determina las relaciones o vínculos entre campos de la base de datos. El objetivo es el de deducir correlaciones entre campos satisfaciendo el umbral de confianza.

Análisis de secuencias: modela patrones secuenciales (como datos con dependencia del tiempo). El objetivo es modelar los estados del proceso generando la secuencia, o extraer y describir desviaciones y tendencias sobre el tiempo.

En el caso de la detección de intrusiones, las funciones más utilizadas son la clasificación (de un caso, en intrusión o no intrusión; o clasificar entre tipos de intrusión), clustering (los casos lejanos a las agrupaciones naturales se consideran anomalías), modelado de dependencias, o análisis de secuencias.

8.1.4.3 Redes Neuronales

Son sistemas artificiales que van a copiar la estructura de las redes neuronales biológicas con el fin de alcanzar una funcionalidad similar. Las redes neuronales artificiales tratan de emular tres conceptos claves:

- Procesamiento paralelo, derivado de que los miles de millones de neuronas que intervienen, por ejemplo en el proceso de ver, están operando en paralelo sobre la totalidad de la imagen
- Memoria distribuida, mientras que en un computador la información está en posiciones de memoria bien definidas, en las redes neuronales biológicas dicha información está distribuida por la sinapsis de la red, existiendo una redundancia en el almacenamiento, para evitar la pérdida de información en caso de que una sinapsis resulte dañada.

- Adaptabilidad al entorno, por medio de la información de las sinapsis. Por medio de esta adaptabilidad se puede aprender de la experiencia y es posible generalizar conceptos a partir de casos particulares.

Se denomina arquitectura a la topología, estructura o patrón de conexionado de una red neuronal. En una red neuronal artificial los nodos se conectan por medio de sinapsis, estando el comportamiento de la red determinado por la estructura de conexiones sinápticas. Estas conexiones sinápticas son direccionales, es decir, la información solamente puede propagarse en un único sentido (desde la neurona presináptica a la pos- sináptica). En general las neuronas se suelen agrupar en unidades estructurales que denominaremos capas. El conjunto de una o más capas constituye la red neuronal.

8.1.4.4 Naive Bayes

Naive Bayes es una técnica de clasificación descriptiva y predictiva basada en la teoría de la probabilidad del análisis de T. Bayes. Esta teoría supone un tamaño de la muestra asintóticamente infinito e independencia estadística entre variables independientes, refiriéndose en nuestro caso a los atributos, no a la clase. Con estas condiciones, se puede calcular las distribuciones de probabilidad de cada clase para establecer la relación entre los atributos (variables independientes) y la clase (variable dependiente).

8.1.4.5 Random Forest

Random forest, introducido por Breiman en 1999, utiliza un conjunto (o bosque) formado por muchos árboles de clasificación. Para clasificar un nuevo objeto, cada árbol en el conjunto lo toma como entrada y produce una salida, su clasificación. La decisión del conjunto de árboles se toma como la clase con mayoría de votos en el conjunto. En Random Forest cada árbol individual se desarrolla de una manera particular.

8.1.4.6 Árboles de Decisión

Un árbol de decisión es una forma gráfica y analítica para poder llevar a cabo la clasificación de los datos utilizados, mediante diferentes caminos posibles. Cada uno de los nodos del árbol representa los diferentes atributos presentes en los datos, las ramificaciones del árbol representan los caminos posibles a seguir, para predecir la clase de un nuevo ejemplo, en donde los nodos terminales u hojas establecen la clase a la que pertenece el ejemplo de prueba si se sigue por la ramificación en cuestión.

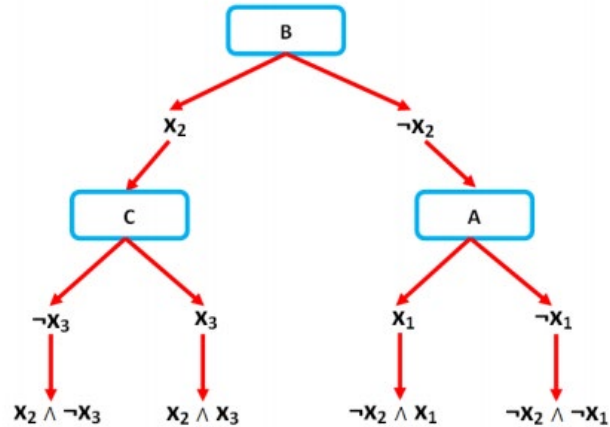
El lenguaje de descripción de los árboles de decisión corresponde a las fórmulas en FND (Forma Normal Disyuntiva). Consideramos el caso en el que tenemos 3 atributos, el atributo A, B y C, cada uno de ellos con dos valores, x_i y $\neg x_i \forall i \in \{1,2,3\}$ respectivamente, con esto se pueden construir 2^n combinaciones en FNC (Forma Normal Conjuntiva). Un ejemplo de estas se muestra a continuación:

$$(x_1 \wedge x_2 \wedge \neg x_3)$$

Cada una de las combinaciones en FNC describe una parte del árbol que estemos formando, por lo que tendríamos para el árbol disyuntivas de la siguiente forma:

$$(x_2 \wedge \neg x_3) \vee (x_2 \wedge x_3) \vee (\neg x_2 \wedge x_1) \vee (\neg x_2 \wedge \neg x_1)$$

Las cuales son descriptores del árbol de inducción construido, entonces podríamos formar $O(2^{2n})$ descripciones posibles en FND. El árbol correspondiente a los descriptores anteriores se muestra en la ilustración 1.



Dado que el orden de los árboles o descriptores es muy grande, evidentemente no es posible explorar todos los descriptores para ver cuál es el más adecuado, por lo que se utilizan técnicas de búsqueda heurística para encontrar una forma más fácil y rápida de hacerlo.

La mayoría de los algoritmos de construcción de árboles de decisión se basa en la estrategia de Ascenso a la Colina (Hill Climbing). Esta es una técnica utilizada en Inteligencia Artificial para encontrar los máximos o mínimos de una función mediante una búsqueda local. Estos algoritmos empiezan con un árbol vacío, después se va particionado en conjuntos de ejemplos, eligiendo en cada caso aquel atributo que mejor discrimina entre las clases, hasta que se completa el árbol. Para saber qué atributo es el mejor se utiliza una función heurística, la elección que hagamos es irrevocable, por lo que debemos asegurar que esta sea la más cercana a la óptima. La principal ventaja de usar este tipo de estrategias es que el costo computacional es bastante reducido.

8.1.4.7 Adaboost

Utiliza el aprendizaje conjunto (ensemble learning) que es un método en el cual se utilizan varios métodos de aprendizaje para resolver un problema. Se utiliza principalmente para mejorar la ejecución de un modelo o disminuir la selección desafortunada.

9 Análisis del Proyecto

La seguridad informática consiste en asegurar que los recursos tales como las metodologías, planes, políticas, documentos, programas o dispositivos físicos, encaminados a lograr que los recursos de cómputo disponibles en una organización o ambiente dado, sean accedidos única y exclusivamente por quienes tienen la autorización para hacerlo y dentro de los límites de su autorización. Para ello disponemos de varias herramientas que nos ayudan a mantener la seguridad de una organización red o recurso cualquiera, entre estas herramientas están los llamados sistemas de detección de intrusos. Los sistemas de intrusos basados en red, los cuales monitorizan el tráfico de una red, se clasifican dependiendo del tipo de análisis que lleven a cabo en dos tipos. Por un lado están los de uso indebido que requieren de un sistema de apoyo, como es una base de datos, éstos necesitan de un mantenimiento regular, como son las actualizaciones periódicas, ejemplo de ello son los antivirus. Por otra parte nos encontramos con los llamados sistemas basados en anomalías los cuales no cuentan con ningún soporte, puesto que aprenden a modelar, gracias a un algoritmo de inteligencia artificial, el comportamiento normal del sistema. Éstos algoritmos les permiten aprender y por ello perfilar una conducta de actividad normal y todo lo que se desvíe de esa conducta es reportado como una anomalía o intrusión.

Los sistemas de detección de intrusos basados en anomalías no están tan desarrollados por los fabricantes debido a su baja fiabilidad frente a los sistemas de detección basados en el uso indebido.

10 Diseño del Proyecto

Como se aprecia en el documento “A taxonomy of computer program security flaws”, todos los sistemas informáticos sufren de problemas de seguridad que son técnicamente difícil y económicamente costosos para ser resueltos por los fabricantes. Por tanto el uso de IDS para la detección de ataques es de suma importancia. (M. Shyu, 2003) Sin embargo, cuando revisamos el estado de arte de las soluciones más avanzadas de IDS y de herramientas comerciales, la mayoría

de los productos utilizan el método de detección por uso indebido basándose en que la detección de anomalías no es una tecnología madura todavía.⁹

Para encontrar la razón de este hecho, se lleva a cabo un estudio detallado enfocado en técnicas basadas en anomalías, examinando diversos aspectos tales como conjunto de datos, selección de atributos, discretización y diferentes técnicas de aprendizaje, creando conjuntos de datos para el entrenamiento y su posterior evaluación (conjuntos de test).

Los datos utilizados en este estudio son del NSL-KDD Data set, el cual es una mejora de los datos del concurso KDD cup99. En KDD-99 se utilizó una versión reducida de la amplia variedad de intrusiones militares simuladas en un entorno de red, proporcionadas por DARPA Intrusion Detection Program Evaluation en 1998, que tenían como objetivo evaluar el estudio y la investigación en la detección de intrusiones. Los Laboratorios Lincoln crearon un entorno para adquirir un volcado de datos TCP durante nueve semanas, en una red de área local (LAN) que simulaba la típica red de las Fuerzas Aéreas de EE.UU salpicada con múltiples ataques. El conjunto de datos de entrenamiento, obtenidos durante las primeras 7 semanas, ocupaba cerca de cuatro gigabytes, lo que equivale aproximadamente a cinco millones de registros de conexión. Del mismo modo, los datos de test se obtuvieron durante las dos últimas semanas y rondaban dos millones de registros de conexión.

NSL-KDD viene a mejorar los fallos que tiene el conjunto de datos KDD"99. La primera deficiencia importante en el conjunto de datos KDD"99 es el gran número de registros redundantes. El análisis del conjunto de datos train y test, se encontró que alrededor del 78% y 75% de los registros se duplican en el train y en el conjunto de prueba, respectivamente. Esta cantidad grande de registros redundantes en el conjunto de entrenamiento causará que el aprendizaje de los algoritmos estará

⁹ M. Shyu, S. C. (2003). A novel anomaly detection scheme based on principal component classifier. En S. C. M. Shyu, Proceedings of the IEEE Foundations and New Directions of Data Mining Workshop, in conjunction with the Third IEEE International Conference on Data Mining (págs. 172–179). IEEE.

afectado y con lo cual desviado hacia los registros más frecuentes, y así impedirá el aprender registros menos infrecuentes que son por lo general más dañosos a redes como son los ataques de tipo U2R. Por otra parte, la existencia de estos registros repetidos en el conjunto de prueba, hará que los resultados de evaluación sean influidos por los métodos que tienen mejores tasas de detección sobre los registros frecuentes.

Los atributos del NSL-KDD Data se pueden clasificar en 3 grupos:

- 1) Características básicas: esta categoría agrupa todos los atributos que se pueden extraer de una conexión TCP / IP. La mayoría de estas características conducen a una demora en la detección.
- 2) Características del tráfico: esta categoría incluye las características que se calculan con respecto a un intervalo de la ventana y se divide en dos grupos: - Atributos de “mismo host”, que tienen en cuenta sólo las conexiones en los dos últimos segundos que tengan el mismo destino que la conexión actual, y las estadísticas relacionadas con el protocolo, los servicios, etc. - Atributos de “mismo servicio”, que examinan sólo las conexiones en los dos últimos segundos que tienen el mismo servicio que la conexión actual.

Los dos tipos de “tráfico” antes mencionados se llaman características basadas en tiempo. Sin embargo, hay varios ataques de sondeo que son lentos y escanean los puertos de los hosts en un intervalo de tiempo mucho mayor que 2 segundos, por ejemplo, uno cada minuto. Como resultado, estos ataques no producen patrones de intrusión en una ventana de tiempo de 2 segundos. Para resolver este problema, las características del “mismo servicio” y del mismo “host” se recalculan basándose en una ventana de 100 conexiones en lugar de en una ventana de tiempo de 2 segundos. Estas características de conexión se denominan basadas en “tráfico”.

- 3) Características de contenido: a diferencia de la mayoría de los ataques de DoS y de sondeo, la R2L y los ataques de U2R no tienen patrones secuenciales frecuentes. Esto es porque el DoS y Probing implican muchas conexiones a algún

host (s) en un período muy corto de tiempo, sin embargo ataques R2Ly U2R están incrustados en las porciones de datos de los paquetes, y normalmente sólo implica una única conexión. Para detectar este tipo de ataques, tenemos algunas características para ser capaces de buscar un comportamiento sospechoso en la parte de datos, por ejemplo, el número de intentos de acceso fallidos. Estas características se denominan características de contenido.

Cada registro de conexión está compuesto de 42 atributos, lo que supone unos 100 bytes por registro. Los atributos que componen un único registro se muestran en las siguientes tablas:

<i>feature name</i>	<i>description</i>	<i>type</i>
duration	length (number of seconds) of the connection	continuous
protocol_type	type of the protocol, e.g. tcp, udp, etc.	discrete
service	network service on the destination, e.g., http, telnet, etc.	discrete
src_bytes	number of data bytes from source to destination	continuous
dst_bytes	number of data bytes from destination to source	continuous
flag	normal or error status of the connection	discrete
land	1 if connection is from/to the same host/port; 0 otherwise	discrete
wrong_fragment	number of ``wrong" fragments	continuous
urgent	number of urgent packets	continuous

Table 1: Basic features of individual TCP connections.

<i>feature name</i>	<i>description</i>	<i>type</i>
hot	number of "hot" indicators	continuous
num_failed_logins	number of failed login attempts	continuous
logged_in	1 if successfully logged in; 0 otherwise	discrete
num_compromised	number of "compromised" conditions	continuous
root_shell	1 if root shell is obtained; 0 otherwise	discrete
su_attempted	1 if "su root" command attempted; 0 otherwise	discrete
num_root	number of "root" accesses	continuous
num_file_creations	number of file creation operations	continuous
num_shells	number of shell prompts	continuous
num_access_files	number of operations on access control files	continuous
num_outbound_cmds	number of outbound commands in an ftp session	continuous
is_hot_login	1 if the login belongs to the "hot" list; 0 otherwise	discrete
is_guest_login	1 if the login is a "guest" login; 0 otherwise	discrete

Table 2: Content features within a connection suggested by domain knowledge.

<i>feature name</i>	<i>description</i>	<i>type</i>
count	number of connections to the same host as the current connection in the past two seconds	continuous
<i>Note: The following features refer to these same-host connections.</i>		
error_rate	% of connections that have "SYN" errors	continuous
error_rate	% of connections that have "REJ" errors	continuous
same_srv_rate	% of connections to the same service	continuous
diff_srv_rate	% of connections to different services	continuous
srv_count	number of connections to the same service as the current connection in the past two seconds	continuous
<i>Note: The following features refer to these same-service connections.</i>		
srv_error_rate	% of connections that have "SYN" errors	continuous
srv_error_rate	% of connections that have "REJ" errors	continuous
srv_diff_host_rate	% of connections to different hosts	continuous

Table 3: Traffic features computed using a two-second time window.

Ataque	Categoría	Frecuencia
Apache2	Dos	737
Back	Dos	555
Land	Dos	8
Mailbomb	Dos	293
Neptune	Dos	12939
Pod	Dos	79
Processtable	Dos	685
Smurf	Dos	1194
Teardrop	Dos	200
Udpstorm	Dos	2
Normal	Normal	23160
Ipsweep	Probe	851
Mscan	Probe	996
Nmap	Probe	374
PortswEEP	Probe	685
Saint	Probe	319
Satan	Probe	1426
Ftp_write	R2L	4
Guess_Passwd	R2L	1241
Imap	R2L	6
Multihop	R2L	20
Named	R2L	17
Phf	R2L	4
Sendmail	R2L	14
Snmpgetattack	R2L	178
Snmpguess	R2L	331
Spy	R2L	1
Warezcclient	R2L	181
WarezmasteR	R2L	951
Worm	R2L	2
Xlock	R2L	9
Xsnoop	R2L	4
Buffer_Overflow	U2R	26
Httpunnel	U2R	133
Loadmodule	U2R	3
Perl	U2R	2
Ps	U2R	15
Rootkit	U2R	17
Sqllattack	U2R	2
Xterm	U2R	13

El conjunto de datos contiene un total de 40 tipos de ataques los cuales se clasifican en 5 categorías diferentes como se puede observar en la figura. Para llevar a cabo el estudio analizaremos este conjunto de datos de 3 formas distintas. Como se puede observar la cantidad de ataques presentes en el conjunto de datos global y de manera general los registros de tipos Probe, R2L y U2R, especialmente estos últimos, quedan en desventaja frente a los registros de tipo Normal y Dos. En el primer estudio el más sencillo, se pretenderá analizar determinados algoritmos de aprendizaje para el modelado del sistema, a nivel de detección de si una conexión es de tipo ataque -independientemente del tipo de ataque que sea- o por el contrario es de tipo normal -situación de no amenaza-. Por tanto el análisis es a nivel de 2 categorías: “ataque” y “normal”. Se crearán ficheros balanceados -igual cantidad de ataques y normal en el fichero de entrenamiento-, para no favorecer el sobre-entrenamiento por parte del modelo favoreciendo a una categoría con más

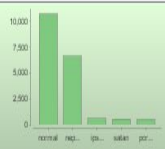
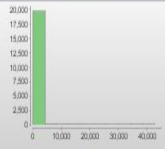
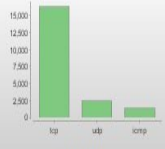
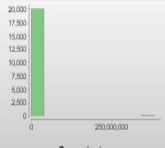
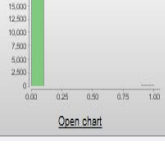
presencia de registros, donde el conjunto de datos será dividido para diez pasadas por validación cruzada donde en cada pasada usará un segmento de los diez para test y los otros nueve para entrenamiento cambiándolos para tener un modelo que no se encuentre ajustado a los datos, por tanto sesgado a un tipo de clase.

En el segundo caso de estudio, la situación se complica un poco más, los datos son clasificados en 5 categorías (este es uno de los métodos más utilizados) y se crearán diez particiones como en el caso anterior, en esta situación los datos no están balanceados –simulando una situación más real- y estudiaremos el comportamiento de todos los algoritmos explicados a la hora de clasificar los ataques en 5 categorías.

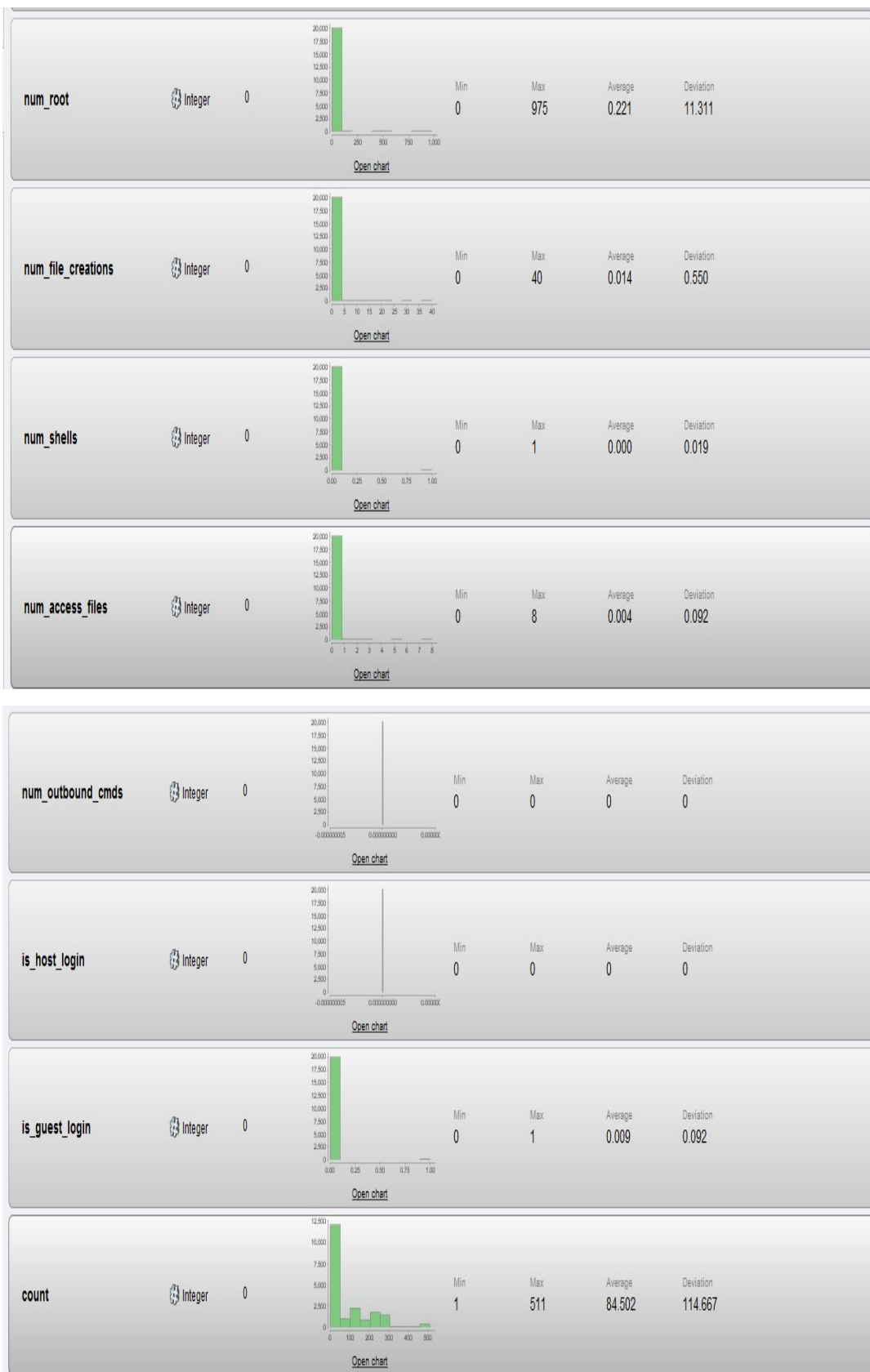
En el tercer estudio se procederá de la misma manera que en el primer caso creando ficheros balanceados sólo que el estudio se realizara a un nivel más complejo, ya no se pretenderá detectar la categoría de un ataque sino un ataque en concreto.

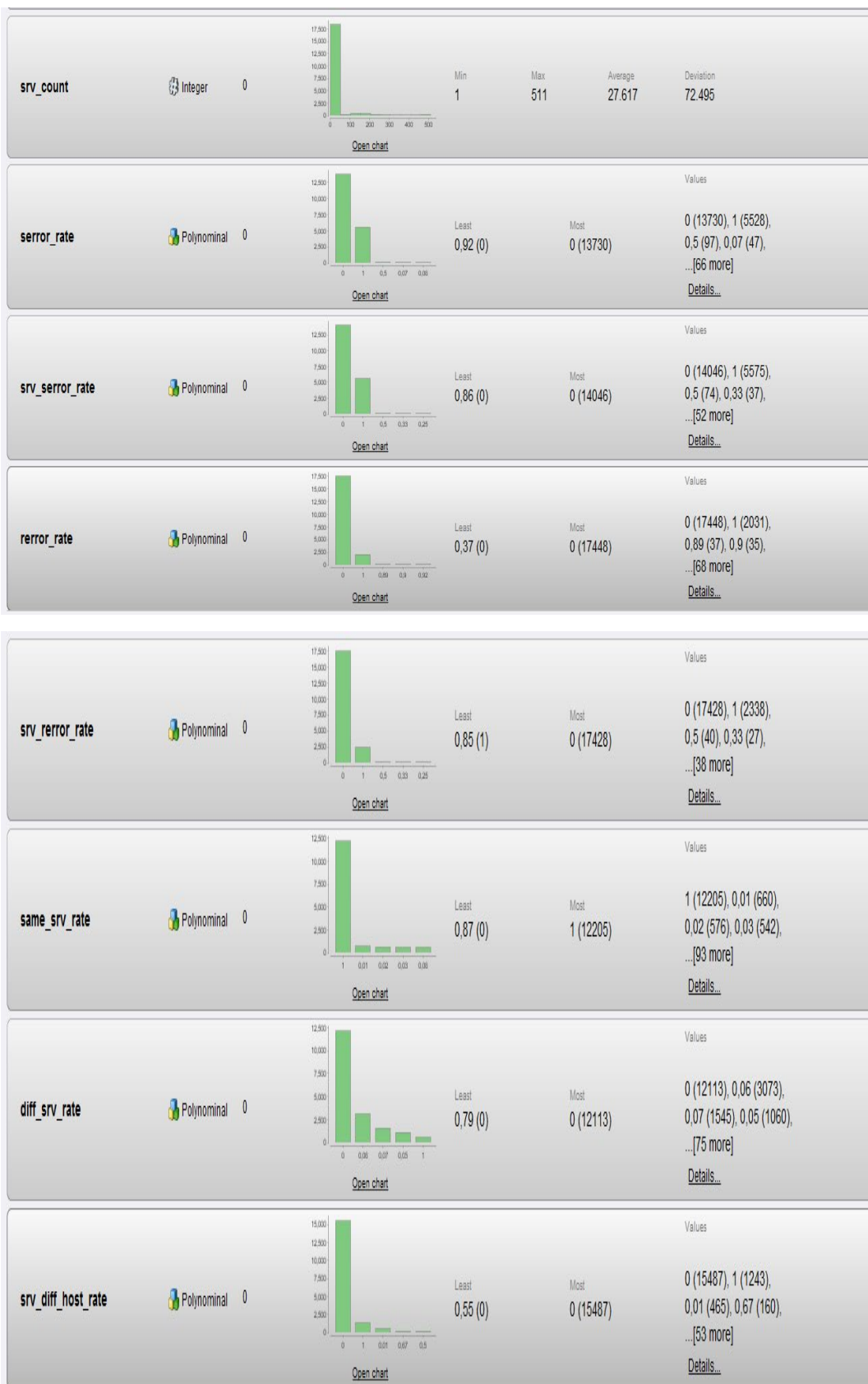
Hemos explicado la perspectiva por la cual abordaremos el estudio de los sistemas de detección de intrusos basados en anomalías, los cuales utilizan algoritmos de aprendizaje automático para su motor de análisis, para clasificar entre situación de ataque o situación de normalidad.

10.1 Análisis de los datos (Estadístico y Gráfico)

Name	Type	Miss.	Statistics	Filter (42 / 42 attributes): Filter
label Class	Polynomial	0	 Least: spy (1) Most: normal (10643) Values: normal (10643), neptune (6568), ipsweep (570), satan (554), ...[18 more] Details...	
duration	Integer	0	 Min: 0 Max: 42862 Average: 310.867 Deviation: 2721.531 Open chart	
protocol_type	Polynomial	0	 Least: icmp (1299) Most: tcp (16319) Values: tcp (16319), udp (2382), icmp (1299) Details...	
service	Polynomial	0	 Least: http_8001 (1) Most: http (6359) Values: http (6359), private (3469), domain_u (1437), smtp (1155), ...[62 more] Details...	
flag	Polynomial	0	 Least: OTH (5) Most: SF (11862) Values: SF (11862), SO (5578), REJ (1766), RSTR (400), ...[7 more] Details...	
src_bytes	Integer	0	 Min: 0 Max: 381709090 Average: 28215.027 Deviation: 2704155.518 Open chart	
dst_bytes	Integer	0	 Min: 0 Max: 5151385 Average: 3583.562 Deviation: 91965.477 Open chart	
land	Integer	0	 Min: 0 Max: 1 Average: 0.000 Deviation: 0.010 Open chart	







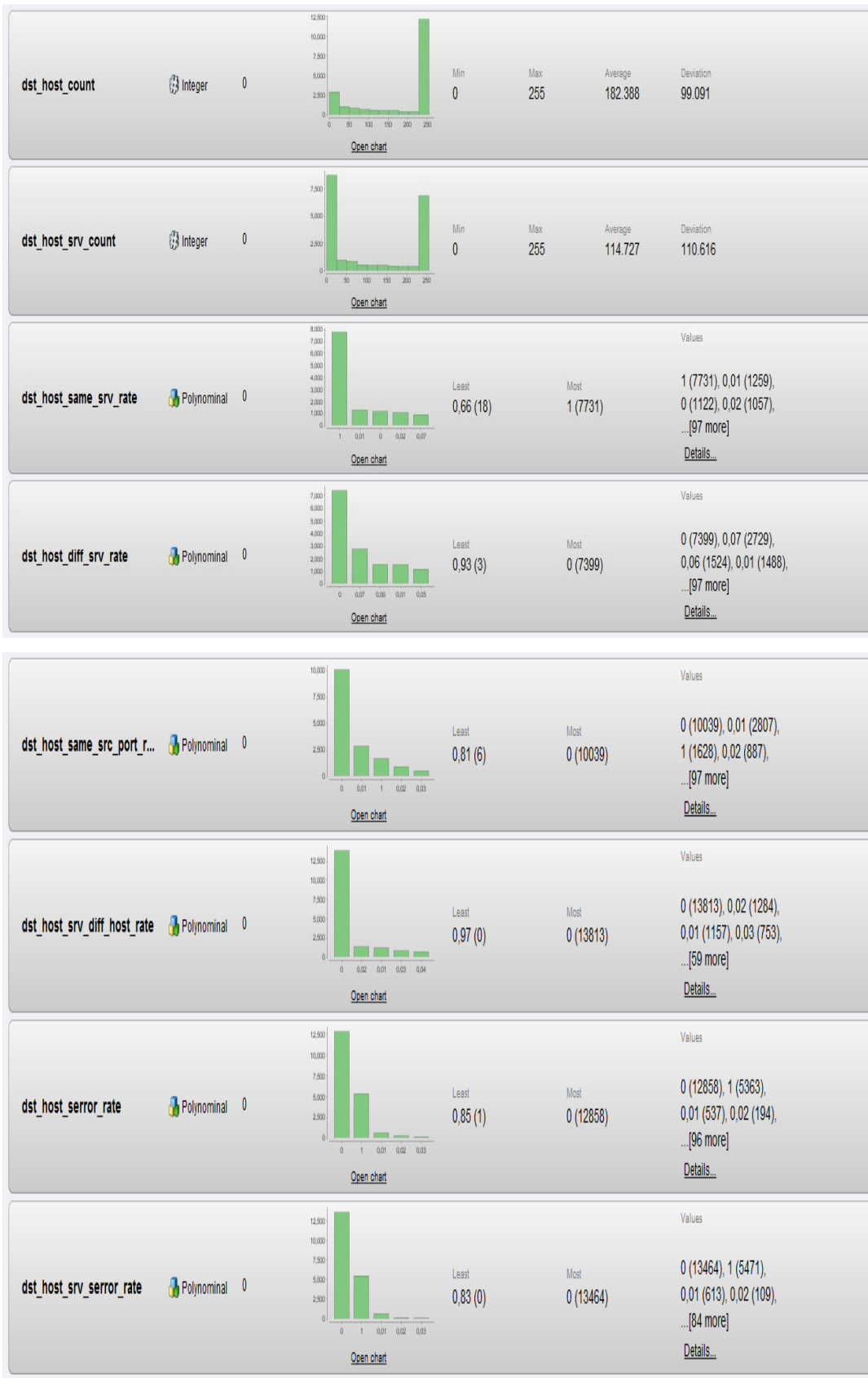




Ilustración 7: Tabla de Resultados Análisis RapidMiner (Elaboración Propia)

En la ilustración 5 se puede observar los datos obtenidos al realizar el análisis con RapidMiner de toda la información contenida en el data set (alrededor de 25193 registros), que representa un 20% del total de los registros del data set.

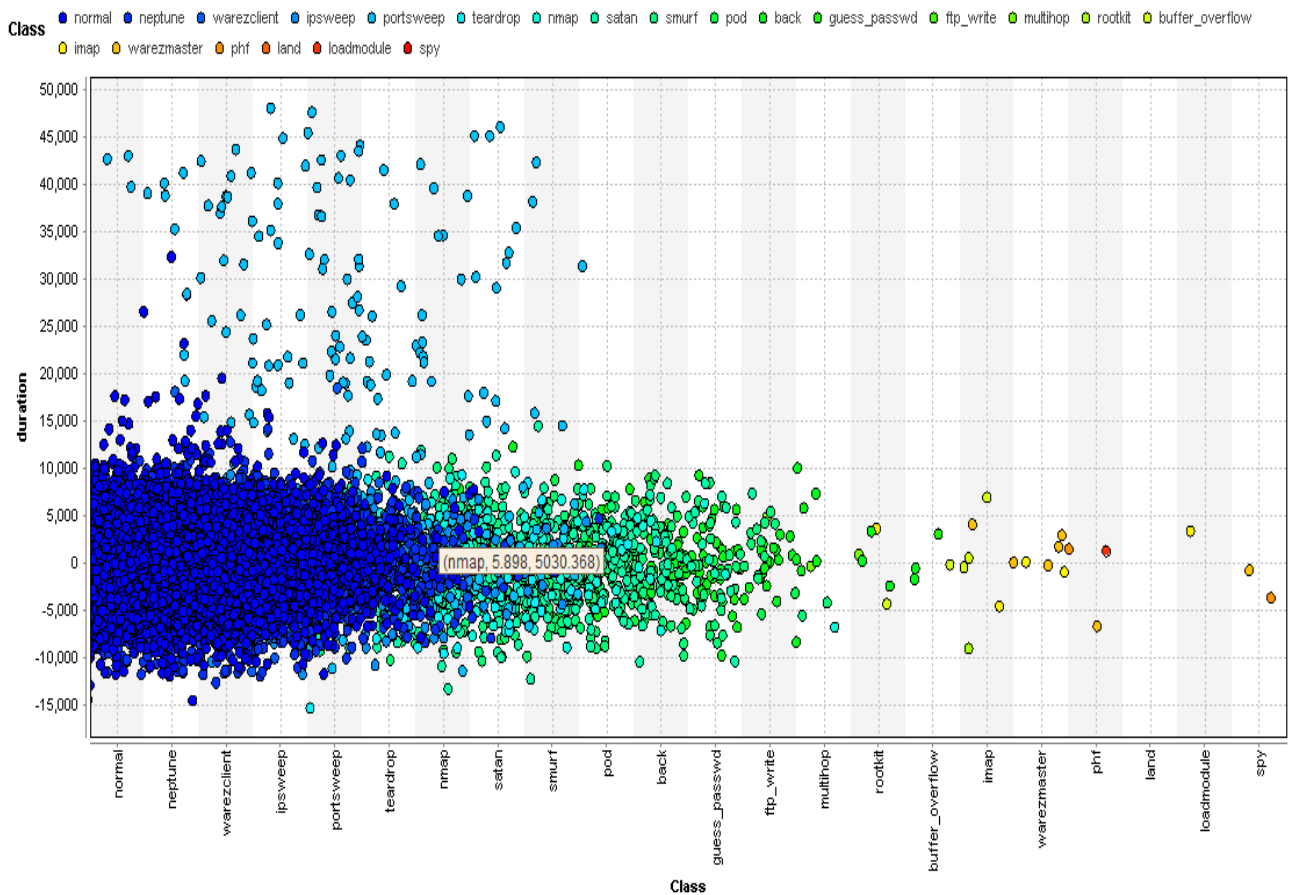


Ilustración 8: Gráfico Distribución Tiempo de Conexión - Clase (Elaboración Propia)

En la ilustración 6 se muestra que la distribución de los datos en cuanto a la clase del tiempo de conexión puede ser un valor que nos sirva como predictivo puesto que pueden separarse.

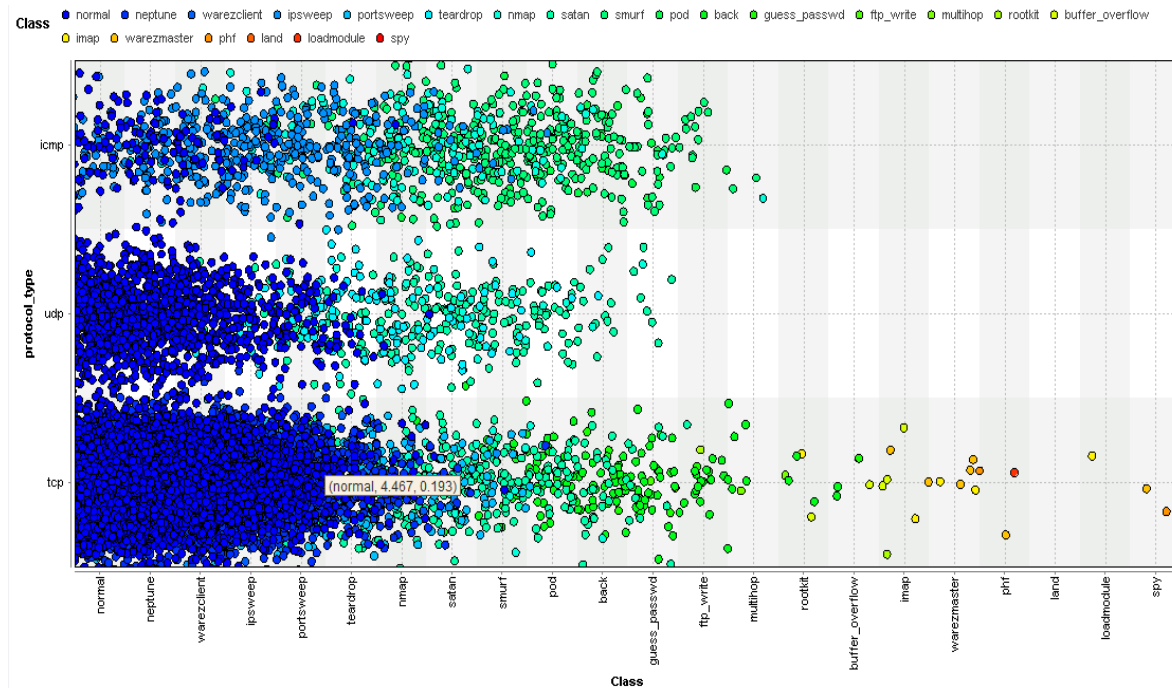


Ilustración 9: Gráfico Distribución (Tipo de Protocolo - Clase) Elaboración Propia

En la ilustración 7 se muestra que la distribución de los datos en cuanto a la clase del tipo de protocolo (tcp, udp e icmp) puede ser un valor que nos sirva como predictivo puesto la ilustración nos demuestra que dichos datos de los .

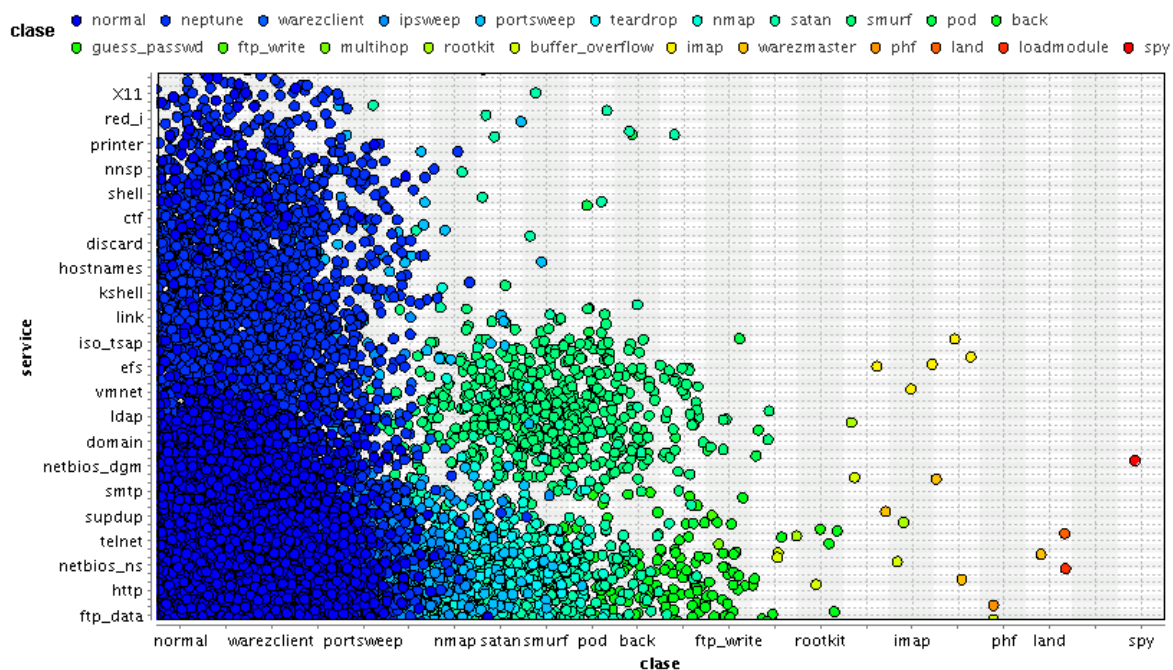


Ilustración 10: Gráfico Distribución (Servicio - Clase) Elaboración Propia

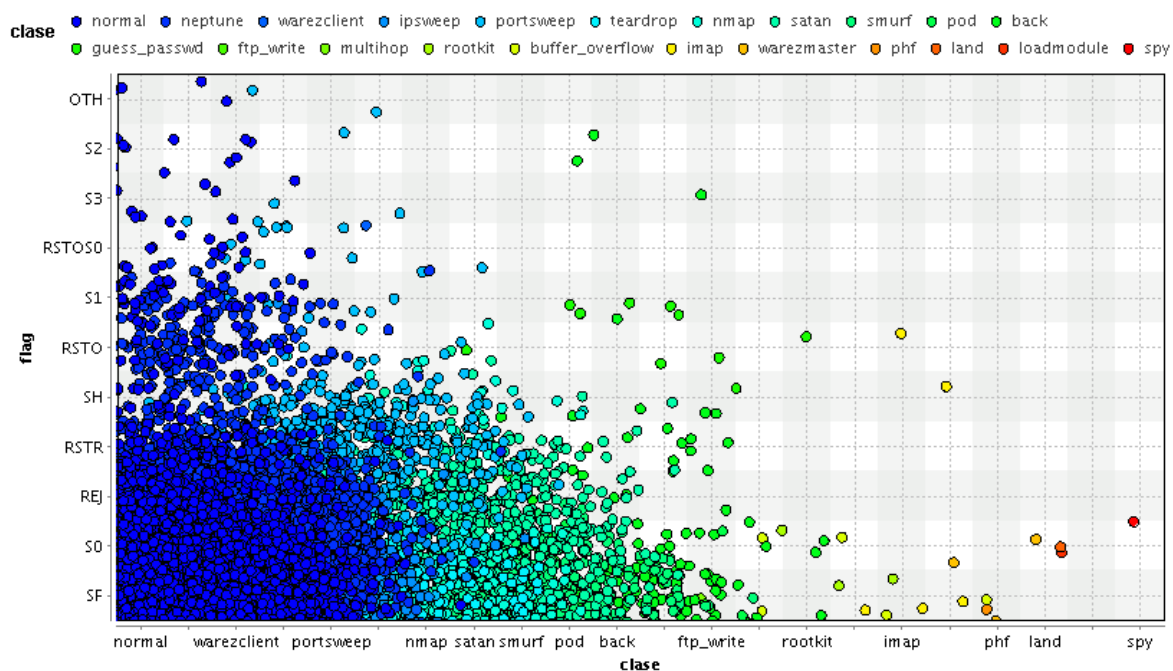


Ilustración 11: Gráfico Distribución (Flag - Clase) Elaboración Propia

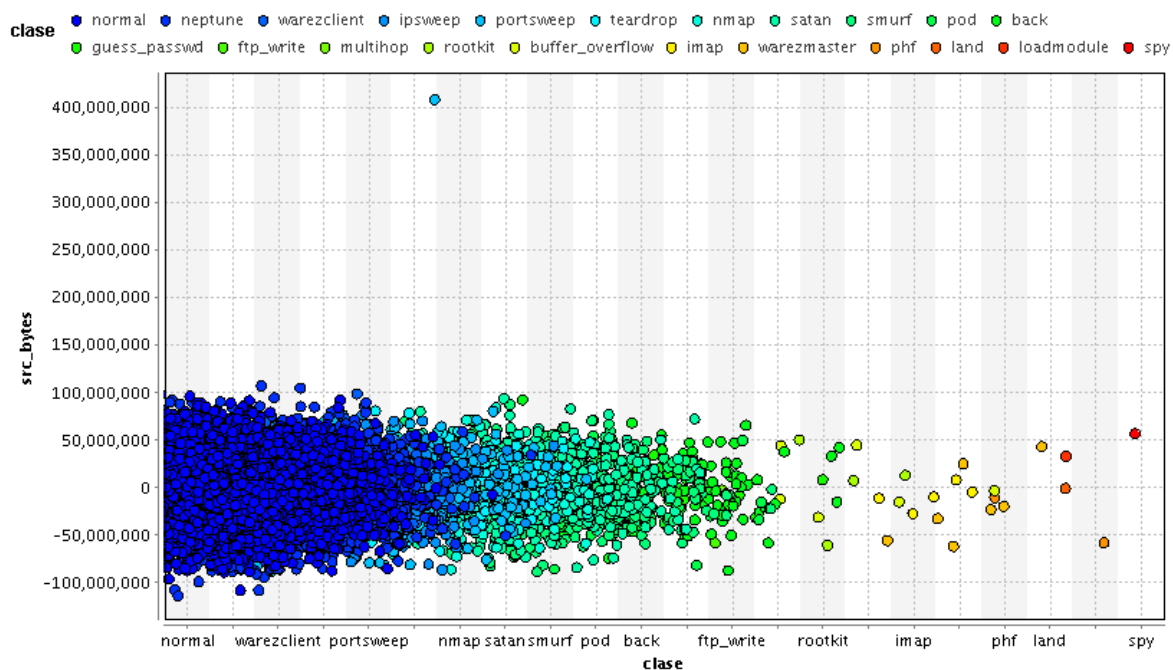


Ilustración 12: Gráfico Distribución (Bytes transmitidos Fuente - Clase) Elaboración Propia

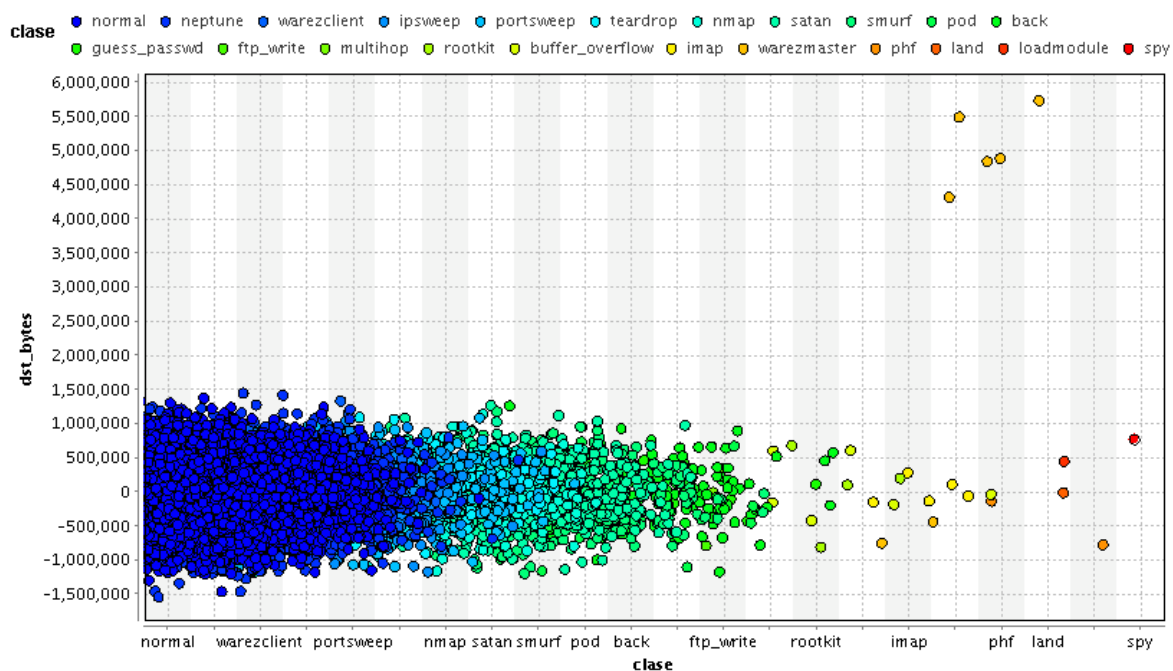


Ilustración 13: Gráfico Distribución (Bytes transmitidos Destino - Clase) Elaboración Propia

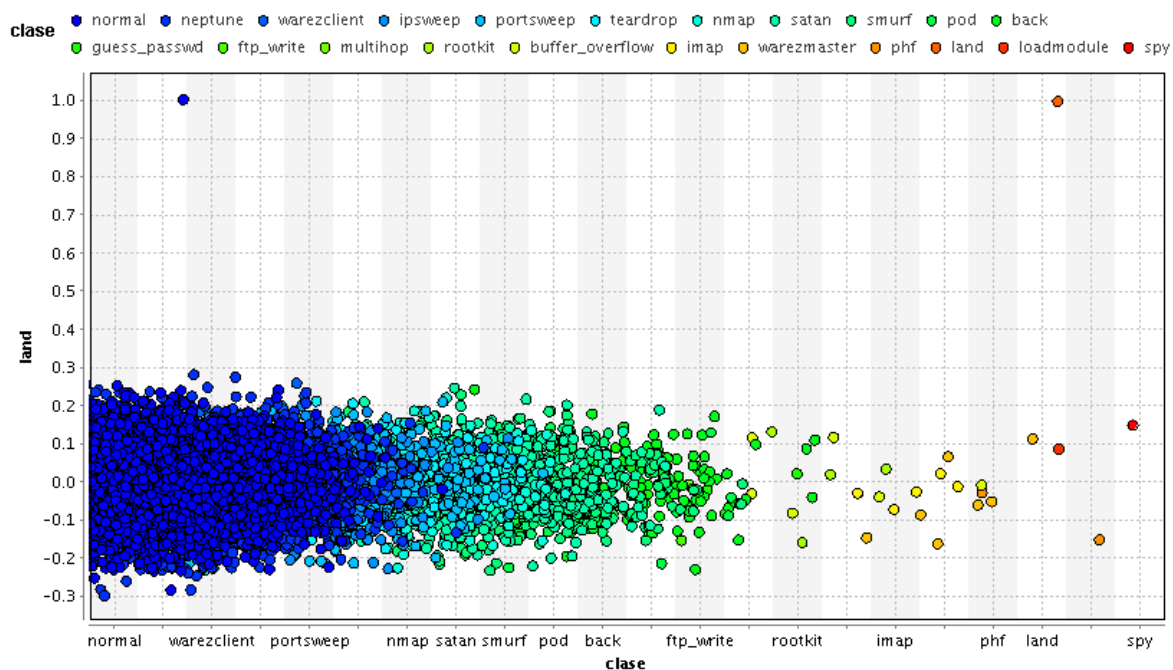


Ilustración 14: Gráfico Distribución (Land - Clase) Elaboración Propia

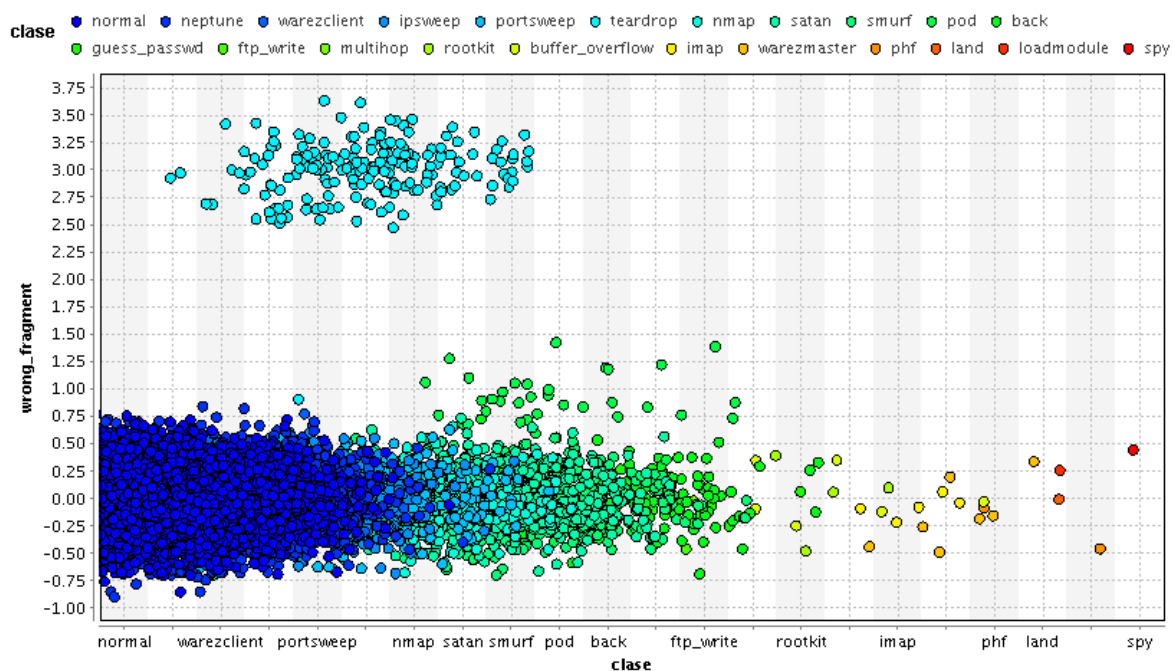


Ilustración 15: Gráfico Distribución (Fragmentos Errados - Clase) Elaboración Propia

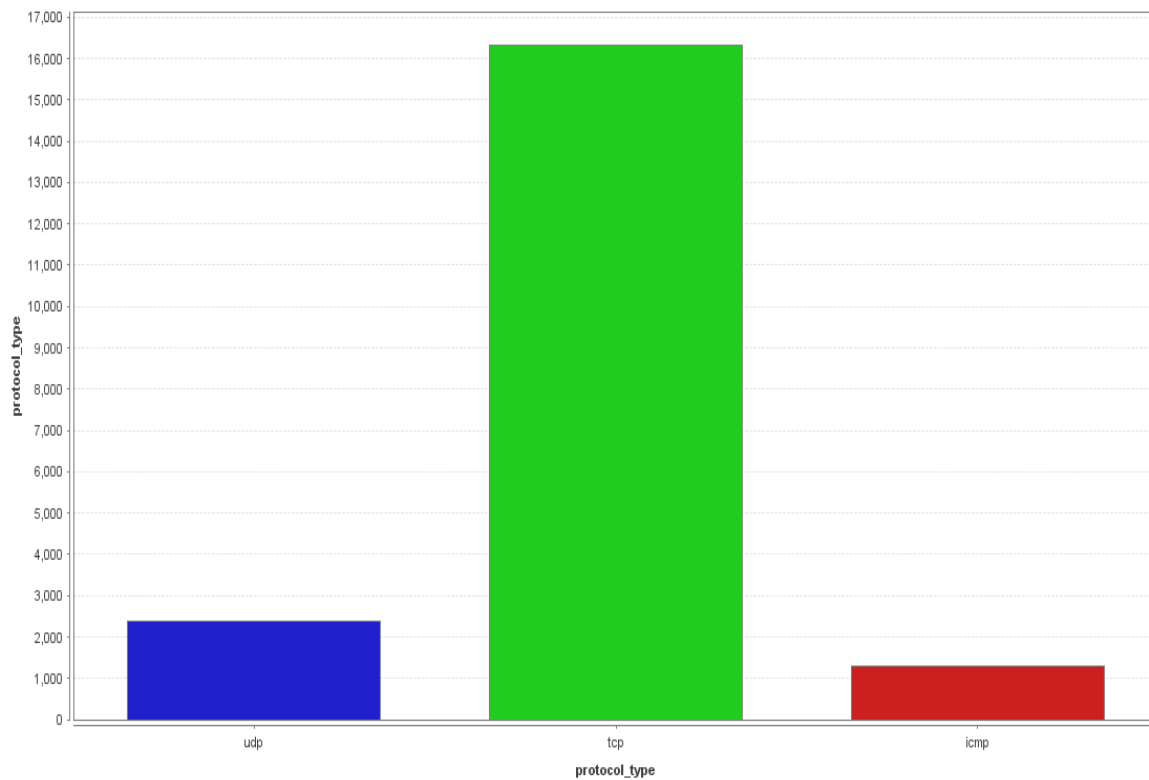


Ilustración 16: Frecuencia Tipo de Protocolo (Elaboración Propia)

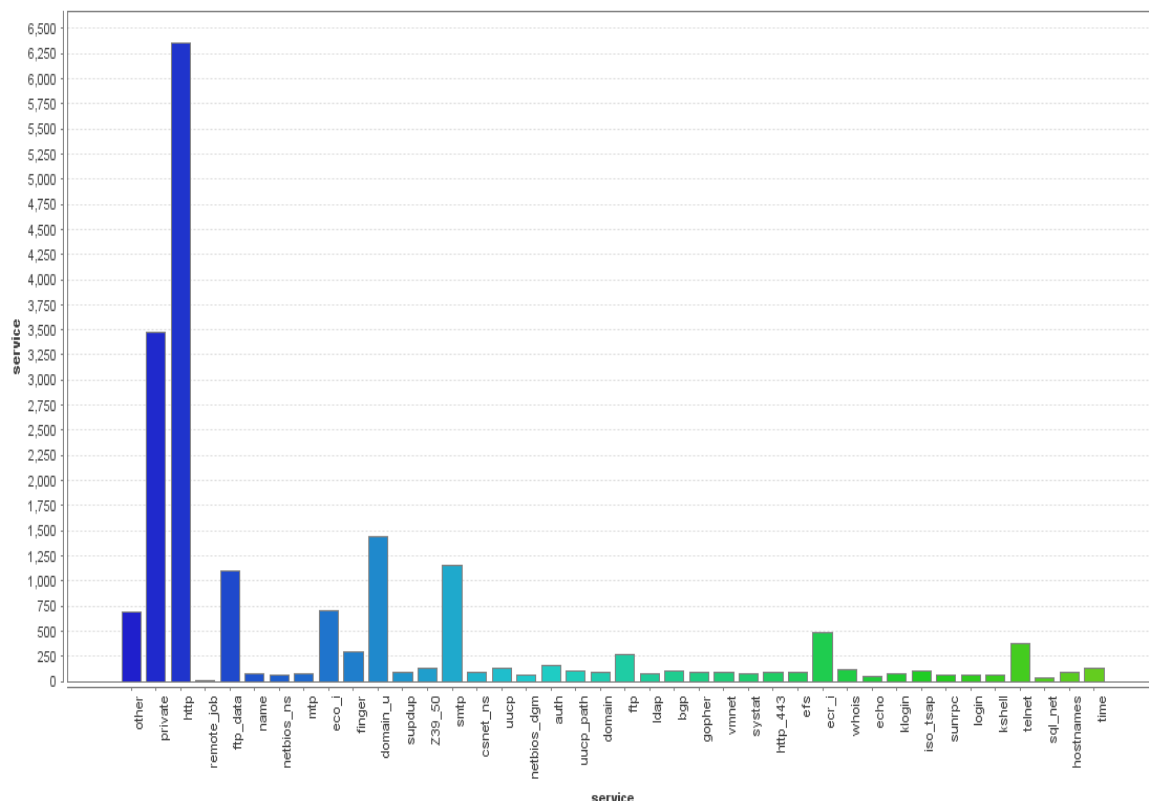


Ilustración 17: Frecuencia por tipo de servicio (Elaboración Propia)

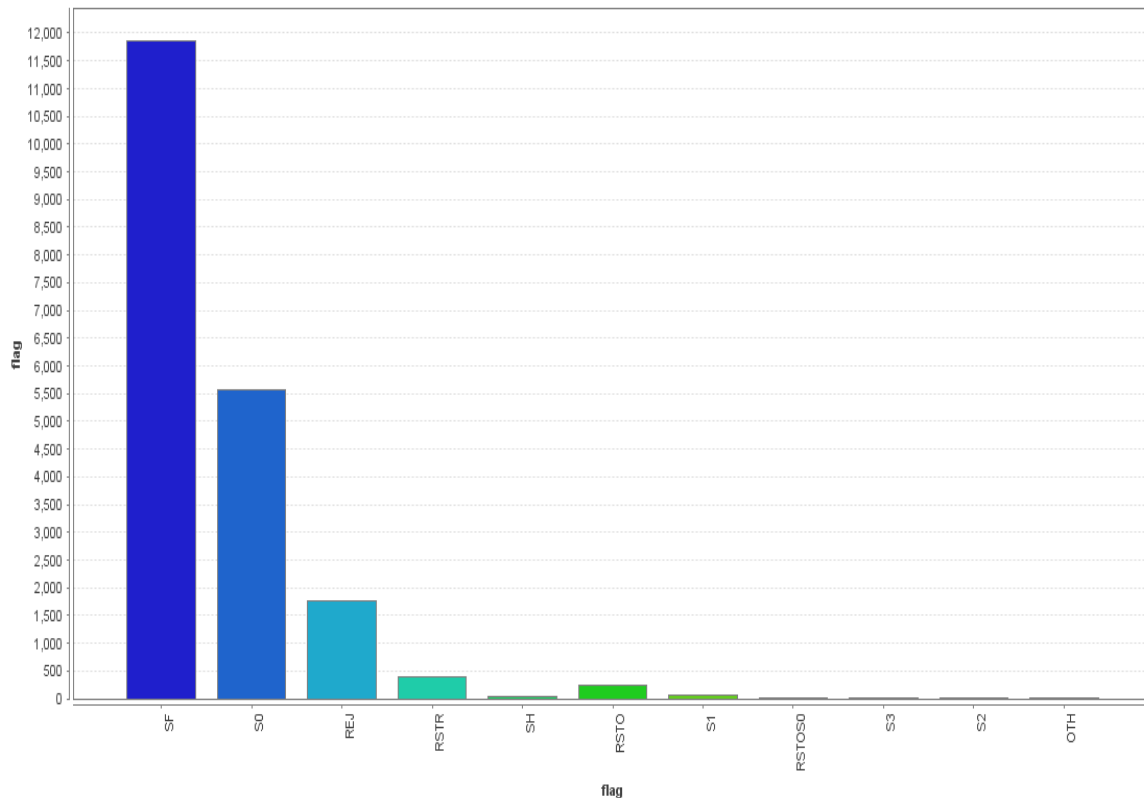


Ilustración 18: Frecuencia por tipo de flag (Elaboración Propia)

10.2 Selección de Variables

En este punto daremos inicio al estudio propiamente dicho para poder realizar un análisis mucho más detallado que el presentado en el punto anterior, para identificar de los 41 atributos que se manejan en el data set cuales son más representativos y que nos pueden ayudar a generar el modelo para lograr los objetivos por los cuales se realiza esta investigación.

Para poder ponderar los atributos se realizó tres tipos de estudios (chi cuadrado, ganancia de información y correlación) mediante los cuales y realizando una comparación determinaremos el peso de cada uno de ellos y que nos ayudarán a poder desechar aquellos que no tengan incidencia sustancial para nuestra investigación.

10.2.1 Chi Cuadrado

Atributo	Peso Chi
Service	1,000
Flag	0,670
dst_host_srv_diff_host_rate	0,669
wrong_fragment	0,661
dst_host_serror_rate	0,656
dst_host_srv_serror_rate	0,625
dst_host_diff_srv_rate	0,598
diff_srv_rate	0,520
same_srv_rate	0,515
serror_rate	0,484
srv_serror_rate	0,475
dst_host_same_srv_rate	0,433
Count	0,414
dst_host_same_src_port_rate	0,397
dst_host_rerror_rate	0,375
rerror_rate	0,349
protocol_type	0,306
dst_host_srv_rerror_rate	0,299
srv_count	0,297
dst_host_srv_count	0,278
srv_rerror_rate	0,262
num_failed_logins	0,224
dst_bytes	0,221
srv_diff_host_rate	0,216
logged_in	0,188
Land	0,174
dst_host_count	0,168
Urgent	0,116

Hot	0,102
Duration	0,091
root_shell	0,068
num_access_files	0,066
num_file_creations	0,050
is_guest_login	0,030
num_shells	0,025
src_bytes	0,001
num_compromised	0,000
su_attempted	0,000
num_root	0,000
is_host_login	0,000
num_outbound_cmds	0,000

Tabla 1: Cuadro de peso obtenido con Chi Cuadrado

En la tabla 1 se realizó una valoración de todos los atributos mediante el peso por cada uno de los atributos utilizando el chi cuadrado.

10.2.2 Ganancia de Información

Atributo	Peso Information Gain
Service	1,000
Flag	0,874
diff_srv_rate	0,854
dst_host_diff_srv_rate	0,820
same_srv_rate	0,794
dst_host_same_srv_rate	0,741
src_bytes	0,715
dst_host_serror_rate	0,657
serror_rate	0,618
dst_host_srv_serror_rate	0,581

dst_bytes	0,576
srv_serror_rate	0,551
dst_host_same_src_port_rate	0,525
Count	0,486
dst_host_srv_count	0,473
logged_in	0,450
dst_host_srv_diff_host_rate	0,427
protocol_type	0,325
dst_host_rerror_rate	0,280
dst_host_count	0,274
srv_diff_host_rate	0,245
dst_host_srv_rerror_rate	0,211
rerror_rate	0,203
srv_rerror_rate	0,144
srv_count	0,142
Duration	0,073
wrong_fragment	0,067
Hot	0,062
num_compromised	0,047
is_guest_login	0,014
num_root	0,005
num_failed_logins	0,005
root_shell	0,004
num_file_creations	0,004
num_access_files	0,004
Land	0,001
Urgent	0,001
num_shells	0,001
su_attempted	0,001
is_host_login	0,000

num_outbound_cmds	0,000
-------------------	-------

Tabla 2: Cuadro de peso obtenido con Information Gain

En la tabla 2 se realizó una valoración de todos los atributos mediante el peso por cada uno de los atributos utilizando ganancia de información.

10.2.3 Correlación

Atributo	Peso por Correlación
protocol_type	1,000
dst_host_error_rate	0,905
logged_in	0,845
Count	0,824
srv_count	0,750
dst_host_srv_count	0,732
dst_host_diff_srv_rate	0,710
error_rate	0,603
wrong_fragment	0,473
serror_rate	0,470
Flag	0,451
dst_host_serror_rate	0,411
srv_diff_host_rate	0,386
dst_host_same_src_port_rate	0,378
srv_error_rate	0,316
diff_srv_rate	0,294
dst_bytes	0,260
Duration	0,234
same_srv_rate	0,219
dst_host_count	0,207
Service	0,187
root_shell	0,152

num_failed_logins	0,115
Urgent	0,109
Land	0,100
dst_host_srv_diff_host_rate	0,097
dst_host_srv_rerror_rate	0,094
dst_host_same_srv_rate	0,072
srv_serror_rate	0,060
Hot	0,056
is_guest_login	0,035
su_attempted	0,031
src_bytes	0,020
num_file_creations	0,020
num_root	0,017
num_shells	0,013
num_compromised	0,009
num_access_files	0,002
dst_host_srv_serror_rate	0,000
is_host_login	0,000
num_outbound_cmds	0,000

Tabla 3: Cuadro de peso obtenido con Correlación

En la tabla 3 se realizó una valoración de todos los atributos mediante el peso por cada uno de los atributos utilizando correlación.

10.2.4 Promedio análisis de pesos

Atributo	Promedio
service	0,729
dst_host_diff_srv_rate	0,709
Flag	0,665
Count	0,575

dst_host_serror_rate	0,575
diff_srv_rate	0,556
protocol_type	0,544
serror_rate	0,524
dst_host_rerror_rate	0,520
same_srv_rate	0,509
dst_host_srv_count	0,494
logged_in	0,494
dst_host_same_src_port_rate	0,433
dst_host_same_srv_rate	0,416
dst_host_srv_serror_rate	0,402
wrong_fragment	0,401
dst_host_srv_diff_host_rate	0,398
srv_count	0,396
rerror_rate	0,385
srv_serror_rate	0,362
dst_bytes	0,352
srv_diff_host_rate	0,282
src_bytes	0,245
srv_rerror_rate	0,240
dst_host_count	0,216
dst_host_srv_rerror_rate	0,201
duration	0,133
num_failed_logins	0,115
land	0,092
urgent	0,075
root_shell	0,075
Hot	0,074
is_guest_login	0,026
num_file_creations	0,025

num_access_files	0,024
num_compromised	0,019
num_shells	0,013
su_attempted	0,011
num_root	0,007
is_host_login	0,000
num_outbound_cmds	0,000

Tabla 4: Cuadro de peso promedio

La tabla 4 nos muestra los atributos con mayor peso los cuales son de importancia para su elección dentro de la investigación.

Al realizar la revisión de los pesos calculados con cada uno de los tres tipos de estudios para tener un promedio para poder tener una amplitud sin sesgarnos en ninguno de los estudios.

Atributo
service
dst_host_diff_srv_rate
flag
count
dst_host_serror_rate
diff_srv_rate
protocol_type
serror_rate
dst_host_rerror_rate
same_srv_rate
dst_host_srv_count
logged_in
dst_host_same_src_port_rate
dst_host_same_srv_rate

dst_host_srv_error_rate

Tabla 5: Cuadro de las variables seleccionadas

10.3 Correlación de Variables

En este punto se realiza la matriz de correlación de las variables seleccionadas en el punto 10.2 al realizar tres estudios por diferentes métodos (chi cuadrado, ganancia de información y correlación) de cálculo de pesos, de esta manera obtener un peso promedio de las 41 variables; de las cuales se ha seleccionado las 15 primeras por ser las más representativas en cuanto a su peso.

Las variables seleccionadas fueron sometidas a un proceso el cual nos genera una matriz con el objetivo de verificar la correlación que existen entre las variables, de existir una correlación alta es decir cercana a 1 se desechara la variable con menor peso.

Attributes	protocol_type	service	flag	logged_in	count	error_rate	same_srv_r...	diff_srv_rate	dst_host_sr...	dst_host_s...	dst_host_di...	dst_host_s...	dst_host_s...	dst_host_sr...	dst_host_re...
protocol_type	1	0.046	-0.270	-0.357	0.072	-0.074	-0.066	0.019	0.066	0.104	0.081	0.194	-0.049	-0.081	-0.017
service	0.046	1	0.197	-0.303	0.349	-0.039	0.150	0.053	-0.327	0.065	-0.068	-0.137	-0.027	0.028	-0.057
flag	-0.270	0.197	1	-0.419	0.283	0.171	0.213	0.131	-0.446	-0.118	0.176	-0.081	0.109	0.076	0.206
logged_in	-0.357	-0.303	-0.419	1	-0.539	-0.093	-0.396	-0.280	0.628	-0.004	-0.186	0.016	-0.016	-0.006	-0.075
count	0.072	0.349	0.283	-0.539	1	0.180	0.202	0.109	-0.402	-0.042	0.007	-0.138	0.086	-0.038	0.047
error_rate	-0.074	-0.039	0.171	-0.093	0.180	1	0.128	0.214	-0.118	-0.059	0.130	-0.003	0.268	0.043	0.247
same_srv_r...	-0.066	0.150	0.213	-0.396	0.202	0.128	1	0.524	-0.410	0.019	0.087	-0.085	0.004	0.050	0.010
diff_srv_rate	0.019	0.053	0.131	-0.280	0.109	0.214	0.524	1	-0.280	0.009	0.182	0.034	0.055	0.027	0.096
dst_host_sn	0.066	-0.327	-0.446	0.628	-0.402	-0.118	-0.410	-0.280	1	-0.084	-0.296	-0.050	-0.130	-0.101	-0.120
dst_host_sa	0.104	0.065	-0.118	-0.004	-0.042	-0.059	0.019	0.009	-0.084	1	0.102	0.274	0.060	0.095	-0.010
dst_host_dif	0.081	-0.068	0.176	-0.186	0.007	0.130	0.087	0.182	-0.296	0.102	1	0.309	0.186	0.015	0.327
dst_host_sa	0.194	-0.137	-0.081	0.016	-0.138	-0.003	-0.085	0.034	-0.050	0.274	0.309	1	0.083	0.005	0.177
dst_host_se	-0.049	-0.027	0.109	-0.016	0.086	0.268	0.004	0.055	-0.130	0.060	0.186	0.083	1	0.294	0.183
dst_host_sn	-0.081	0.028	0.076	-0.006	-0.038	0.043	0.050	0.027	-0.101	0.095	0.015	0.005	0.294	1	-0.004
dst_host_rei	-0.017	-0.057	0.206	-0.075	0.047	0.247	0.010	0.096	-0.120	-0.010	0.327	0.177	0.183	-0.004	1

Tabla 6: Correlación de variables seleccionadas para investigación

Para poder realizar un análisis de las variables podemos decir que existen dos tipos de correlación que se encontró, la correlación directa y la inversa; cómo podemos observar en la tabla 6 cuando una variable tiene correlación directa se concluye que cuando una de ellas aumenta su valor dentro del estudio la otra también lo hará. En cambio cuando es correlación inversa (signo negativo) cuando una variable aumenta la otra disminuye).

10.4 Primer Estudio Experimental a nivel ataque o normal

Para el primer estudio a realizar, se clasificara la información contenida en el data set únicamente en dos tipos:

- Ataque
- Normal

Estos dos tipos serán los que conformen la clase para el primer caso de estudio.

10.4.1 Preparación de datos

Para lograr este objetivo primeramente se realizará una categorización de normal o ataque (aglutinando a todos los ataques), dentro del cual se quería tener un fichero lo más balanceado posible obteniendo en el recuento de los registros 13.449 registros de normal y 11.743 registros catalogados como ataque. Este data set con nombre “Data Set Ataque – Normal”, el cual fue importado al RapidMiner para incorporarlo al proceso respectivo que se realizará en esta herramienta para generar el modelo. A continuación se ve gráficamente la cantidad de datos por cada categoría de la clase.

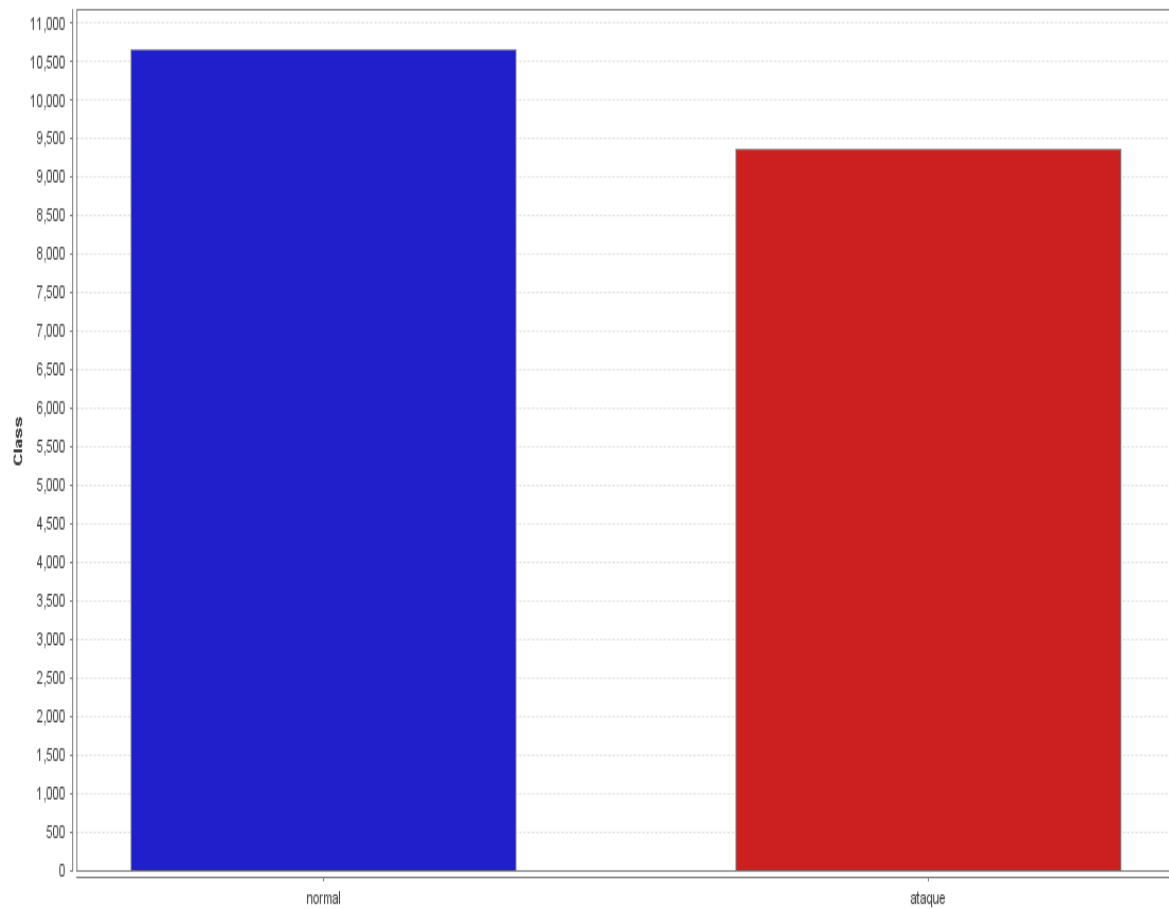


Ilustración 19: Gráfico de la distribución de registros de la muestra

10.4.2 Árbol de decisión

10.4.2.1 Modelado

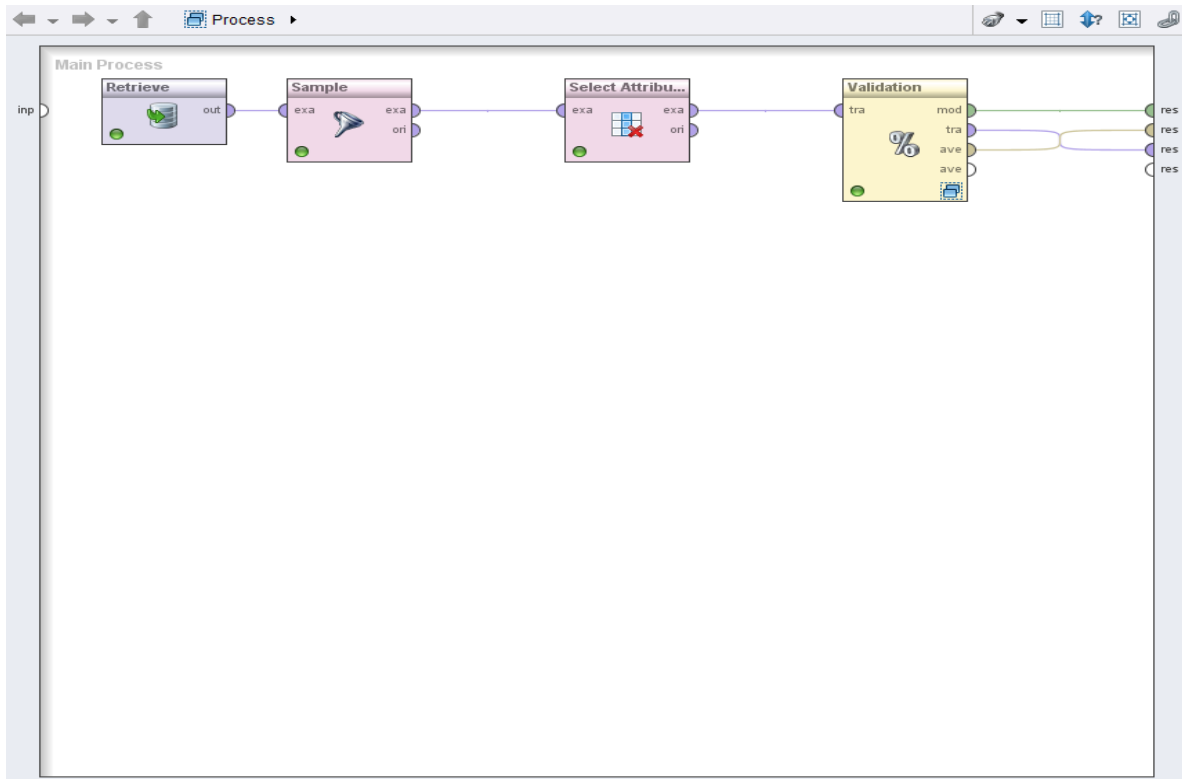


Ilustración 20: Proceso Estudio I (Ataque - Normal)

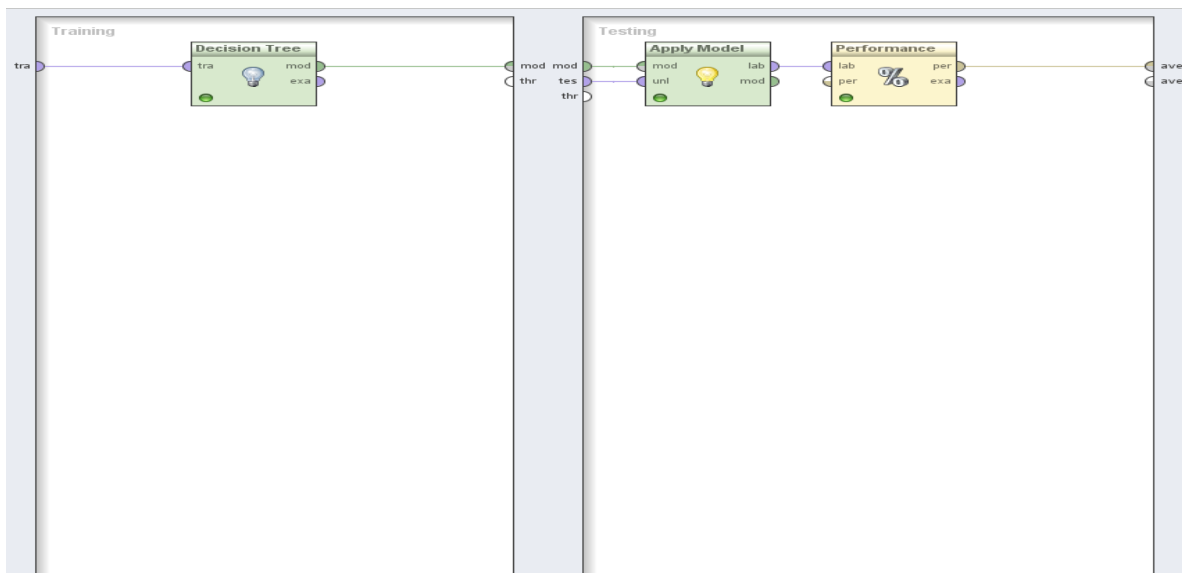


Ilustración 21: Proceso de entrenamiento y prueba Estudio I (Ataque - Normal)

En base al árbol de decisión obtenido, se pudieron identificar de manera general que dependiendo de los valores de las 15 variables escogidas para el desarrollo de esta investigación podemos encontrar varios caminos para poder detectar si es un ataque o no mediante los datos de una conexión.

Una vez analizado el árbol de decisión generado en rapidminer, encontramos que de las 15 variables escogidas del data set, las que nos ayudarían a descubrir si estamos ante una intrusión o no son las siguientes:

- logged_in.- 1 = logeo exitoso, caso contrario = 0
- dst_host_srv_count.- Sumatoria de conexiones al mismo puerto destino.
- count.- Número de conexiones del mismo host en la conexión actual
- protocol_type.- El tipo de protocolo por el cual se realiza la conexión.
- Service.- Servicio de red en el destino.
- serror_rate.- Porcentaje de conexiones que tienen error de sincronización.
- Flag.- Estado de la conexión (SF, S0, S1, S2, S3, OTH, REJ, RSTO, RSTOSO, SH, RSTRH, SHR)

De esta selección de variables, se identificaron 3 variables las cuales siguen un patrón general que son identificados como ataques según su valor, estos datos los podemos ver en la siguiente tabla:

Variable	Valor	Ataque
Protocol_type	ICMP	SI
Service	PRIVATE, ECR_I	SI
Flag	REJ, S0	SI

En base a la tabla descrita podemos deducir que cuando el tipo de protocolo por el cual se realiza la conexión es ICMP se trata de un ataque, para los casos en los cuales el tipo de protocolo sea TCP y el número de conexiones desde el mismo host sea mayor a 22, se considera como un posible ataque y para los casos en los cuales el tipo de protocolo sea UDP y el servicio de red sea privado es considerado como

ataque. Cuando el servicio de red es de tipo PRIVADO o ECR_I, se trata de un ataque. Cuando el estado de la conexión no es normal y se encuentra en los valores REJ y S0, también es considerado como ataque.

Sobre las variables de sumatoria de conexiones al mismo puerto y la del número de conexiones del mismo host en la conexión actual, podemos identificar que los valores de estas dos variables son versátiles.

Se pudo identificar que las vulnerabilidades se encuentran en tipos de ataques como la denegación de servicios al identificar el tipo de protocolo ICMP, dicho protocolo se utiliza para el envío de mensajes de error en caso de que un servicio determinado no esté disponible y al tener una cantidad considerable de conexiones al mismo puerto y dirección IP destino, se considera como ataque.

En los casos en los cuales el tipo de servicio es privado se puede determinar un ataque ya que no se conoce el la conexión al ser de tipo privado.

10.4.3 Naive Bayes

10.4.3.1 Modelado

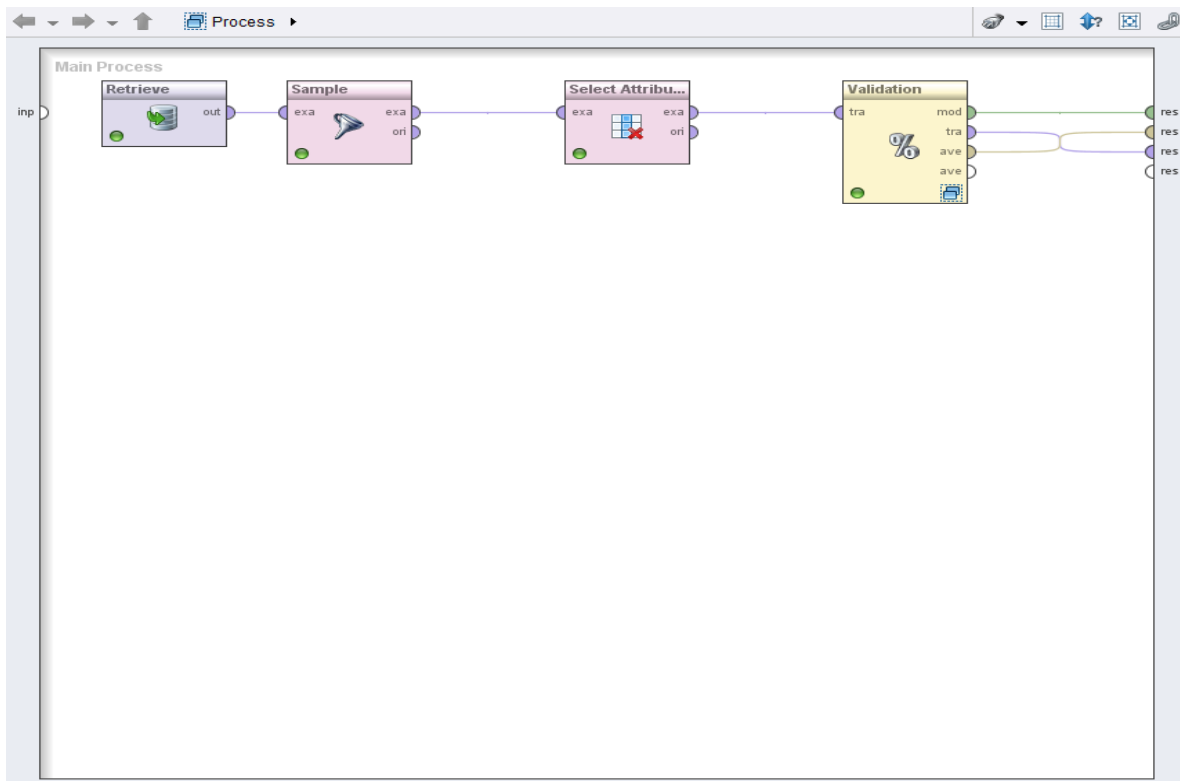


Ilustración 23: Proceso Estudio I (Ataque - Normal)

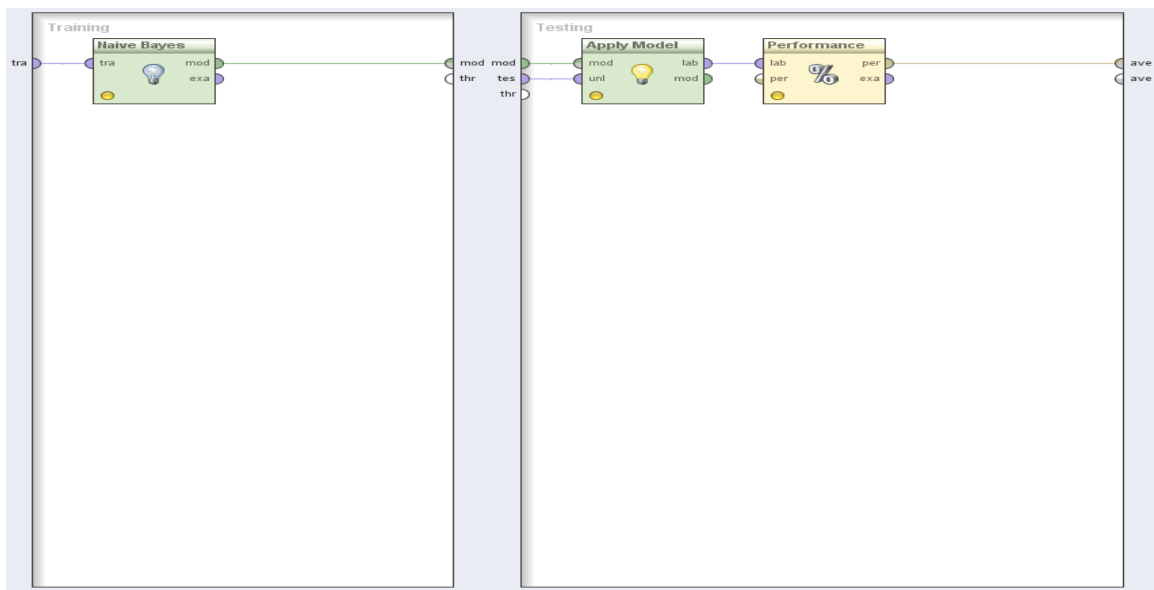


Ilustración 24: Proceso de entrenamiento y prueba Estudio I (Ataque - Normal)

☒ Table View
 ☐ Plot View

accuracy: 92.57% +/- 0.50% (mikro: 92.57%)

	true normal	true ataque	class precision
pred. normal	10476	1319	88.82%
pred. ataque	167	8038	97.96%
class recall	98.43%	85.90%	

Tabla 8: Precisión con Naive Bayes

SimpleDistribution

Distribution model for label attribute Class

Class normal (0.532)

15 distributions

Class ataque (0.468)

15 distributions

Ilustración 25: Distribución Simple Estudio I

10.4.3.2 Análisis

Naive Bayes utiliza un modelo estadístico para realizar el estudio, por lo cual todo el proceso interno que realiza se resume tan solo en la probabilidad de encontrar la clase normal que sería de 0.532 y de encontrar la clase ataque 0.468; lo cual no nos deja mucho para el análisis como se muestra en la ilustración 25.

10.4.4 Random Forest

10.4.4.1 Modelado

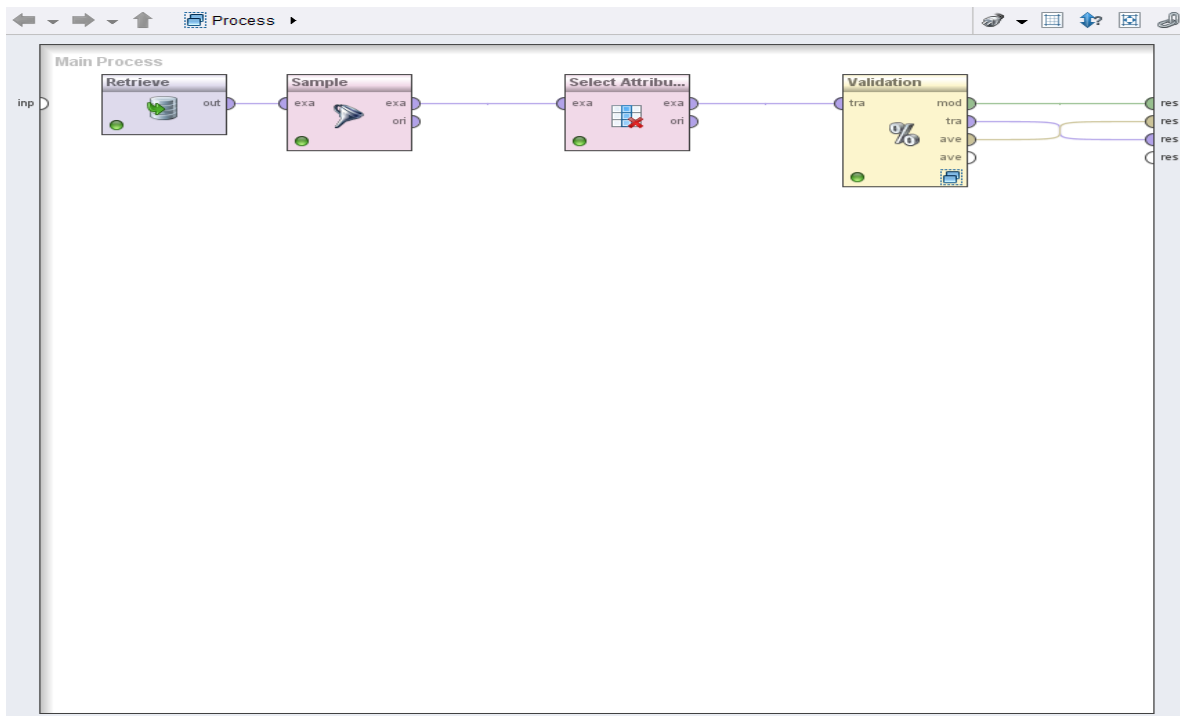


Ilustración 26: Proceso Estudio I (Ataque - Normal)

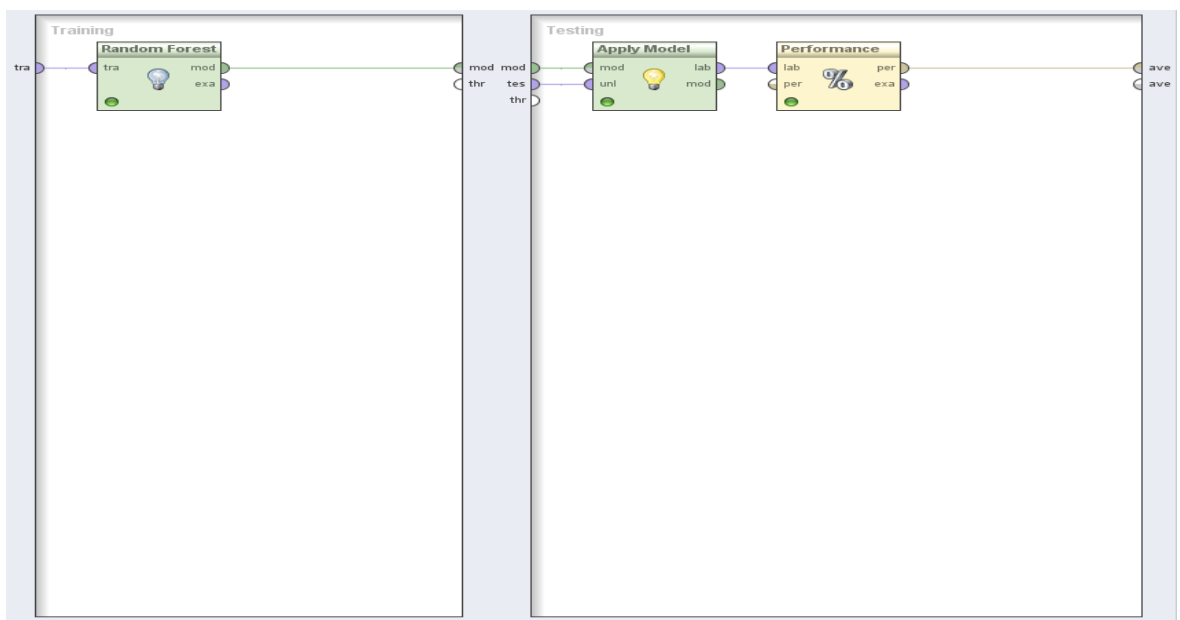


Ilustración 27: Proceso de entrenamiento y prueba Estudio I (Ataque - Normal)

☒ Table View
 ☐ Plot View

accuracy: 91.37% +/- 2.46% (mikro: 91.37%)

	true normal	true ataque	class precision
pred. normal	7869	1194	86.83%
pred. ataque	101	5836	98.30%
class recall	98.73%	83.02%	

Tabla 9: Precisión con Random Forest

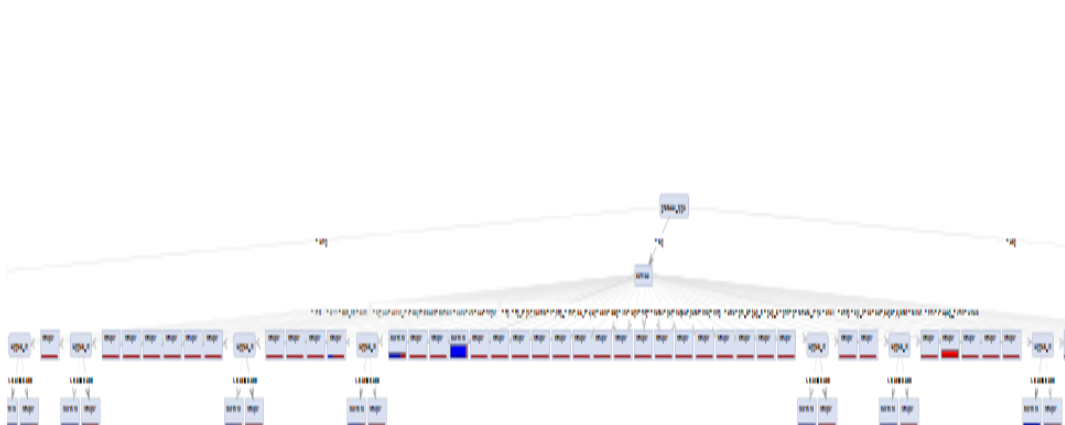


Ilustración 28: Random Forest (Modelo I) Estudio I

10.4.4.2 Análisis

Al realizar el estudio a nivel de 2 categorías (normal o ataque) podemos evidenciar que al tomar una muestra de 20.000 registros para el estudio con el modelo de random forest y luego hacer una selección de las variables para el estudio que se realizó en el punto 10.2 y 10.3, se logra obtener una precisión del modelo de 91.37%; en la ilustración 28 se muestra el árbol generado para el random forest, con los datos del data set y cuál sería la predicción siguiendo el camino de acuerdo a las variables.

De acuerdo a los veinte árboles de decisión generados en rapidminer a partir de los datos del data set, resultados que se muestran en el apartado random forest se puede definir la variable como nuestro nodo principal para poder comenzar la detección de intrusos en una red.

En base al árbol de decisión obtenido, se pudieron identificar de manera general que dependiendo de los valores de las 15 variables escogidas para el desarrollo de esta investigación podemos encontrar varios caminos para poder detectar si es un ataque o no mediante los datos de una conexión.

Una vez analizado el árbol de decisión generado en rapidminer, encontramos que de las 15 variables escogidas del data set, las que nos ayudarían a descubrir si estamos ante una intrusión o no son las siguientes:

- logged_in.- 1 = logeo exitoso, caso contrario = 0
- dst_host_srv_count.- Sumatoria de conexiones al mismo puerto destino.
- dst_host_srv_error_rate.- Porcentaje de conexiones al mismo puerto destino con error de sincronización.
- count.- Número de conexiones del mismo host en la conexión actual
- protocol_type.- El tipo de protocolo por el cual se realiza la conexión.
- Service.- Servicio de red en el destino.
- error_rate.- Porcentaje de conexiones que tienen error de sincronización.
- Flag.- Estado de la conexión (SF, S0, S1, S2, S3, OTH, REJ, RSTO, RSTOSO, SH, RSTRH, SHR)
- same_srv_rate.- Porcentaje de conexiones al mismo servicio.

De esta selección de variables, se identificaron 3 variables las cuales siguen un patrón general que son identificados como ataques según su valor, estos datos los podemos ver en la siguiente tabla:

Variable	Valor	Ataque
Dst_host_srv_serror_rate	1	SI
Service	Smtpt, ftp, ftp_data, http, domain_u, ntp_c, other, urp_i y ecr_i	NO
Flag	REJ, RSTR, S0, RSTO, RSTOS0, SH	SI

En base a la tabla descrita podemos deducir que cuando el porcentaje de conexiones al mismo puerto destino con error de sincronización tiene un valor de 1 se trata de un ataque, para los casos en los cuales se encuentre como servicio usado para la conexión sea diferente a smtp, ftp, ftp_data, http, domain_u, ntp_c, other, urp_i y ecr_i se trata de un ataque que puede ser identificado por medio del servicio de red. Cuando el flag de la cabecera IP tiene los valores REJ, RSTR, S0, RSTO, SH estamos siendo víctimas de un ataque.

Sobre las variables de sumatoria de conexiones al mismo puerto, la del número de conexiones del mismo host en la conexión actual, el logeo exitoso o no y el protocolo que se utiliza; podemos identificar que los valores de estas variables son versátiles. En base a este análisis general se pueden definir reglas específicas las cuales puedan ser implementadas en los sistemas de detección de intrusos.

10.4.5 Red Neuronal

10.4.5.1 Modelado

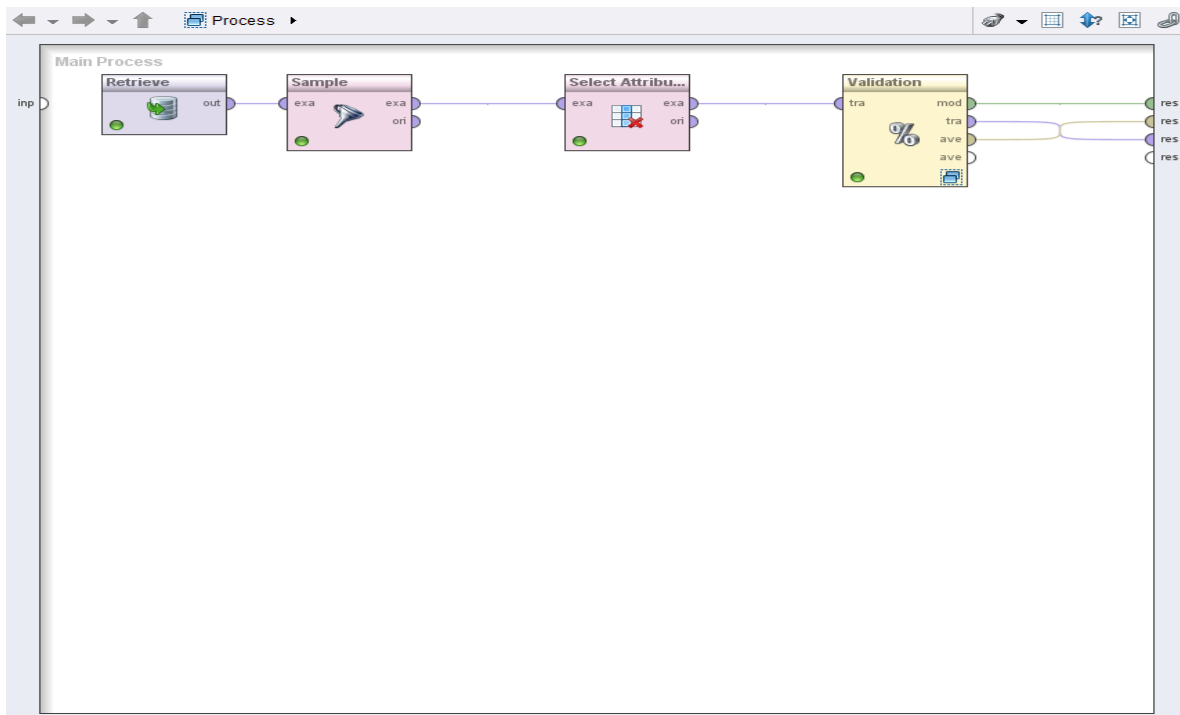


Ilustración 29: Proceso Estudio I (Ataque - Normal)

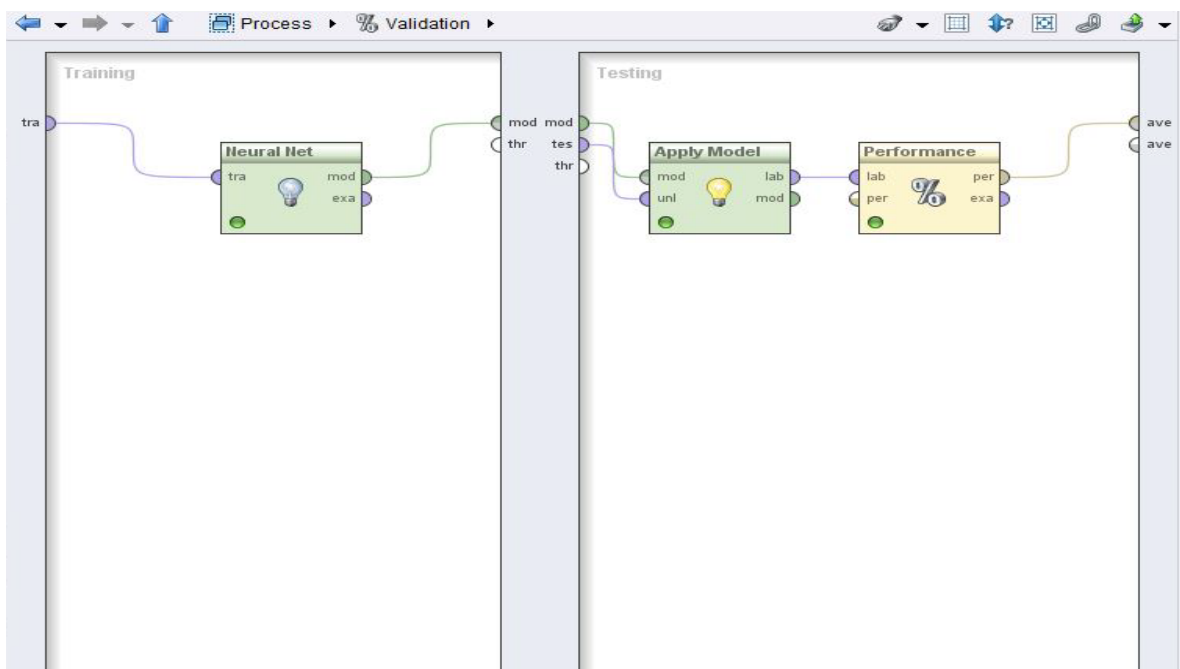


Ilustración 30: Proceso de entrenamiento y prueba Estudio I (Ataque - Normal)

ext View ☐ Annotations

☒ Multiclass Classification Performance ☐ Annotations

☒ Table View ☐ Plot View

accuracy: 97.72% +/- 0.44% (mikro: 97.72%)

	true normal	true ataque	class precision
pred. normal	13316	442	96.79%
pred. ataque	133	11301	98.84%
class recall	99.01%	96.24%	

Tabla 10: Precisión con Red Neuronal

PerformanceVector

PerformanceVector:
 accuracy: 97.72% +/- 0.44% (mikro: 97.72%)
 ConfusionMatrix:
 True: normal ataque
 normal: 13316 442
 ataque: 133 11301
 precision: 98.84% +/- 0.56% (mikro: 98.84%) (positive class: ataque)
 ConfusionMatrix:
 True: normal ataque
 normal: 13316 442
 ataque: 133 11301
 recall: 96.24% +/- 0.82% (mikro: 96.24%) (positive class: ataque)
 ConfusionMatrix:
 True: normal ataque
 normal: 13316 442
 ataque: 133 11301
 AUC (optimistic): 0.991 +/- 0.002 (mikro: 0.991) (positive class: ataque)
 AUC: 0.991 +/- 0.002 (mikro: 0.991) (positive class: ataque)
 AUC (pessimistic): 0.991 +/- 0.002 (mikro: 0.991) (positive class: ataque)

Ilustración 31: Red Neuronal (Modelo I) Estudio I

10.4.5.2 Análisis

Al realizar el estudio a nivel de 2 categorías (normal o ataque) podemos evidenciar que al tomar una muestra de 20.000 registros para el estudio con el modelo de redes neuronales y luego hacer una selección de las variables para el estudio que se realizó en el punto 10.2 y 10.3, se logra obtener una precisión del modelo de 97.72%; en la ilustración 31 se muestra el resultado de la red neuronal, con los datos del data set y cuál sería la predicción siguiendo el camino de acuerdo a las variables.

10.5 Segundo Estudio Experimental a nivel de 5 categorías

El segundo estudio experimental abordará el data set desde la perspectiva del uso y agrupación de los ataques en cinco categorías, procedimiento que se explicó en el apartado diseño del proyecto.

10.5.1 Preparación de datos

Para lograr este objetivo primeramente se realizó una categorización en cinco categorías (normal, DOS, PROBE, R2L, U2R), dentro del cual se tiene los registros de cada una de las categorías en la cual se maneja este segundo estudio.

NORMAL	10643
DOS	7334
PROBE	1842
R2L	172
U2R	9

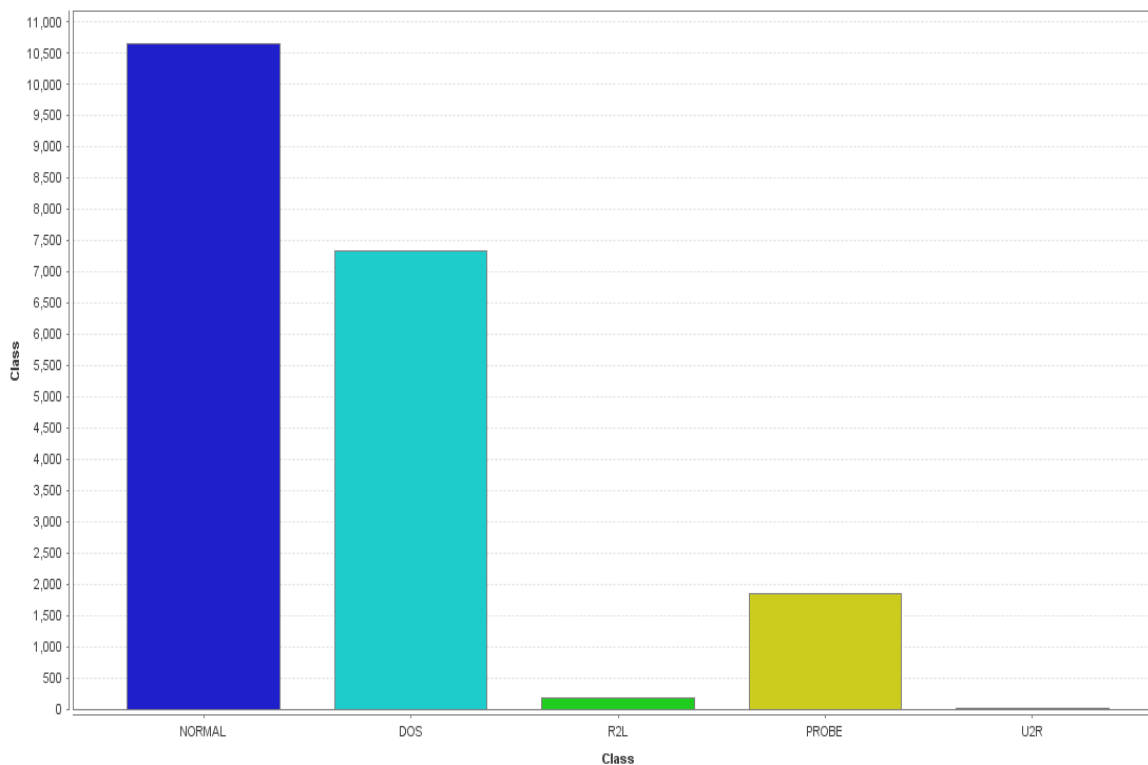


Ilustración 32: Gráfico de la distribución de registros de la muestra

10.5.2 Árbol de decisión

10.5.2.1 Modelado

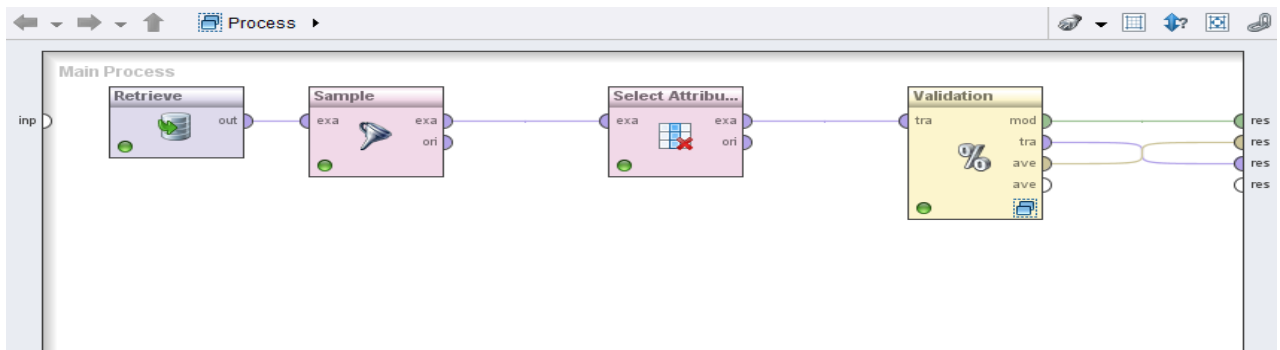


Ilustración 33: Proceso Estudio II

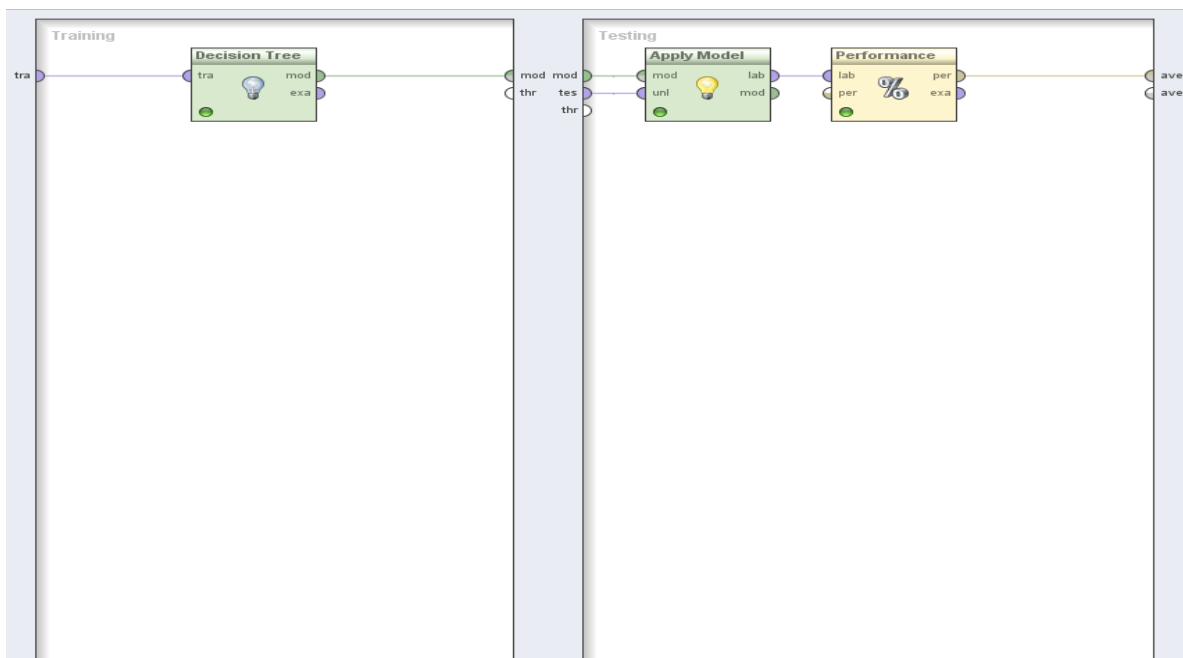


Ilustración 34: Proceso de entrenamiento y prueba Estudio II

accuracy: 88.04% +/- 0.37% (mikro: 88.04%)						
	true NORMAL	true DOS	true R2L	true PROBE	true U2R	class precision
pred. NORMAL	10595	646	154	1426	9	82.58%
pred. DOS	40	6616	0	36	0	98.86%
pred. R2L	4	0	18	0	0	81.82%
pred. PROBE	4	72	0	380	0	83.33%
pred. U2R	0	0	0	0	0	0.00%
class recall	99.55%	90.21%	10.47%	20.63%	0.00%	

Tabla 11: Precisión con Árbol de decisión

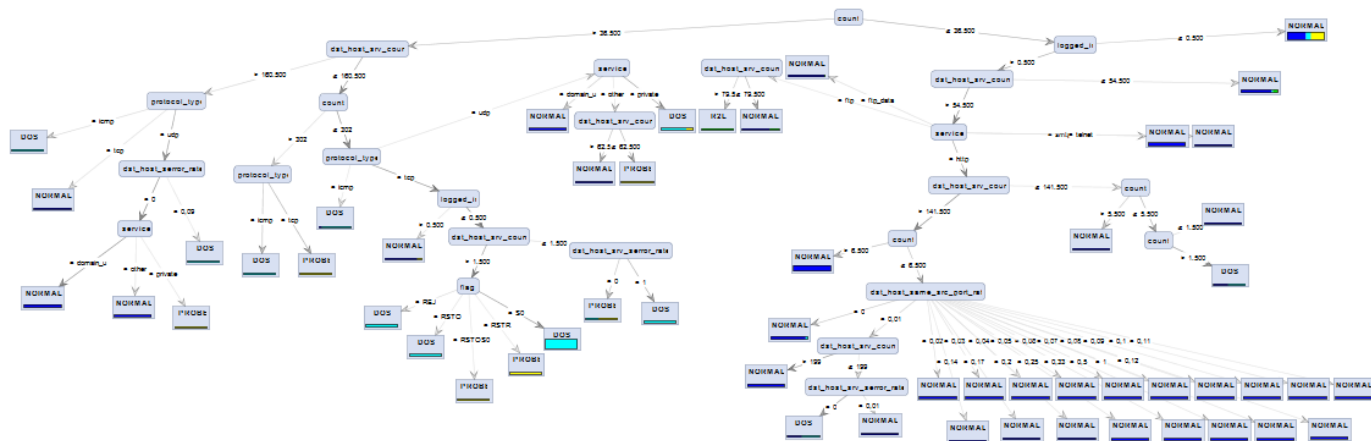


Ilustración 35: Árbol de decisión Estudio II

10.5.2.2 Análisis

El estudio 2 se basa en el manejo de 5 tipos de categorías, de las cuales 4 son consideradas ataques y solamente una no se considera como ataque. Estas 5 variables son:

- Normal.- No es ataque.
- DOS.- Denegación de servicio.
- PROBE.- Indagación y exploración a la red.
- R2L.- Acceso remoto local.
- U2R.- Acceso con usuario root.

Podemos evidenciar que al tomar una muestra de 20.000 registros para el estudio con el modelo de árboles de decisión y luego hacer una selección de las variables

para el estudio que se realizó en el punto 10.2 y 10.3, se logra obtener una precisión del modelo de 88.04%; en la ilustración 35 se muestra el árbol generado con los datos del data set y cuál sería la predicción siguiendo el camino de acuerdo a las variables categorizadas.

Una vez analizado el árbol de decisión generado en rapidminer, encontramos que de las 15 variables escogidas del data set, las que nos ayudarían a descubrir si estamos ante una intrusión y el tipo de intrusión o no son las siguientes:

- dst_host_srv_count.- Sumatoria de conexiones al mismo puerto destino.
- count.- Número de conexiones del mismo host en la conexión actual
- protocol_type.- El tipo de protocolo por el cual se realiza la conexión.
- Service.- Servicio de red en el destino.
- dst_host_serror_rate.- Porcentaje de conexiones que activaron el flag (s0, s1, s2, s3).
- dst_host_same_src_port_rate.- Porcentaje de conexiones desde el mismo puerto origen.
- Flag.- Estado de la conexión (SF, S0, S1, S2, S3, OTH, REJ, RSTO, RSTOSO, SH, RSTRH, SHR).

Una vez realizado el análisis se pudo determinar que de las 4 categorías de ataques, solamente 2 son relevantes DOS y PROBE, existe un mínimo de relevancia en cuanto al ataque R2L.

- Entre los casos que se identificaron para el tipo de ataque DOS se dan en base al siguiente criterio:

En la categoría de ataque DOS se pudo evidenciar que este tipo de ataque de manera general se da en los casos en los cuales el tipo de protocolo es ICMP.

Para los casos más específicos se pudo evidenciar que cuando la suma de conexiones a la misma dirección IP destino es mayor a 36.5, la suma de conexiones al mismo puerto destino es mayor a 160.5 el valor relevante que

identifica es el tipo de protocolo que se maneja, en este caso si el protocolo es ICM se considera un ataque. También se concediera un ataque si el tipo de protocolo es UDP y adicionalmente el porcentaje de conexiones que activaron el estado de la conexión a: S0, S1, S2, S3, adicionalmente en los casos en los cuales el tipo de protocolo es UDP y el servicio es PRIVATE también es considerado como ataque.

En los casos en que la suma de conexiones al mismo puerto destino sea menor o igual a 16.5, y no exista éxito en la conexión y el estado de la conexión este entre: S0, REJ, RSTO, se considera un ataque.

- Entre los casos que se identificaron para el tipo de ataque PROBE se dan en base al siguiente criterio:

Cuando la suma de conexiones a la misma dirección IP destino es mayor a 36.5, la suma de conexiones al mismo puerto destino es mayor a 160.5 el valor relevante que identifica es el tipo de protocolo que se maneja, en este caso si el protocolo es UDP y el tipo de servicio es PRIVATE se considera un ataque.

Si la suma de conexiones al mismo puerto destino es menor o igual 160.5, la suma de conexiones a la misma IP destino es mayor a 302 y el tipo de protocolo es TCP se considera como ataque. En el caso en que la suma de conexiones a la misma IP destino es menor o igual a 302, el tipo de protocolo es TCP, que no exista éxito en el loggeo y el estado sea: RST0S0 y RSTR también es considerado como ataque.

- Entre los casos que se identificaron para el tipo de ataque R2L se dan en base al siguiente criterio:

Cuando la suma de conexiones a la misma dirección IP destino es menor o igual a 36.5, exista una conexión de éxito, el servicio sea de tipo FTP y la

suma de conexiones al mismo puerto destino sea mayor a 79.5 se considera como ataque.

En base al análisis de los criterios que generan los errores anteriormente explicados se muestra un resumen en la siguiente tabla:

Tipo Ataque	Descripción	Resumen
DOS	Denegación de servicio.	Al ser el ataque una denegación de servicio este se da en los casos en los cuales el tipo de protocolo es ICMP, dicho protocolo se utiliza para el envío de mensajes de error en caso de que un servicio determinado no esté disponible y al tener una cantidad considerable de conexiones al mismo puerto y dirección IP destino, se considera como ataque.
PROBE	Indagación y exploración de la red	Al ser un tipo de ataque de indagación y exploración a la red, donde la cantidad de conexión considerable a la dirección IP destino mediante el protocolo UDP, donde este protocolo permite envío de datagramas a través de la red sin que existe una conexión previa, como el datagrama contiene la información necesaria de direccionamiento en su cabecera, y al ser un tipo de servicio privado se considera como ataque. También se considera ataque en los cuales el protocolo utilizado es TCP, el cual se utiliza para la transición de información por internet y donde no exista éxito en el loggeo y el estado de la conexión no sea normal, estos síntomas indican que también es un ataque por otro protocolo.
R2L	Remote to local	Cuan existe una conexión de éxito, y el tipo de servicio es FTP, se pueden manipular remotamente la maquina local, al ser un servicio FTP el cual permite la conexión cliente servidor donde los archivos y los datos de loggeo

		no son encriptados por este protocolo, se considera un ataque.
--	--	--

10.5.3 Naive Bayes

10.5.3.1 Modelado

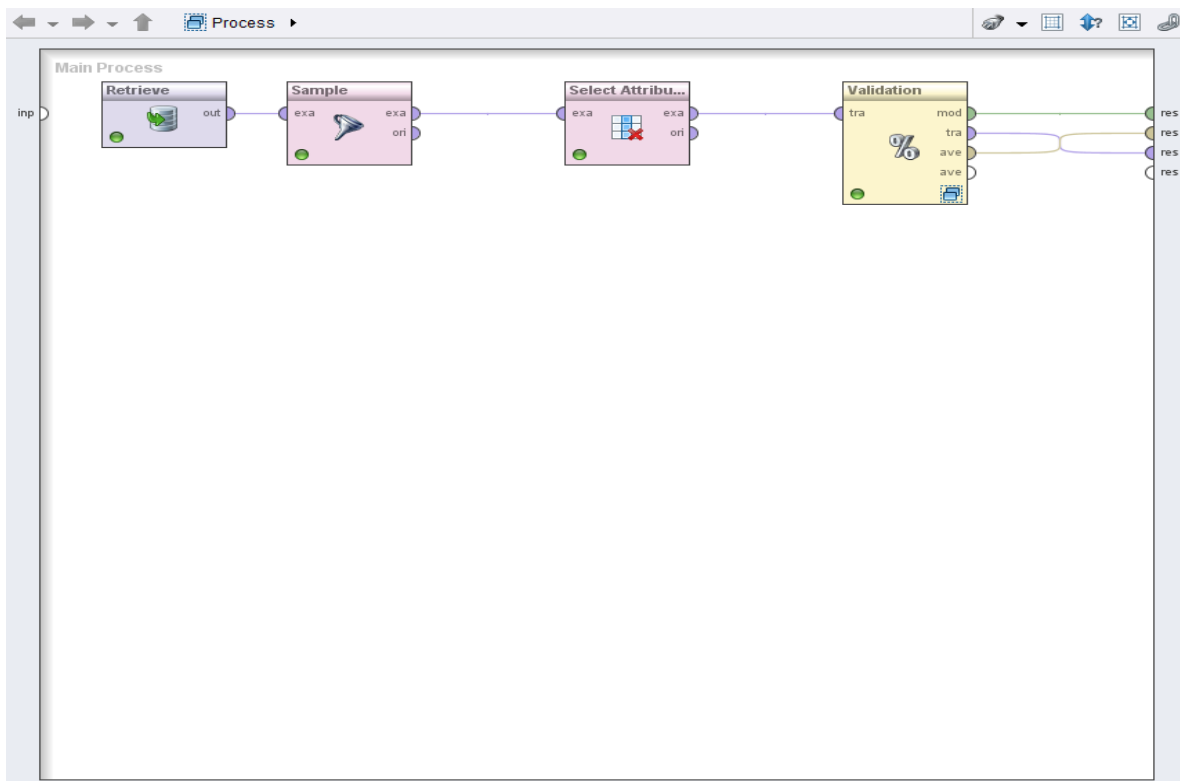


Ilustración 36: Proceso Estudio II (Cinco categorías)

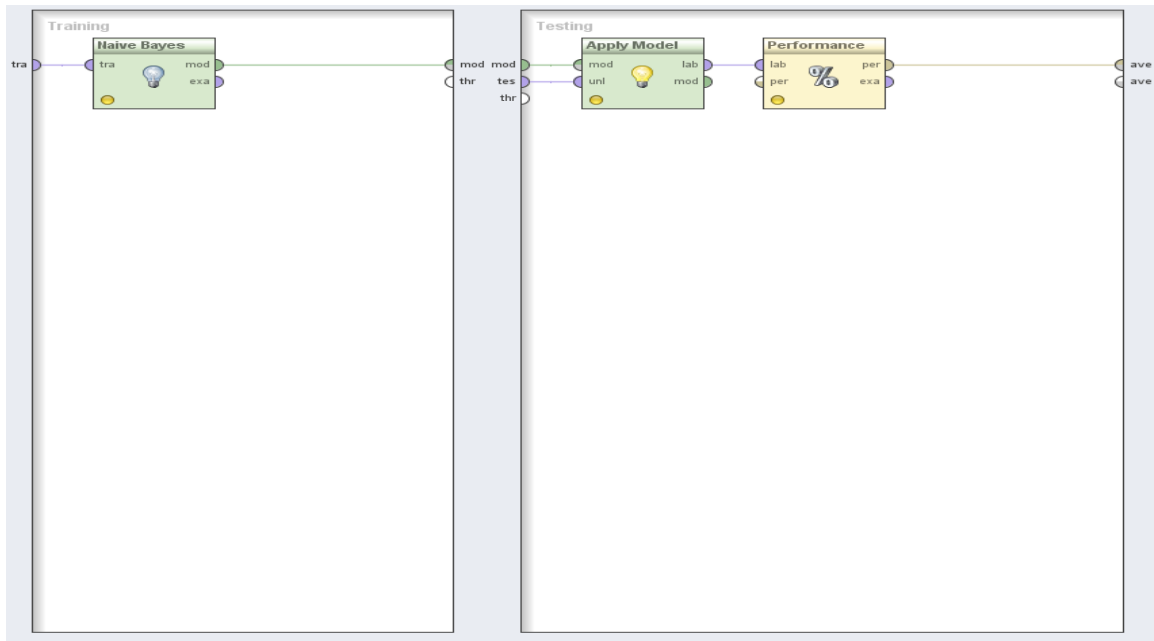


Ilustración 37: Proceso de entrenamiento y prueba Estudio II (Cinco categorías)

Table View PlotView

accuracy: 91.52% +/- 0.56% (mikro: 91.52%)

	true NORMAL	true DOS	true R2L	true PROBE	true U2R	class precision
pred. NORMAL	9875	295	38	56	1	96.20%
pred. DOS	17	6601	0	18	0	99.47%
pred. R2L	144	1	57	1	3	27.67%
pred. PROBE	554	437	3	1767	0	64.00%
pred. U2R	53	0	74	0	5	3.79%
class recall	92.78%	90.01%	33.14%	95.93%	55.56%	

Tabla 12: Precisión con Naive Bayes

SimpleDistribution

Distribution model for label attribute Class

Class NORMAL (0.532)
15 distributions

Class DOS (0.367)
15 distributions

Class R2L (0.009)
15 distributions

Class PROBE (0.092)
15 distributions

Class U2R (0.000)
15 distributions

Ilustración 38: Distribución Simple Estudio II

10.5.3.2 Análisis

Naive Bayes utiliza un modelo estadístico para realizar el estudio, por lo cual todo el proceso interno que realiza se resume tan solo en la probabilidad de encontrar la clase normal que sería de 0.532, clase DOS 0.367, clase R2L 0.009, clase PROBE 0.092 y U2R 0; lo cual no nos deja mucho para el análisis como se muestra en la ilustración 38.

10.5.4 Random Forest

10.5.4.1 Modelado

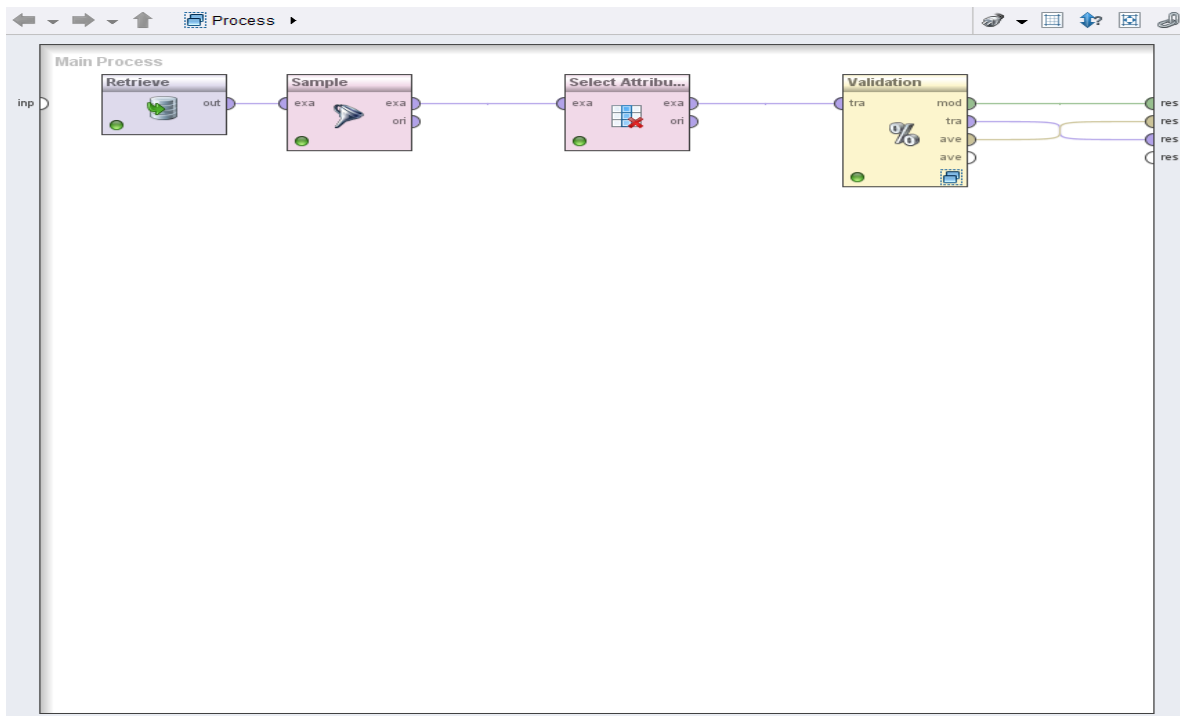


Ilustración 39: Proceso Estudio II (Cinco Categorías)

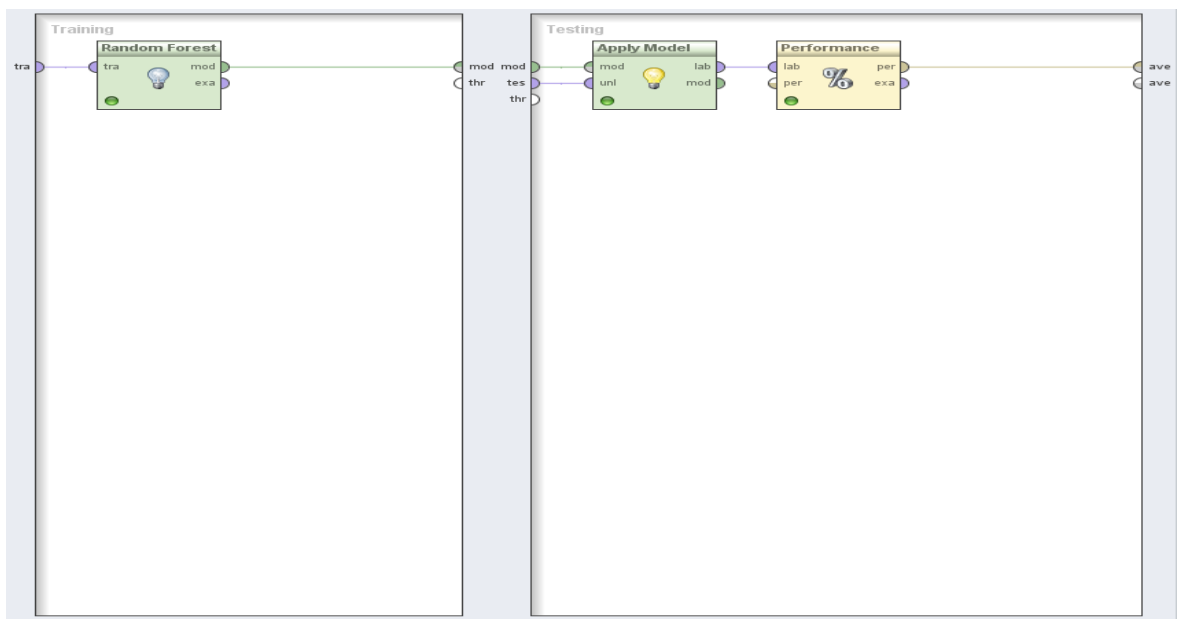


Ilustración 40: Proceso de entrenamiento y prueba Estudio II (Cinco Categorías)

Table View Plot View

accuracy: 78.90% +/- 12.40% (mikro: 78.90%)

	true NORMAL	true DOS	true R2L	true PROBE	true U2R	class precision
pred. NORMAL	7942	1851	135	934	6	73.08%
pred. DOS	19	3635	0	187	0	94.64%
pred. R2L	0	0	0	0	0	0.00%
pred. PROBE	9	24	0	258	0	88.66%
pred. U2R	0	0	0	0	0	0.00%
class recall	99.65%	65.97%	0.00%	18.71%	0.00%	

Tabla 13: Precisión con Random Forest

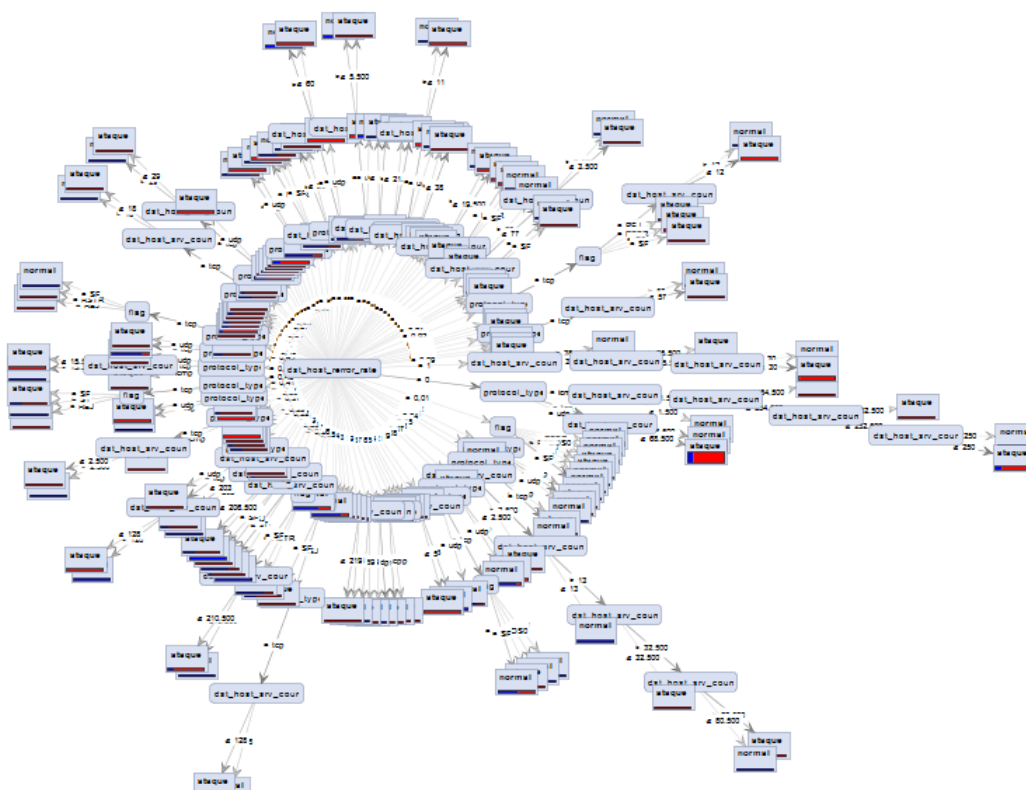


Ilustración 41: Random Forest (Modelo II) Estudio II

10.5.4.2 Análisis

Podemos evidenciar que al tomar una muestra de 15.000 registros para el estudio con el modelo de random forest y luego hacer una selección de las variables para el estudio que se realizó en el punto 10.2 y 10.3, se logra obtener una precisión del

modelo de 78.20%; en la ilustración 41 se muestra el árbol generado con los datos del data set y cuál sería la predicción siguiendo el camino de acuerdo a las variables categorizadas.

Una vez analizado el árbol de decisión generado en rapidminer, encontramos que de las 15 variables escogidas del data set, las que nos ayudarían a descubrir si estamos ante una intrusión y el tipo de intrusión o no son las siguientes:

- dst_host_srv_count.- Sumatoria de conexiones al mismo puerto destino.
- count.- Número de conexiones del mismo host en la conexión actual
- protocol_type.- El tipo de protocolo por el cual se realiza la conexión.
- Service.- Servicio de red en el destino.
- dst_host_serror_rate.- Porcentaje de conexiones que activaron el flag (s0, s1, s2, s3).
- dst_host_same_src_port_rate.- Porcentaje de conexiones desde el mismo puerto origen.
- Flag.- Estado de la conexión (SF, S0, S1, S2, S3, OTH, REJ, RSTO, RSTOSO, SH, RSTRH, SHR).

Una vez realizado el análisis se pudo determinar que de las 4 categorías de ataques, solamente 2 son relevantes DOS y PROBE, existe un mínimo de relevancia en cuanto al ataque R2L.

- Entre los casos que se identificaron para el tipo de ataque DOS se dan en base al siguiente criterio:

En la categoría de ataque DOS se pudo evidenciar que este tipo de ataque de manera general se da en los casos en los cuales el tipo de protocolo es ICMP.

Para los casos más específicos se pudo evidenciar que cuando la suma de conexiones a la misma dirección IP destino es mayor a 36.5, la suma de conexiones al mismo puerto destino es mayor a 160.5 el valor relevante que identifica es el tipo de protocolo que se maneja, en este caso si el protocolo es ICMP se considera un

ataque. También se concediera un ataque si el tipo de protocolo es UDP y adicionalmente el porcentaje de conexiones que activaron el estado de la conexión a: S0, S1, S2, S3, adicionalmente en los casos en los cuales el tipo de protocolo es UDP y el servicio es PRIVATE también es considerado como ataque.

En los casos en que la suma de conexiones al mismo puerto destino sea menor o igual a 16.5, y no exista éxito en la conexión y el estado de la conexión este entre: S0, REJ, RSTO, se considera un ataque.

- Entre los casos que se identificaron para el tipo de ataque PROBE se dan en base al siguiente criterio:

Cuando la suma de conexiones a la misma dirección IP destino es mayor a 36.5, la suma de conexiones al mismo puerto destino es mayor a 160.5 el valor relevante que identifica es el tipo de protocolo que se maneja, en este caso si el protocolo es UDP y el tipo de servicio es PRIVATE se considera un ataque.

Si la suma de conexiones al mismo puerto destino es menor o igual 160.5, la suma de conexiones a la misma IP destino es mayor a 302 y el tipo de protocolo es TCP se considera como ataque. En el caso en que la suma de conexiones a la misma IP destino es menor o igual a 302, el tipo de protocolo es TCP, que no exista éxito en el loggeo y el estado sea: RST0S0 y RSTR también es considerado como ataque.

- Entre los casos que se identificaron para el tipo de ataque R2L se dan en base al siguiente criterio:

Cuando la suma de conexiones a la misma dirección IP destino es menor o igual a 36.5, exista una conexión de éxito, el servicio sea de tipo FTP y la suma de conexiones al mismo puerto destino sea mayor a 79.5 se considera como ataque.

En base al análisis de los criterios que generan los errores anteriormente explicados se muestra un resumen en la siguiente tabla:

Tipo Ataque	Descripción	Resumen
DOS	Denegación de servicio.	Al ser el ataque una denegación de servicio este se da en los casos en los cuales el tipo de protocolo es ICMP, dicho protocolo se utiliza para el envío de mensajes de error en caso de que un servicio determinado no esté disponible y al tener una cantidad considerable de conexiones al mismo puerto y dirección IP destino, se considera como ataque.
PROBE	Indagación y exploración de la red	Al ser un tipo de ataque de indagación y exploración a la red, donde la cantidad de conexión considerable a la dirección IP destino mediante el protocolo UDP, donde este protocolo permite envío de datagramas a través de la red sin que existe una conexión previa, como el datagrama contiene la información necesaria de direccionamiento en su cabecera, y al ser un tipo de servicio privado se considera como ataque. También se considera ataque en los cuales el protocolo utilizado es TCP, el cual se utiliza para la transición de información por internet y donde no exista éxito en el loggeo y el estado de la conexión no sea normal, estos síntomas indican que también es un ataque por otro protocolo.
R2L	Remote to local	Cuan existe una conexión de éxito, y el tipo de servicio es FTP, se pueden manipular remotamente la maquina local, al ser un servicio FTP el cual permite la conexión cliente servidor donde los archivos y los datos de loggeo no son encriptados por este protocolo, se considera un ataque.

10.6 Tercer Estudio Experimental a nivel de ataque

Para el tercer estudio a realizar, se manejarán todos los tipos de ataque que se encuentran en el data set, todos los ataques serán analizados en base a los resultados que se obtengan en el rapidminer para los 3 procesos que se corran.

10.6.1 Preparación de datos

Para lograr este objetivo, en el cual se tiene los registros de cada uno de los ataques en la cual se maneja este tercer estudio.

Normal	10643
neptune	6568
ipsweep	570
Satan	554
portsweep	484
Smurf	422
Nmap	234
Back	157
teardrop	155
warezclient	145
Pod	31
guess_passwd	9
warezmaster	7
buffer_overflow	5
Imap	5
Rootkit	3
multihop	2
Phf	2
ftp_write	1
Land	1
loadmodule	1
Spy	1

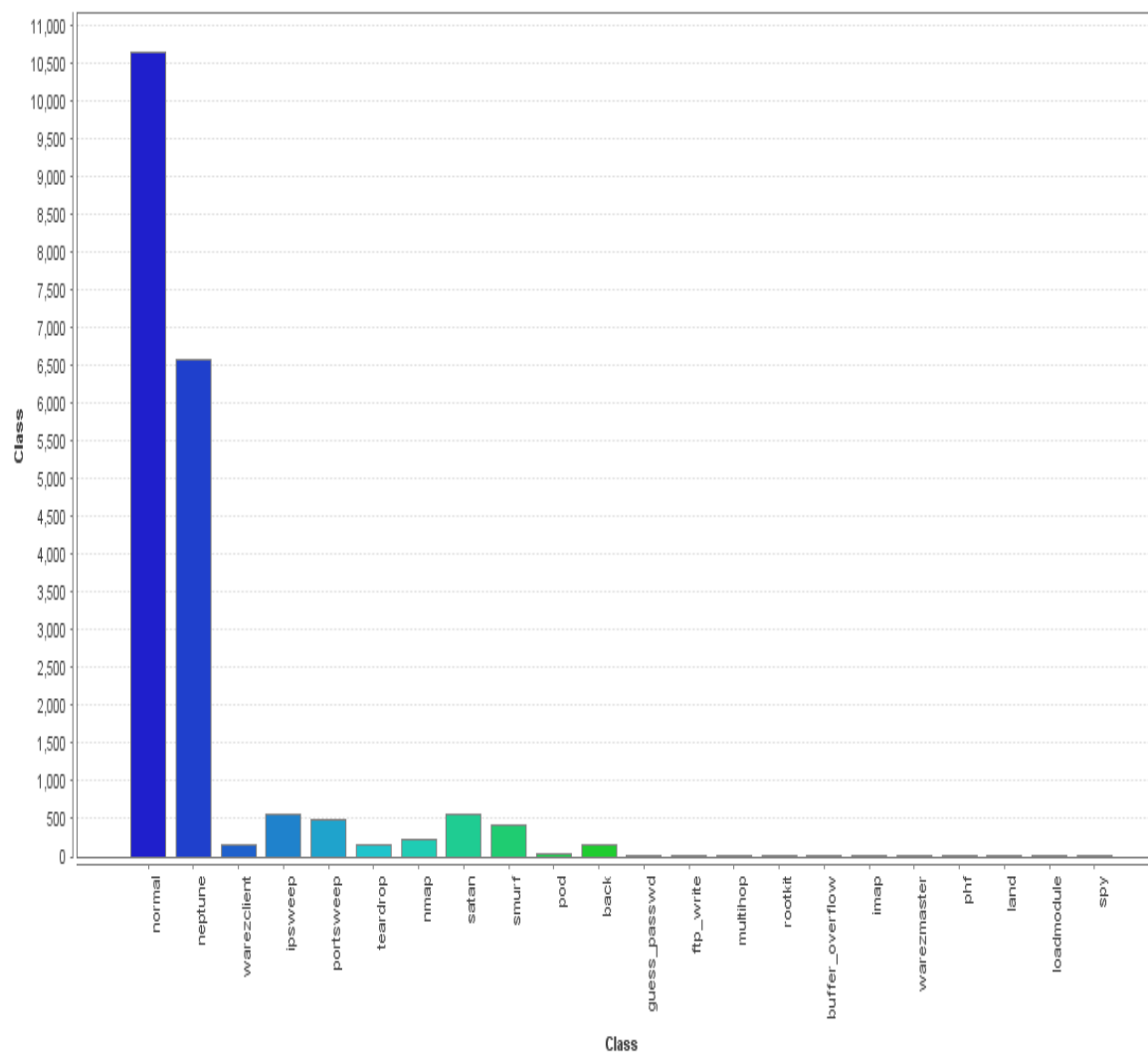


Ilustración 42: Gráfico de la distribución de registros de la muestra

10.6.2 Árbol de decisión

10.6.2.1 Modelado

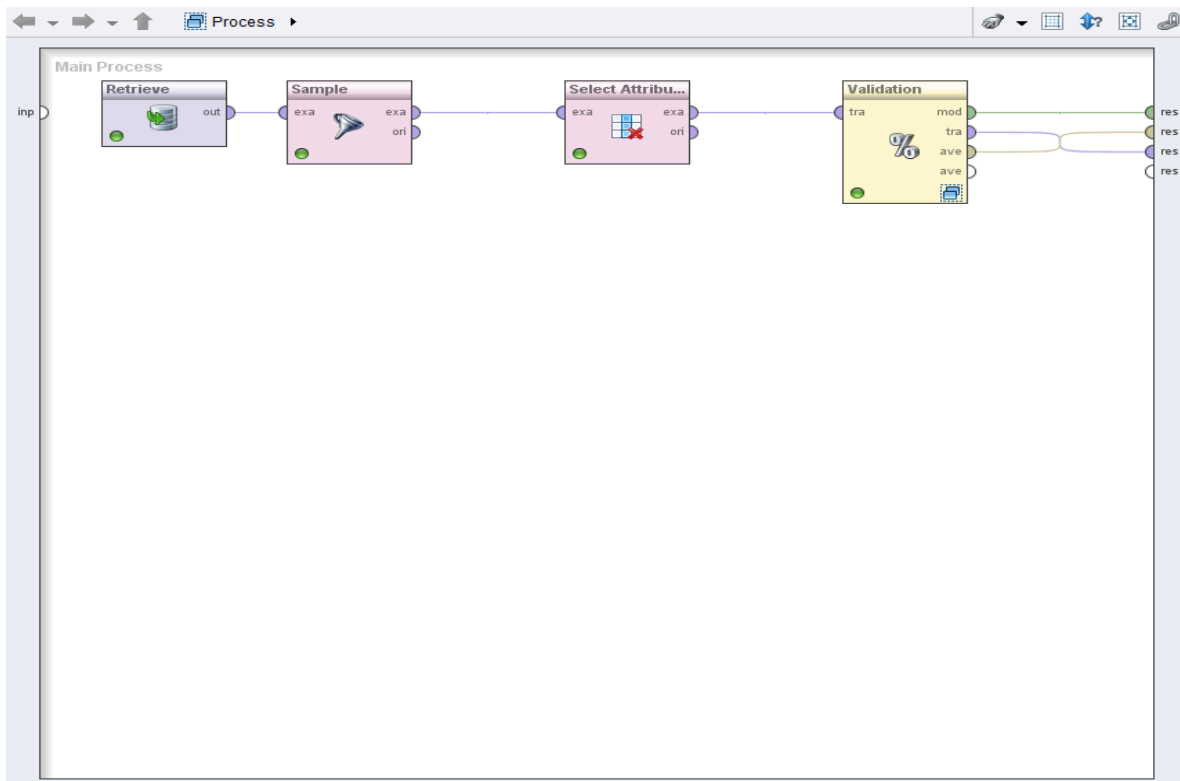


Ilustración 43: Proceso Estudio III (Ataques)

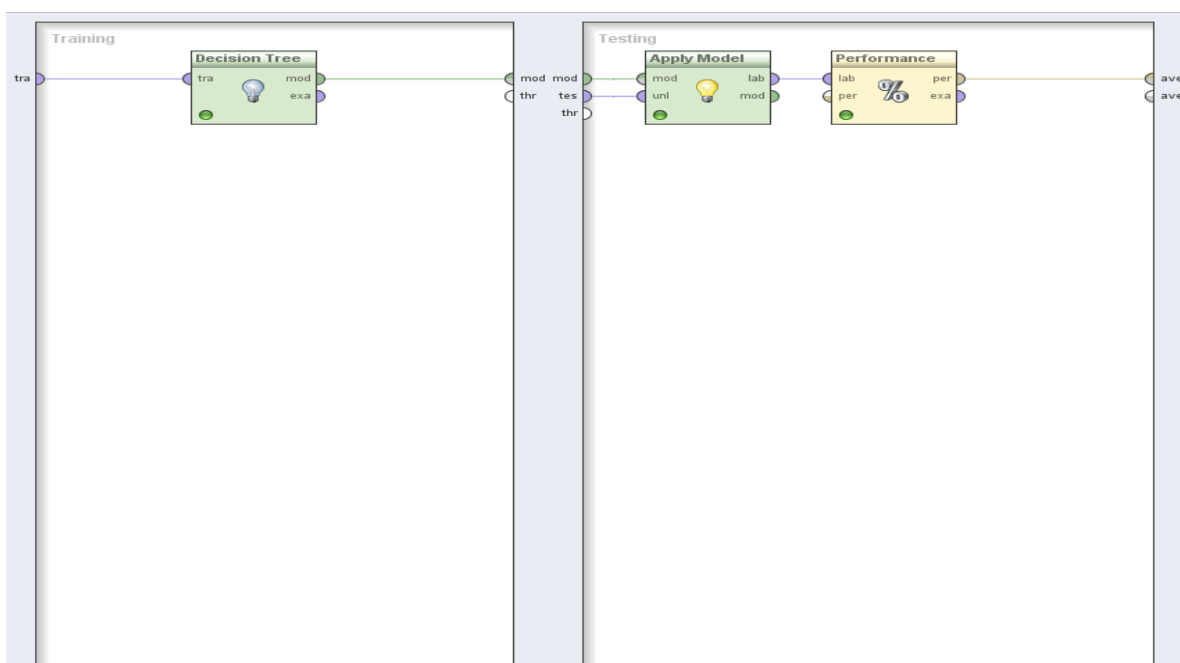


Ilustración 44: Proceso de entrenamiento y prueba Estudio III (Ataques)

accuracy: 94.84% +/- 0.45% (mikro: 94.84%)														
	true normal	true neptune	true warezcli	true ipsweeper	true portsw	true teardro	true nmap	true satan	true smurf	true pod	true back	true guess_	true ftp_write	true m
pred. norma	10527	26	142	19	3	4	34	36	7	26	146	7	1	2
pred. neptun	18	6509	0	0	17	0	0	64	0	0	0	0	0	0
pred. warezc	0	0	3	0	0	0	0	0	0	0	0	0	0	0
pred. ipswee	52	0	0	522	10	0	153	4	1	5	0	0	0	0
pred. portsw	19	3	0	29	429	0	6	4	0	0	0	0	0	0
pred. teardr	0	0	0	0	0	116	0	47	0	0	0	0	0	0
pred. nmap	0	0	0	0	0	0	35	0	0	0	0	0	0	0
pred. satan	16	30	0	0	24	35	6	399	0	0	0	0	0	0
pred. smurf	9	0	0	0	0	0	0	0	414	0	0	0	0	0
pred. pod	0	0	0	0	0	0	0	0	0	0	0	0	0	0
pred. back	0	0	0	0	1	0	0	0	0	0	11	0	0	0
pred. guess_	2	0	0	0	0	0	0	0	0	0	0	2	0	0
pred. ftp_wri	0	0	0	0	0	0	0	0	0	0	0	0	0	0
pred. multih	0	0	0	0	0	0	0	0	0	0	0	0	0	0
pred. rootkit	0	0	0	0	0	0	0	0	0	0	0	0	0	0
pred. buffer_	0	0	0	0	0	0	0	0	0	0	0	0	0	0
pred. imap	0	0	0	0	0	0	0	0	0	0	0	0	0	0
pred. warezr	0	0	0	0	0	0	0	0	0	0	0	0	0	0
pred. phf	0	0	0	0	0	0	0	0	0	0	0	0	0	0
pred. land	0	0	0	0	0	0	0	0	0	0	0	0	0	0

Tabla 14: Precisión con Árbol de decisión

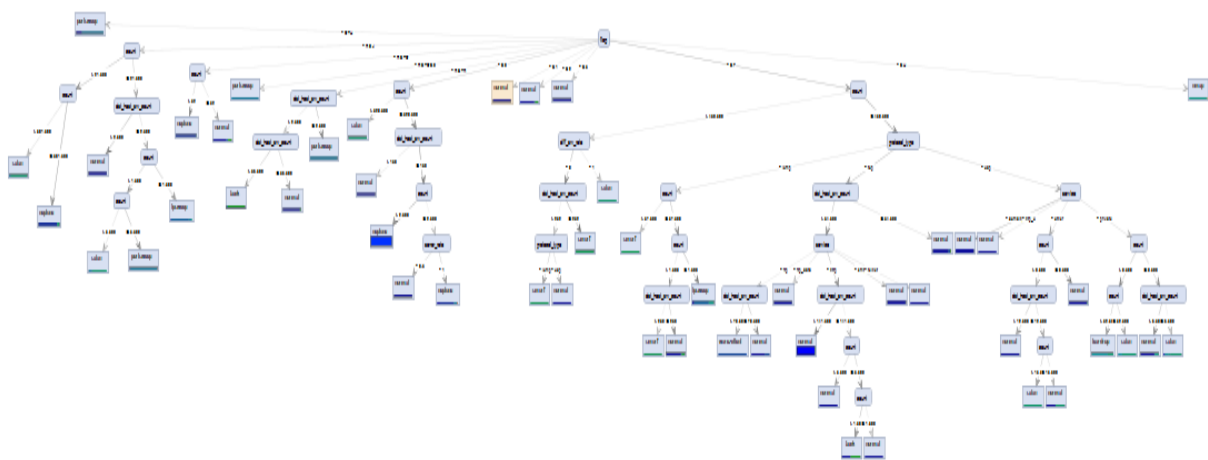


Ilustración 45: Árbol de decisión Estudio III

10.6.2.2 Análisis

Al realizar el estudio a nivel de todos los tipos de ataques podemos evidenciar que al tomar una muestra de 20.000 registros para el estudio con el modelo de árboles de decisión y luego hacer una selección de las variables para el estudio que se realizó en el punto 10.2 y 10.3, se logra obtener una precisión del modelo de 94.84%; en la ilustración 45 se muestra el árbol generado con los datos del data set y cuál sería la predicción siguiendo el camino de acuerdo a las variables.

De acuerdo al árbol de decisión generado en rapidminer a partir de los datos del data set, resultados que se muestran en el apartado árbol de decisión se puede definir la variable FLAG como nuestro nodo principal para poder comenzar la detección de intrusos en una red. También se identificó que cuando los estados de conexión se encuentran entre: S1, S2 y S3 no existe riesgos de ataques.

Se pudo analizar los ataques en base al siguiente criterio:

Estado de la conexión OCH, se identifica el tipo de ataque PORTSWEEP el cual pertenece a la categoría DOS denegación de servicio. Cuando el estado de la conexión es REJ y el número de conexiones al mismo host es elevado se identificaron los ataques SATAN que pertenece a la categoría PROBE indagación y exploración de la red, y los ataques NEPTUNE y PORTSWEEP los cuales pertenecen a la categoría DOS denegación de servicio, vemos que ambos ataques tienen directamente conexión con la red de comunicación.

También se identificaron los ataques TEARDROP que pertenece a la categoría denegación de servicio y el ataque SATAN que pertenece a la categoría exploración de red, estos casos se identificaron cuando el servicio por el cual intentan realizar la conexión es de tipo privado y el tipo de protocolo es UDP el cual permite envío de datagramas a través de la red sin que existe una conexión previa, en estos casos es considerado con esos tipos de ataques.

En el caso donde el tipo de protocolo es TCP se identificó el ataque BACK el cual pertenece a la categoría DOS denegación de servicio, ya que este protocolo se utiliza para la transmisión de datos por internet.

Cuando el tipo de protocolo es ICMP el cual se utiliza para el envío de mensajes de error, se identificaron los tipos de error SMURF el cual pertenece a la categoría de error DOS denegación de servicio y el ataque IPSWEEP el cual pertenece a la categoría PROBE indagación y exploración de red.

También se considera el ataque WAREZCLIENT el cual pertenece al tipo de ataque R2L remoto a local en los casos donde el tipo de servicio es FTP donde este servicio permite compartir archivos desde un repositorio.

10.6.3 Naive Bayes

10.6.3.1 Modelado

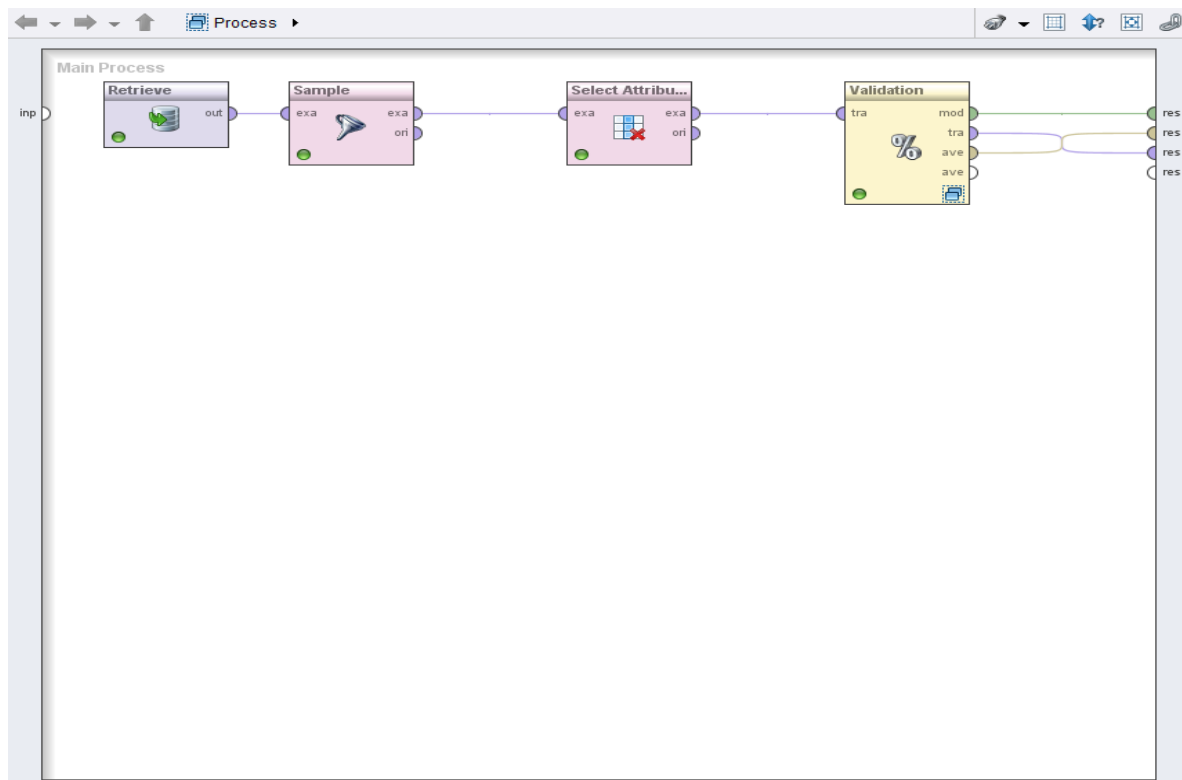


Ilustración 46: Proceso Estudio I (Ataque - Normal)

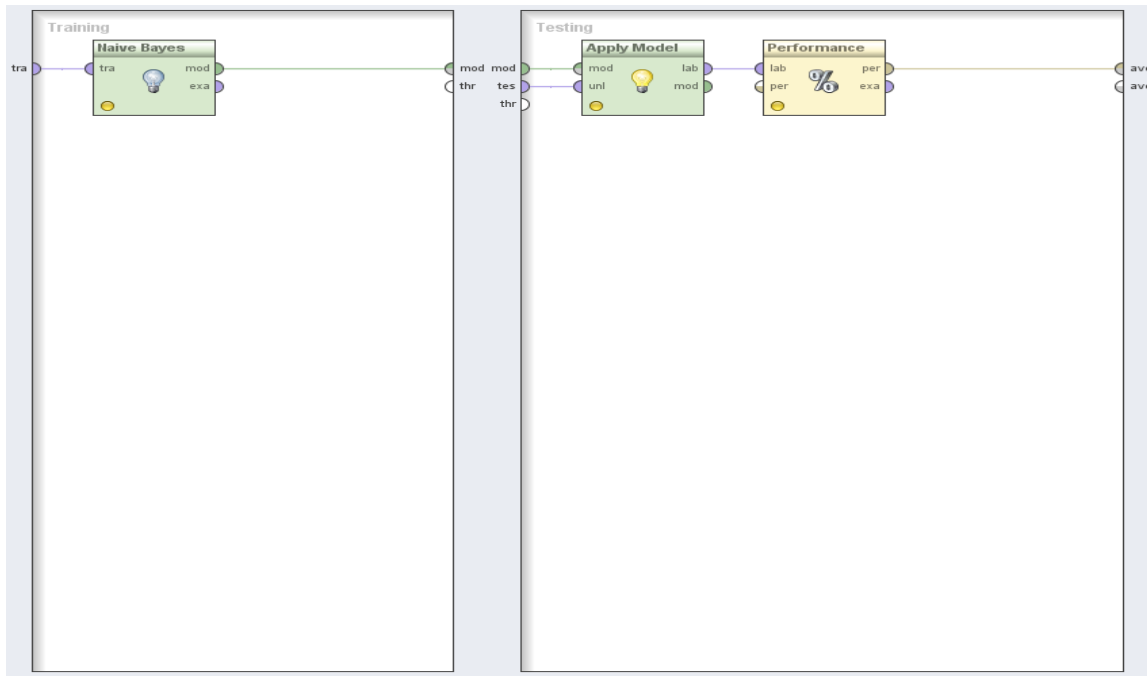


Ilustración 47: Proceso de entrenamiento y prueba Estudio III (Ataques)

Table View Plot View

accuracy: 80.40% +/- 0.42% (mikro: 80.40%)

	true normal	true neptune	true warezdi	true ipswee	true portsw	true teardro	true nmap	true satan	true smurf	true pod	true back	true guess_	true ftp_wri	true multih	tr
pred. norma	7443	28	13	3	2	16	4	44	4	1	7	5	0	0	0
pred. neptun	2	6538	0	0	0	0	0	1	0	0	0	0	0	0	0
pred. warezc	220	0	121	0	0	0	0	0	0	0	0	0	1	0	0
pred. ipswee	114	0	0	111	0	0	14	1	0	1	0	0	0	0	0
pred. portsw	4	0	0	13	472	0	0	6	0	0	0	0	0	0	0
pred. teardrc	15	0	0	0	0	125	8	22	0	0	0	0	0	0	0
pred. nmap	95	0	0	437	0	0	207	4	1	4	0	0	0	0	0
pred. satan	124	2	0	3	9	14	0	472	4	0	0	0	0	0	0
pred. smurf	18	0	0	0	0	0	0	0	410	7	0	0	0	0	0
pred. pod	15	0	0	1	0	0	1	4	3	18	0	0	0	0	0
pred. back	1986	0	0	0	0	0	0	0	0	0	148	0	0	0	0
pred. guess_	0	0	0	0	0	0	0	0	0	0	0	4	0	0	0
pred. ftp_wri	11	0	1	1	0	0	0	0	0	0	1	0	0	1	1
pred. multih	4	0	0	0	1	0	0	0	0	0	0	0	0	0	0
pred. rootkit	47	0	1	1	0	0	0	0	0	0	0	0	0	0	2
pred. buffer_	16	0	9	0	0	0	0	0	0	0	0	0	0	0	0
pred. imap	0	0	0	0	0	0	0	0	0	0	0	0	0	0	0
pred. warezc	5	0	0	0	0	0	0	0	0	0	0	0	0	1	0
pred. phf	524	0	0	0	0	0	0	0	0	0	1	0	0	0	0
pred. land	0	0	0	0	0	0	0	0	0	0	0	0	0	0	0
pred. loadmv	0	0	0	0	0	0	0	0	0	0	0	0	0	0	0
pred. spy	0	0	0	0	0	0	0	0	0	0	0	0	0	0	0
class recall	69.93%	99.54%	83.45%	19.47%	97.52%	80.65%	88.46%	85.20%	97.16%	58.06%	94.27%	44.44%	0.00%	0.00%	6

Tabla 15: Precisión con Naive Bayes

SimpleDistribution

Distribution model for label attribute Class

Class normal (0.532)
15 distributions

Class neptune (0.328)
15 distributions

Class warezclient (0.007)
15 distributions

Class ipsweep (0.028)
15 distributions

Class portsweep (0.024)
15 distributions

Class teardrop (0.008)
15 distributions

Class nmap (0.012)
15 distributions

Class satan (0.028)
15 distributions

Ilustración 48: Distribución Simple Estudio III

10.6.3.2 Análisis

Naive Bayes utiliza un modelo estadístico para realizar el estudio, por lo cual todo el proceso interno que realiza se resume tan solo en la probabilidad de encontrar la clase que en este tercer estudio se define por cada uno de los ataques; lo cual no nos deja mucho para el análisis como se muestra en la ilustración 48.

10.6.4 Random Forest

10.6.4.1 Modelado

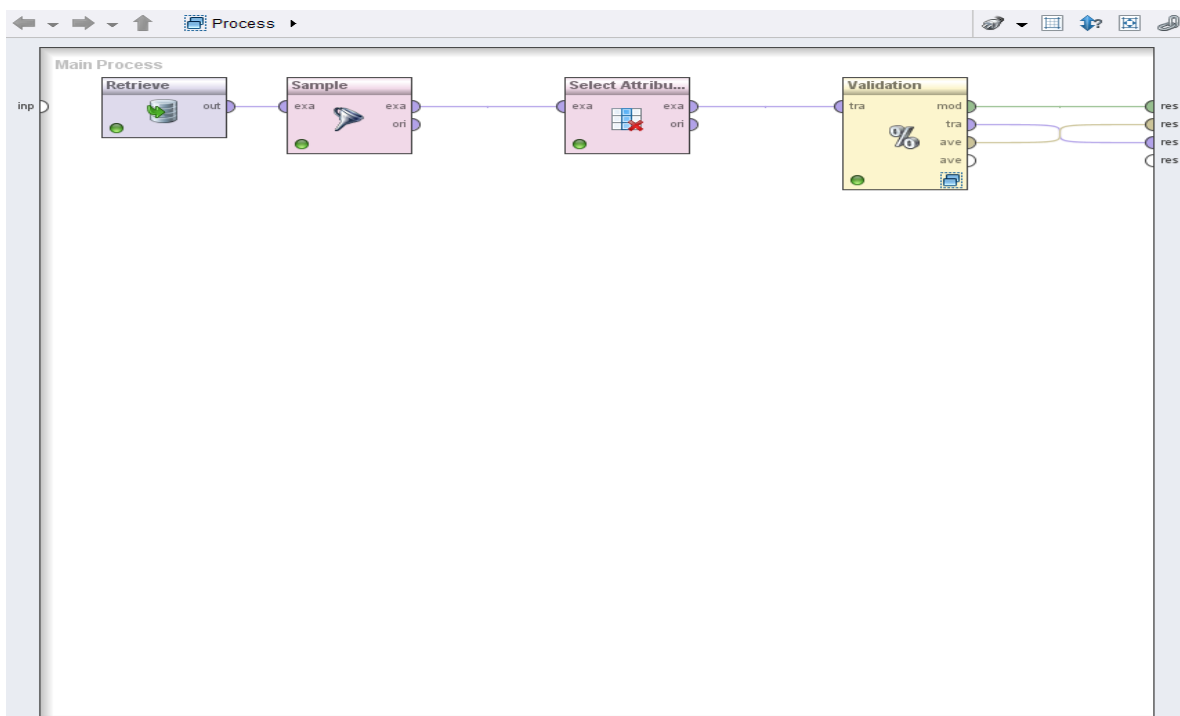


Ilustración 49: Proceso Estudio III (Ataques)

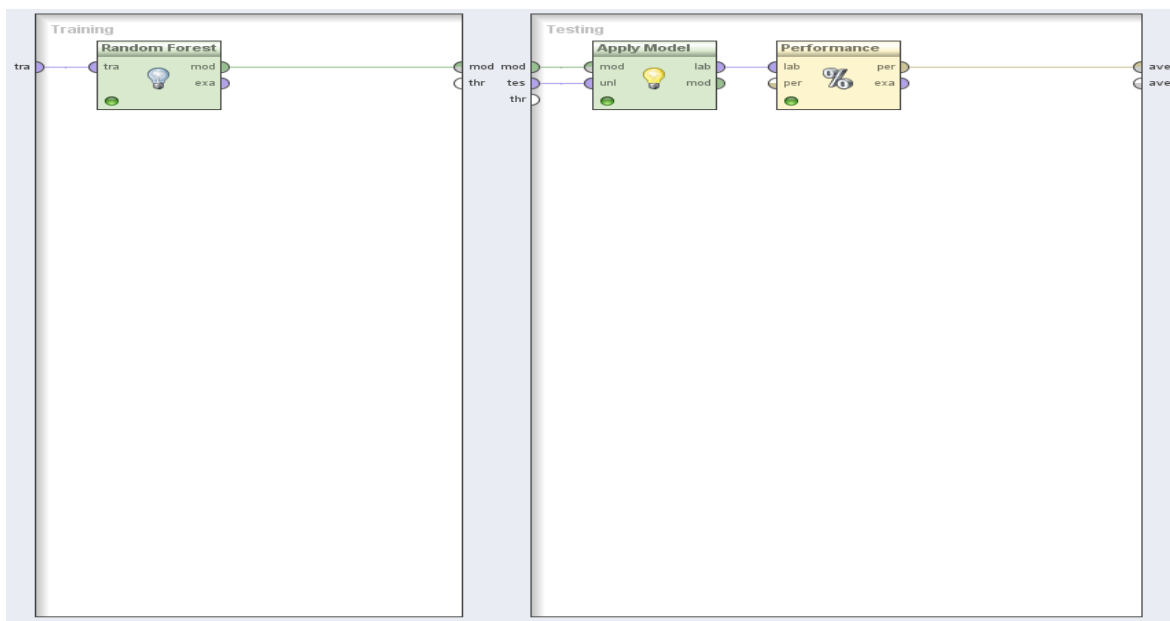


Ilustración 50: Proceso de entrenamiento y prueba Estudio III (Ataques)

Table View Plot View

accuracy: 81.89% +/- 9.75% (mikro: 81.89%)

	true normal	true neptune	true warezc	true ipswee	true portsw	true teardr	true nmap	true satan	true smurf	true pod	true back	true guess_	true ftp_wri	true multih	tr
pred. norma	7940	754	116	320	223	114	146	197	272	22	115	4	0	2	2
pred. neptun	21	4179	0	21	100	3	5	177	11	0	0	0	0	0	0
pred. warezc	0	0	0	0	0	0	0	0	0	0	0	0	0	0	0
pred. ipswee	8	0	0	85	0	0	27	0	16	0	0	0	0	0	0
pred. portsw	0	0	0	0	25	0	0	0	0	0	0	0	0	0	0
pred. teardr	0	0	0	0	0	0	0	0	0	0	0	0	0	0	0
pred. nmap	0	0	0	0	0	0	0	0	0	0	0	0	0	0	0
pred. satan	1	5	0	0	16	0	1	36	0	0	0	0	0	0	0
pred. smurf	0	0	0	0	0	0	0	0	18	0	0	0	0	0	0
pred. pod	0	0	0	0	0	0	0	0	0	0	0	0	0	0	0
pred. back	0	0	0	0	0	0	0	0	0	0	0	0	0	0	0
pred. guess_	0	0	0	0	0	0	0	0	0	0	0	0	0	0	0
pred. ftp_wri	0	0	0	0	0	0	0	0	0	0	0	0	0	0	0
pred. multih	0	0	0	0	0	0	0	0	0	0	0	0	0	0	0
pred. rootkit	0	0	0	0	0	0	0	0	0	0	0	0	0	0	0
pred. buffer_	0	0	0	0	0	0	0	0	0	0	0	0	0	0	0
pred. imap	0	0	0	0	0	0	0	0	0	0	0	0	0	0	0
pred. warezc	0	0	0	0	0	0	0	0	0	0	0	0	0	0	0
pred. phf	0	0	0	0	0	0	0	0	0	0	0	0	0	0	0
pred. land	0	0	0	0	0	0	0	0	0	0	0	0	0	0	0
pred. loadm	0	0	0	0	0	0	0	0	0	0	0	0	0	0	0
pred. spy	0	0	0	0	0	0	0	0	0	0	0	0	0	0	0
class recall	99.62%	84.63%	0.00%	19.95%	6.87%	0.00%	0.00%	8.78%	5.68%	0.00%	0.00%	0.00%	0.00%	0.00%	0

Tabla 16: Precisión con Random Forest

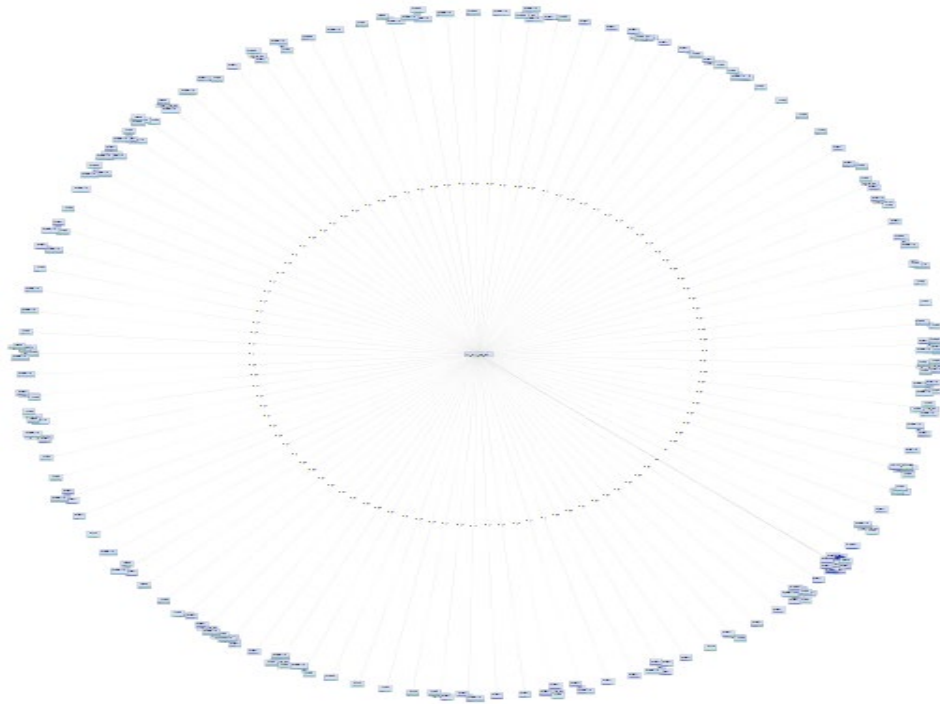


Ilustración 51: Random Forest (Modelo III) Estudio III

10.6.4.2 Análisis

Al realizar el estudio a nivel de todos los tipos de ataques podemos evidenciar que al tomar una muestra de 20.000 registros para el estudio con el modelo de árboles de decisión y luego hacer una selección de las variables para el estudio que se realizó en el punto 10.2 y 10.3, se logra obtener una precisión del modelo de 81.89%; en la ilustración 45 se muestra el árbol generado con los datos del data set y cuál sería la predicción siguiendo el camino de acuerdo a las variables.

De acuerdo al random forest generado en rapidminer a partir de los datos del data set, resultados que se muestran en el apartado árbol de decisión se puede definir la variable FLAG como nuestro nodo principal para poder comenzar la detección de intrusos en una red. También se identificó que cuando los estados de conexión se encuentran entre: S1, S2 y S3 no existe riesgos de ataques.

Se pudo analizar los ataques en base al siguiente criterio:

Estado de la conexión OCH, se identifica el tipo de ataque PORTSWEEP el cual pertenece a la categoría DOS denegación de servicio. Cuando el estado de la conexión es REJ y el número de conexiones al mismo host es elevado se identificaron los ataques SATAN que pertenece a la categoría PROBE indagación y exploración de la red, y los ataques NEPTUNE y PORTSWEEP los cuales pertenecen a la categoría DOS denegación de servicio, vemos que ambos ataques tienen directamente conexión con la red de comunicación.

También se identificaron los ataques TEARDROP que pertenece a la categoría denegación de servicio y el ataque SATAN que pertenece a la categoría exploración de red, estos casos se identificaron cuando el servicio por el cual intentan realizar la conexión es de tipo privado y el tipo de protocolo es UDP el cual permite envío de datagramas a través de la red sin que existe una conexión previa, en estos casos es considerado con esos tipos de ataques.

En el caso donde el tipo de protocolo es TCP se identificó el ataque BACK el cual pertenece a la categoría DOS denegación de servicio, ya que este protocolo se utiliza para la transmisión de datos por internet.

Cuando el tipo de protocolo es ICMP el cual se utiliza para el envío de mensajes de error, se identificaron los tipos de error SMURF el cual pertenece a la categoría de error DOS denegación de servicio y el ataque IPSWEEP el cual pertenece a la categoría PROBE indagación y exploración de red.

También se considera el ataque WAREZCLIENT el cual pertenece al tipo de ataque R2L remoto a local en los casos donde el tipo de servicio es FTP donde este servicio permite compartir archivos desde un repositorio.

11 Conclusiones y Recomendaciones

11.1 Conclusiones

La elección de la técnica, la validación de los resultados y su análisis requieren de una fuerte fundamentación en estadística y de conocimiento del dominio; lo que puede dar lugar, si no se cuenta con ellas, a modelos sin significancia estadística o sin sentido para el dominio en estudio.

Se ha logrado la construcción de los modelos conceptual, lógico y físico para de esta manera determinar los algoritmos más apropiados para los diferentes tipos de ataques en la detección de intrusos en la red de datos, en cada uno de los estudios.

11.2 Recomendaciones

El sistema propuesto se presenta como una plataforma de análisis, más que como un sistema cerrado, al que podrían incorporarse nuevas variables y nuevos análisis que generen a través de otros modelos.

Este estudio podrá ser implementado en un IDS a través de reglas que ayuden a mejorar el performance de rendimiento para detectar una intrusión a la red, a partir del estudio realizado se pueden ir incorporando nuevos ataques que pudieran aparecer en el futuro para lograr que este conocimiento se vea fortalecido y coadyuve con la seguridad en las redes.

Bibliografía

- Béjar, J. (s.f.). Apuntes de Aprendizaje Automático. Catalunya: Universidad Politécnica de Catalunya.
- Borghello, C. (20 de Abril de 2014). *Seguridad de la Información*. Obtenido de <http://www.segu-info.com.ar/proteccion/deteccion.htm>
- Britos, J. D. (1 de Septiembre de 2010). Detección de Instrucciones en redes de datos con captura distribuida y procesamiento estadístico. La Plata, Argentina: Universidad Nacional de La Plata.
- Campoy, D. (2011). Propuesta teórica de Webmining para detección de Intrusos mediante lógica borrosa.
- Carlos Márquez Vera, C. R. (2012). Predicción del Fracaso Escolar mediante Técnicas de Minería de Datos. IEEE-RITA Vol. 7 Núm. 3.
- computer emergency response team for Internet security incidents. (20 de Mayo de 2014). *CERT*. Obtenido de <http://cert.inteco.es/cert/INTECOCERT/?jsessionid=1F07AA82BDE8C7A747C7504C3620A33D?postAction=getCertHome>
- DataPriX. (10 de Noviembre de 2013). *DataPriX is the goal*. Obtenido de <http://www.dataprix.com/blogs/respinosamilla/herramientas-etl-que-son-para-que-valen-productos-mas-conocidos-etl-s-open-sour>
- Definicion.de. (10 de Noviembre de 2013). *Definicion.de*. Obtenido de <http://definicion.de/postgrado/>
- Francisco Javier Díaz, M. A. (2013). Aplicando estrategias y tecnologías de Inteligencia de Negocio. *XV WORK SHOP DE INVESTIGADORES DE CIENCIAS DE LA COMPUTACION*. ENTRE RIOS, PARANA.
- Gonzáles Márquez, V. (2009). Sistema de detección de intrusos basado en sistemas expertos. Distrito Federal, Mexico: Instituto Politécnico Nacional.
- Hellman, W. D. (1976). New Directions in Cryptography. IEEE Transactions on Information Theory, vol. IT-22, num. 6.
- M. Shyu, S. C. (2003). A novel anomaly detection scheme based on principal component classifier. En S. C. M. Shyu, *Proceedings of the IEEE Foundations and New Directions of Data Mining Workshop, in conjunction with the Third IEEE International Conference on Data Mining* (págs. 172–179). IEEE.
- Pereira, R. T. (2007). Detección de Patrones de Bajo Rendimiento Académico y Deserción Estudiantil con Técnicas de Minería de Datos. Nariño, Colombia: Universidad de Nariño San Juan de Pasto.
- Pinzón Trejos, C. I. (2010). Arquitectura multi-agente adaptativa para la detección de ataques en entornos dinámicos y distribuidos. Salamanca, España: Universidad de Salamanca.

- Ponsot, B. E. (2009). Un modelo de regresión logística del rendimiento en los estudios universitarios: Caso FACES–ULA. Venezuela: Revista Actualidad Contable Faces.
- Porcel Eduardo, D. G. (2009). Modelos predictivos y técnicas de minería de datos para la identificación de factores asociados al rendimiento académico de alumnos universitarios. Facultad de Ciencias Exactas y Naturales y Agrimensura Universidad Nacional del Nordeste.
- Scribd. (10 de Noviembre de 2013). *Scribd*. Obtenido de <http://es.scribd.com/doc/19855790/Mineria-de-Datos-y-Data-Warehouse>
- Shannon, C. E. (1949). Communication Theory of Secrecy Systems. Bell System Technical Journal, vol.28-4.
- Sinnexus. (10 de Noviembre de 2013). *Sinnexus Bussines Inteligence*. Obtenido de http://www.sinnexus.com/business_intelligence/datamart.aspx
- Toer, M. (2000). El caso de los ingresantes de 1998 al Ciclo Básico Común de la Universidad de Buenos Aires, para seguir carreras de la Universidad de Derecho, Ciencias Económicas y Ciencias Sociales. Instituto de Investigaciones Gino Germani, Universidad.
- Vallejo, D., & Germán, T. (2012). Minería de datos aplicada en la detección de intrusos. Medellin, Colombia: usbmed.
- Wikipedia. (10 de Noviembre de 2013). *Wikipedia, la enciclopedia libre*. Obtenido de http://es.wikipedia.org/wiki/Miner%C3%ADa_de_datos
- Wikipedia. (10 de Noviembre de 2013). *Wikipedia, la enciclopedia libre*. Obtenido de http://es.wikipedia.org/wiki/Universidad#cite_note-1
- Wikipedia. (10 de Noviembre de 2013). *Wikipedia, la enciclopedia libre*. Obtenido de http://en.wikipedia.org/wiki/Educational_data_mining